
 Avenue V. Maistriau 8a
B-7000 Mons
 +32 (0)65 33 81 54
 scitech-mons@heh.be

WWW.HEH.BE

UE : Cybersécurité

Denis Mandoux

Bachelier en Informatique
Orientation réseaux et télécommunications

Table des matières

1. Introduction au projet.....	(Diapositive 1)	1
2. Introduction à l'UTM Fortigate.....	(Diapositive 60)	30
3. Règles de pare-feu	(Diapositive 113)	66
4. NAT.....	(Diapositive 151)	75
5. Routage	(Diapositive 170)	93
6. VPN IPsec	(Diapositive 200)	100
7. Configuration d'un VPN de site à site	(Diapositive 284)	142
8. Inspection SSL/SSH	(Diapositive 316)	158
9. Filtrage Web	(Diapositive 345)	172
10. Antivirus.....	(Diapositive 386)	193
11. Bibliographie.....	(Diapositive 445)	222

Chapitre 1

Introduction au projet

Projet cybersécurité

- **Le projet**
 - Le projet consiste à déployer et sécuriser plusieurs réseaux locaux interconnectés par deux WAN.
 - **Les réseaux doivent être déployés dans les locaux 2/13 et 2/16.**
 - Deux sites principaux (sites centraux) ayant une architecture hiérarchique (équipes de 2 à 3 étudiants). Un dans le local 2/13, l'autre dans le local 2/16.
 - Des LAN plus petits correspondant à des petites agences distantes d'un site central (équipes de 1 à 2 étudiants). A répartir dans les deux locaux 2/13 et 2/16.
 - **Sécuriser**
 - En déployant des UTM FortiGate.
 - En durcissant la configuration des périphériques réseaux (selon les fonctionnalités disponibles sur le matériel).
 - **Une zone DMZ** devra être déployée dans chaque site central et chaque agence.
 - Soit le serveur web du projet Linux, soit une autre VM (Kali, DVWA).
 - Les PC utilisateurs doivent recevoir leur **configuration IP via DHCP**.
 - **Rédiger la documentation** et la remettre 1 heure avant la fin de la dernière séance de projet.

Projet cybersécurité

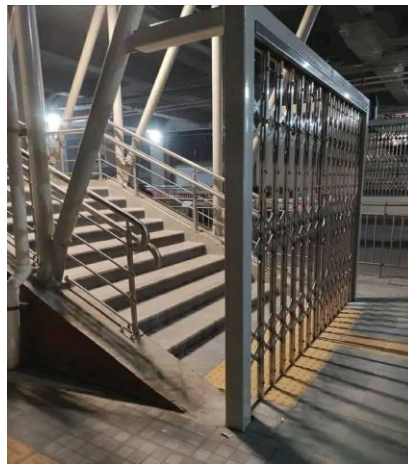
- **Réflexion et méthodologie !**

- Bonnes pratiques
 - Respectez les normes, standard, règles de bonnes pratiques, ...
 - Travaillez avec méthode.
 - Voir méthodologies de l'administrateur.
 - Les référentiels ne disent pas toujours exactement quoi faire dans quelle situation.
 - Réfléchissez.
 - Comprenez ce que vous faites !
 - Vous devez comprendre les commandes que vous validez.
- Je respecte ce que dit la norme → mon travail est bien fait !
- Par exemple :
 - La norme dit de sécuriser l'entrée d'un escalier avec une porte de sécurité grillagée.
 - Vous avez installé une grille, vous êtes donc conforme à la norme (compliant).

Projet cybersécurité

- **Normes, standard, règles de bonnes pratiques**
 - OK, mais surtout réfléchir, analyser, tester, améliorer !

Compliant but not secure !



- Principe de fonctionnement des séances de théorie

- Constat lors de la première séance de TP

- Souvent quasi aucune connaissance théorique.
 - Même après réalisation, ne savent pas expliquer les paramètres configurés.
 - Aucune planification.
 - Ne savent pas quoi faire lors des premiers TP.
 - Ne savent pas quelle documentation/ressource est disponible.
 - Parfois même pas inscrit sur ecampus ni sur teams.
 - « Perdu » face au matériel physique.

- Le temps manque

- Il faut donc être efficace lors des séances TP.
 - Il faut mettre en place une stratégie de travail qui vous convient.

- Principe de fonctionnement des séances de théorie (suite)

- Cours sur les notions essentielles d'un chapitre

- **Tâche 1** réalisée par l'enseignant (environ 30 minutes).

- Mettre en place vos propres techniques de mémorisation

- Sans connaissances, impossible de raisonner sur un problème.
 - **Tâche 2** : vous avez du temps pendant les séances pour mettre en place vos propres techniques de mémorisation (environ 2x20 minutes) sur les notions essentielles.
 - Etudier, créer un résumé, une carte mentale, des flashcards, ...

- Préparer le projet

- **Tâche 3** : vous analysez le projet et planifiez vos séances de TP (environ 40 minutes).

- Testez-vous

- Pour mieux mémoriser, il faut chercher à restituer ce que l'on vient d'apprendre.
 - **Tâche 4** : entraînez-vous en essayant de répondre aux questions de la tâche 1 ou du QCM (environ 10 minutes).

- Hors séance de cours : la méthode des répétitions espacées

- **Tâche 5** : entraînez-vous régulièrement à restituer la matière.

→ Les parcours des leçons sont disponibles sur ecampus

Exercice

- Constitution des équipes
 - Durée : 5 minutes
 - Tâche : regroupez-vous en équipes
 - 2 groupes → 2 projets
 - 2 Équipes dans les sites centraux (voire 3 max)
 - 2 à 3 étudiants pour les sites centraux.
 - Le reste des équipes dans les agences
 - 1 à 2 étudiants.
 - Autant d'équipes que nécessaire.
 - Compléter le fichier sur teams
 - Projet cyber 24-25> Drafts > Projet-Cyber1_ListeEquipes-DRAFT
- [Projet-Cyber1_ListeEquipes-DRAFT.xlsx](#)

Documenter

Documenter

- Garder la maîtrise de son réseau commence par être prêt à documenter



Source : National Security Agency/Central Security Service



9

Documenter

- Pourquoi documenter ?
 - Pour partager des informations
 - Par exemple, s'il y a eu modification
 - Si vous effectuez des modifications de configuration, d'autres personnes doivent probablement en être averties (un autre admin, un client, un chef de projet, ...).
 - Si vous ajoutez une fonctionnalité à un programme (qui sera au courant?).
 - Si quelqu'un d'autre que vous doit intervenir, il a besoin des informations utiles.
 - Utile d'inclure non seulement le **quoi** mais aussi le **pourquoi** des changements.
 - Il faut donc documenter certaines informations et mettre en place un système pour les communiquer
 - Blog, panneau d'affichage, flux RSS, journal de bord, newsletter, document partagé, ...
 - Pour conserver les informations
 - Par exemple, en cas de panne
 - Si vous devez rétablir un périphérique qui a subi une panne critique ou devez supprimer/adapter des modifications préalablement réalisées.
 - Il faut alors définir avec quel niveau de détail on doit documenter



10

Exercice

- Documenter quoi ? De quels documents avons-nous besoin?
 - Objectifs :
 - Créez une liste des documents dont nous pourrions avoir besoin pour la mise en œuvre, la gestion et la sécurisation du réseau.
 - Par exemple : un plan d'adressage, un schéma topologique, ...
 - Consignes
 - Durée : 5 minutes.
 - Tout le monde complète le même document sur Teams : Projet-Cyber1-Doclist-DRAFT.xlsx
 - Dans la colonne « Remarques » de chaque item, indiquer le nom de la personne qui a proposé ce document.

Documenter

- Documentation minimale à réaliser pour le projet
 - Ce qui est indispensable
 - Le plan d'adressage.
 - Plan de nommage.
 - Les schémas topologiques.
 - Procédures de mise à jour/patching.
 - Plan de sauvegarde (minimaliste).
 - Procédure de dépannage et solution apportée.
 - Ce qui fait partie des bonnes pratiques et qui ne prend pas trop de temps
 - Journal de bord.
 - Checklist.
 - To Do List
 - Pour les documents et tâches que l'on aura pas le temps de traiter, créer une To Do list.

- **Comment documenter**
 - **Doit être aussi facile et rapide que possible**
 - **Sinon, risque que personne ne documente.**
 - Règle des 80/20 : 20% des documents peuvent couvrir 80 % des besoins.
 - **Évitez la complexité.**
 - Créer des schémas distincts qui zooment sur les détails.
 - **Mais il peut s'avérer nécessaire d'adopter une approche plus formelle incluant**
 - une autorité centrale de documentation,
 - un système de classification,
 - le suivi et la vérification de la conformité de la documentation.
 - **Documenter mais pas trop et pas n'importe quoi**
 - **La surabondance d'informations nuit à son accessibilité.**
 - Le cas-échéant, intégrez des exemples dans le contenu.
 - **Bien définir quels sont les cas d'usage de la documentation ?**
 - A quoi sert-elle ? A qui sert-elle ? Quand sert-elle (obsolescence) ?
 - On n'écrit pas la même chose si l'information est destinée à un professionnel de l'informatique (doc. Technique) ou pas (manuel utilisateur).

- **Comment documenter (suite)**
 - **Savoir à quoi et à qui va servir la documentation permet de mieux définir ce qu'il faut documenter et avec quel niveau de détail il faut documenter**
 - **Données techniques**
 - Schéma topologique du réseau.
 - Fichiers de configuration du matériel.
 - **Données « logistiques »**
 - Inventaire du matériel.
 - Inventaire des licences.
 - **Liste de contacts**
 - Responsables administratifs, sysadmin (qui est responsable des backup? de quel serveur?).
 - Liste des numéros de téléphone d'urgence: support technique FAI, support technique du fabricant de routeur, ...
 - **Procédures**
 - Procédures documentées et testées de scénarios de sinistre / récupération.
 - Procédure de restauration des sauvegardes.
 - Procédure de création de comptes (droits d'accès, règles de création de mdp, ...)
 - Procédure d'accès à un service.

Documenter

- **Comment documenter (suite)**

- **Charte graphique à respecter, un système déjà en place ?**

- Le cas-échéant, vous devez respecter la charte graphique et le système de documentation/classification mis en place dans l'entreprise.

- **Système de classification des données à respecter ?**

- **Important d'un point de vue sécurité**

- Documents confidentiels, internes, publiques, ...

- **Nécessite de créer une politique de classification**

- Définir quel niveau de classification attribuer à quel document selon quels critères.
- Comment distinguer les différents niveaux de classification? (code couleur, indication).
- De nouveau, plus le système sera simple, plus il a de chance d'être correctement adopté par les utilisateurs.



Documenter

- **Comment documenter (suite)**

- **Informations sur le document**

- **Ne pas oublier de dater la documentation**

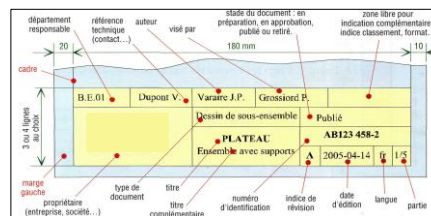
- Permet de savoir à quels moments des modifications ont été réalisées.
- Permet de savoir si un document est encore d'actualité ou obsolète.

- **Indiquer l'auteur du document**

- Et, le cas-échéant, le moyen de le contacter pour signaler une erreur par exemple.
- L'auteur est-il le seul propriétaire du document ou faut-il ouvrir le contenu au collaboratif? Donner le droit de modifier ou à minima de commenter le document?

- **Exemple**

Exemple d'un cartouche



Documenter

- **Comment documenter (suite)**

- **Sauvegarder la documentation**

- La documentation doit faire partie du plan de sauvegarde.

- **Protéger la documentation**

- Si un hacker a accès à la documentation, il pourrait disposer de beaucoup d'informations sensibles.
 - Protection par mot de passe, chiffrement, sauvegarde uniquement locales ou aussi dans le cloud (uniquement des clouds Européen?), système de classification, système DLP (Data leak Prevention).
 - Copie papier ?
 - A conserver dans un endroit sécurisé, limiter le nombre de copies, détruire les anciennes versions.

Documenter

- **Exemple d'informations sur le document**

Projet Cybersécurité - Plan d'adressage
Objectif du document
Ce document est fourni à titre d'exemple pour le projet de l'UE "Networks : Connected and secure". Il contient une liste de points à vérifier pour la mise en œuvre d'un plan d'adressage.
Contact
Mandoux Denis - Maître-assistant Mail : denis.mandoux@heh.be Haute Ecole en Hainaut, Département des Sciences et Technologies 8A, Avenue Maistriaux, 7000 Mons
Confidentialité
Les informations contenues dans ce document sont réservées à un usage interne à la HEH.
Termes et conditions
L'auteur et la HEH n'assument aucune responsabilité pour les erreurs ou omissions dans le contenu de ce document ou de tout document de tiers référencé ou associé, y compris, mais sans s'y limiter, les erreurs typographiques, les inexactitudes ou les informations périmées. Ce document et tous les renseignements qui s'y trouvent sont fournis «tels quels» sans aucune garantie, expresse ou implicite.
Informations sur le document
Nom du document : Checklist-ProjetNCS-AddressingPlan Version : Version 1.0 Niveau de confidentialité : Utilisation interne à la HEH uniquement Auteur du document : Mandoux Denis Date de création : 26/10/2021 Contributeur(s) : / Révisé par : / Date de dernière révision : / Approuvé par : /

– Exemple de journal des modifications (Changelog)

Change Log

Date	Change Description
2020-12-10	Initial release.
2020-12-14	Added VDOM exceptions on page 891. Updated IPsec VPNs on page 1286 chapter.
2021-01-04	Updated Inter-VDOM routing on page 408.
2021-01-05	Updated Software switch on page 413 and Hardware switch on page 415.
2021-01-07	Updated Access control lists on page 1012.
2021-01-08	Updated FortiGuard outbreak prevention on page 1116 and Interface-based traffic shaping profile on page 1080. Added VXLAN over IPsec using a VXLAN tunnel endpoint on page 1535.
2021-01-20	Added Provision a trusted certificate with Let's Encrypt on page 934.
2021-01-21	Updated Matching multiple parameters on application control signatures on page 1205.
2021-01-25	Added GCP SDN connector on page 256. Updated Databases on page 1114 and FortiClient EMS on page 151.

• A faire

– Avant la première séance de projet

- Vous devez avoir réalisé l'inventaire du matériel
 - Permet de vous répartir le matériel.
- Vous devez avoir créé les schémas topologiques.
- Vous devez avoir créé le plan d'adressage.
- Vous devez avoir créé le plan de nommage.
- Vous devez avoir créé la liste des tâches à réaliser dans votre site/agence.
- Vous devez avoir planifié votre travail avant la première séance de projet
 - Par exemple, via l'onglet Tasks dans teams ou un fichier exell.

– Pendant le projet

- Configurer et sécuriser l'infrastructure.
- Vous devez notamment documenter tout changement réalisé sur l'infrastructure du projet.

Exercice

- **Schéma topologique**
 - **Objectifs :**
 - Créez un schéma topologique du réseau à déployer afin de répondre au cahier des charges (disponible sur teams).
 - **Consignes**
 - Durée : 30 minutes.
 - Exercice individuel pendant 15 minutes.
 - Ensuite, faites des groupes de 3 à 5 personnes et continuez l'exercice 15 minutes.

Gestion des vulnérabilités

Programme de gestion des vulnérabilités

- Gestion des vulnérabilités

- Objectifs

- Réduire l'exposition aux risques en atténuant un maximum de vulnérabilités, permettant ainsi de prévenir les attaques ou minimiser leurs incidences.
 - Se conformer à la loi ou aux normes du secteur.

- Principe

- Consiste à **rechercher, évaluer et traiter** les failles de sécurité potentielles.
 - La gestion des vulnérabilités est un processus continu, proactif et souvent automatisé.

- Comment ?

- Il convient de mettre en œuvre un programme de gestion efficace des vulnérabilités.
 - De nombreux outils et solutions peuvent être utilisés pour prévenir et gérer les cybermenaces et faciliter la réalisation d'un programme de gestion des vulnérabilités.
 - Exemples : Qualys VMDR, Rapid7 InsightVM, Nessus, ...

Programme de gestion des vulnérabilités

- Identifier les exigences en matière de gestion des vulnérabilités

- Pourquoi mettre en œuvre une gestion des vulnérabilités?

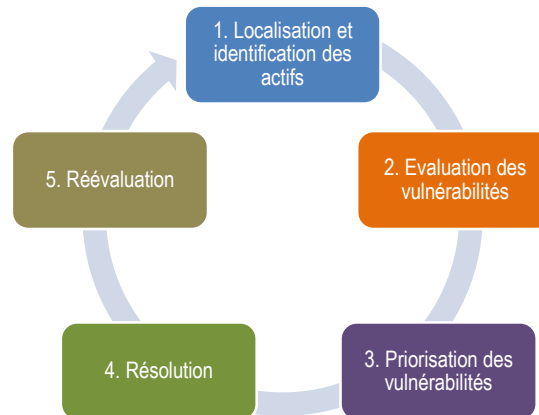
- Le fait de savoir dans quel but une gestion des vulnérabilités doit être réalisée, permet de savoir ce qui devra concrètement être mis en œuvre.
 - Permet aussi de choisir les outils adéquats.
 - Nécessaire pour satisfaire une réglementation ?
 - Certaines réglementations qui régissent la manière dont les organisations stockent, traitent et transmettent les informations peuvent imposer d'effectuer une analyse de vulnérabilités.
 - » HIPAA (santé) et GLBA (financier) ne l'imposent pas.
 - » PCI DSS (cartes bancaires) et FISMA (agences gouvernementales) l'imposent.
 - Doit être réalisé dans le cadre d'un pentest?
 - Imposé par la politique de sécurité de l'entreprise?

Dans tous les cas, la gestion des vulnérabilités est un élément essentiel de tout programme de sécurité de l'information.

Programme de gestion des vulnérabilités

- **Vulnerability assessment program**

- Un programme de gestion des vulnérabilités est un processus continu qui inclut généralement :



Programme de gestion des vulnérabilités

1. Localisation et identification des actifs

- Mettre en place un processus de découverte et de classification des assets

- **Nécessaire car il n'est pas possible de protéger un système dont on ignore l'existence**
 - Quels systèmes, réseaux, services, applications et protocoles seront inclus dans l'analyse de vulnérabilités ?
- **Classification en fonction de l'impact sur l'entreprise et du risque**
 - L'impact et le niveau de risque sont très différents si c'est une imprimante ou l'Active Directory qui est vulnérable ou indisponible.
 - Quel est le niveau de classification des données stockées, traitées ou transmises par le système ?
 - Le système est-il exposé à Internet ou un réseau publique ?
 - Le système est-il en production, test ou développement ?
 - ...
- **L'inventaire complet des assets doit être constamment mis à jour**
 - Car les environnements IT évoluent : applis sur site migrées dans le cloud, appareils mobiles, appareils IoT, assets temporaires, ...

2. Evaluation des vulnérabilités

- Une fois les assets connus, il faut évaluer les vulnérabilités qu'ils recèlent
 - Permet d'avoir une image claire de la surface d'attaque et du niveau de risque.
- Comment rechercher ces vulnérabilités?
 - Avec quels outils et méthodes rechercher les vulnérabilités (scanner, code review) ?
 - Quelle fréquence d'analyse?
 - Quel type de scan? Avec ou sans agent ?
 - Certaines analyses sont-elles susceptibles de perturber l'activité de l'entreprise?
 - Peut-on automatiser le processus?
 - ...

3. Priorisation des vulnérabilités

- Nombreuses vulnérabilités trouvées?
 - Si de nombreuses vulnérabilités critiques sont trouvées, il ne sera probablement pas possible de toutes les corriger dans un délai raisonnable.
- Quelles vulnérabilités corriger en premier? Pas si simple.
 - **Déterminer la valeur de l'asset**
 - Comme vous avez déjà identifié les ressources critiques lors de la phase 1, il est relativement simple de classer chaque ressource par ordre de priorité.
 - **Évaluer l'exposition aux menaces de chaque asset**
 - Il faut déterminer le niveau de risque de chaque ressource et déterminer quelles sont les vulnérabilités et les assets les plus susceptibles d'être exploités.
 - Par exemple, une grave vulnérabilité peut être présente sur un serveur accessible uniquement en interne, la rendant moins susceptible d'être exploitée rapidement.
 - **Evaluer la difficulté de remédier à la vulnérabilité**
 - Vous allez peut-être devoir utiliser les mêmes ressources et temps pour remédier à la vulnérabilité classée 1 que pour celles classées de 2 à 10.

Programme de gestion des vulnérabilités

4. Résolution des vulnérabilités

- Déterminer le meilleur plan d'action pour corriger la vulnérabilité ou minimiser la menace
 - **Accepter le risque**
 - Envisageable (momentanément) pour les systèmes non critiques ou lorsque le risque d'occurrence est très faible ou encore lorsque le coût de protection dépasse le coût de l'actif.
 - **Atténuer la vulnérabilité**
 - Elaborer une stratégie ou mettre en œuvre une technique qui compliquera fortement l'exploitation de la vulnérabilité.
 - La vulnérabilité n'est pas éliminée, mais les protections mises en place diminuent le risque.
 - **Corriger la vulnérabilité**
 - Solution à privilégier, par exemple via l'application d'un correctif.
 - » Idéalement, à tester avant déploiement (sandbox, machine de test, ...)
 - Pas trivial !
 - » Il est parfois difficile d'obtenir des informations précises sur les correctifs à appliquer.
 - » Le cycle de patch prend du temps et peut entraîner des interruptions d'activité.

Programme de gestion des vulnérabilités

5. Réévaluation

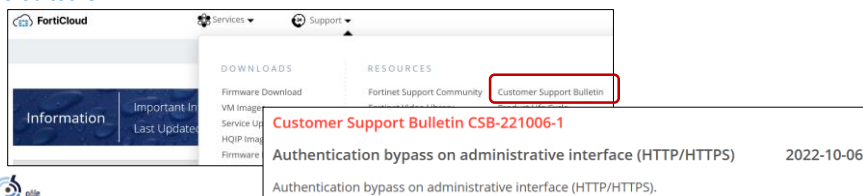
- Vérifier la résolution
 - Il faut s'assurer que la vulnérabilité a bien été corrigée et que le risque pour l'entreprise a bien été réduit.
- Documenter et communiquer
 - **Mettre à jour la liste de vulnérabilités**
 - Supprimer les problèmes corrigés et ajouter les éventuels nouveaux problèmes.
 - **Constituer des rapports**
 - Avec des données faciles à comprendre permet de montrer, à la direction, l'efficacité d'un programme de gestion des vulnérabilités.
 - **Comparer**
 - Certaines solutions vous aident à comparer les performances de votre programme avec celles d'entreprises similaires dans votre secteur.
- Améliorer
 - Chercher à améliorer le programme de gestion des vulnérabilités et renforcer les défenses.

Recherche des vulnérabilités

- Se baser sur le référencement des vulnérabilités
 - Les vulnérabilités sont référencées et classées par le MITRE (CVE).

Name	Description
CVE-2022-45857	An incorrect user management vulnerability [CWE-286] in the FortiManager version 6.4.6 and below VDOM creation component may allow an attacker to access a FortiGate without a password via newly created VDOMs after the super_admin account is deleted.
CVE-2022-42469	A permissive list of allowed inputs vulnerability [CWE-183] in FortiGate version 7.2.3 and below, version 7.0.9 and below Policy-based NGFW Mode may allow an authenticated SSL-VPN user to bypass the policy via bookmarks in the web portal.
CVE-2022-22306	An improper certificate validation vulnerability [CWE-295] in FortiOS 6.0.0 through 6.0.14, 6.2.0 through 6.2.10, 6.4.0 through 6.4.8, 7.0.0 may allow a network adjacent and unauthenticated attacker to man-in-the-middle the communication between the FortiGate and some peers such as private SD-WAN and external cloud platforms.

- Rester informé
 - Consulter les bulletins des CERT (*Computer Emergency Response Team*) et des éditeurs.



Recherche des vulnérabilités

- Analyser et tester le code source des programmes
 - De nombreux défauts peuvent se trouver dans le code source
 - Erreurs de programmation, problèmes de logique, de traitement des erreurs, d'intégration avec d'autres services et systèmes, ...
 - Nécessité d'analyser et de tester le code
 - Diverses méthodes existent telles que
 - **Analyse statique** : analyse du code source sans exécuter le programme.
 - **Analyse dynamique** : exécution du code tout en lui fournissant différentes entrées pour le tester (fuzzing, injection de fautes, ...).
 - Nécessité de tester les modifications
 - Par exemple via des tests de régression pour s'assurer que les corrections mises en place n'ont pas créés de nouveaux problèmes de sécurité.

- **Utiliser des outils d'analyse (scanner)**

- **Solution déployée sur le réseau**

- Peut poser des problèmes d'accès aux assets (Accréditations, pare-feu).
 - Offre une visibilité limitée par rapport à un agent et potentiellement obsolète dès le lendemain de l'analyse.

- **Agent installé sur la ressource à analyser**

- Nécessite l'installation d'un agent sur la ressource.
 - Ne risque t-il pas de dégrader les performance du serveur ou causer des problèmes de stabilité?
 - Certains agents sont assez léger pour être exécutés en continu.

- **Remarque**

- Si un scanner de vulnérabilité ne tentent pas d'exploiter les vulnérabilités identifiées, il peut ne pas donner une idée complète de l'impact probable de l'exploitation ou du niveau de risque.

- **Scanner les vulnérabilités des applications Web**

- **Scanners spécifiques pour les applications Web**

- Ils fournissent un rapport sur les problèmes qu'ils ont découverts et généralement l'endroit où le problème a été trouvé ainsi que des conseils de remédiation.
 - **Exemples d'outils**
 - Acunetix WVS, Arechni, Burp Suite, ApoScan, Web Application Scanner (QualysGuard), Nikto (Projet open-source, en ligne de commande).

- **Scanner de vulnérabilités « classiques »**

- Certains scanners « classique » disposent aussi de fonctionnalités pour scanner les application Web (Nessus, Qualys Guard).

- **Scan manuel**

- Souvent réalisés pour identifier les problèmes que les scanners automatisés pourraient manquer.
 - Utilisés pour s'assurer qu'une vulnérabilité existe réellement (faux positif).
 - Utilisation de proxys d'interception qui permettent de capturer la communication entre le navigateur et le serveur web et de modifier les données envoyées et reçues (TamperData, Burp Suite).

Recherche des vulnérabilités

- **Scanner de vulnérabilités des bases de données**
 - Les DB contiennent souvent des informations sensibles.
 - Généralement pas accessibles directement depuis l'extérieur (NGFW) mais les applications Web peuvent offrir une porte d'entrée.
 - Via des injections SQL par exemple.
 - Il existe des scanner de vulnérabilités spécifiques pour les DB tel que Sqlmap.
- **Divers**
 - Simulateurs de ransomware.
 - Bug bounty.
 - Faire pentester ou auditer son infrastructure.
 - ...

Configurer les outils d'analyse

- **Configurer les outils d'analyse de vulnérabilités (suite)**
 - Définir la portée des analyses de vulnérabilités
 - Quels systèmes, réseaux, services, applications et protocoles seront inclus dans l'analyse de vulnérabilités ?
 - Cela pourrait se limiter aux nouveaux équipements IoT qui viennent d'être déployés.
 - Quelles analyses seront effectués sur quels systèmes ?
 - Certaines analyses sont-elles susceptibles de perturber l'activité de l'entreprise?
 - Peut-on adapter les analyses pour éviter ces perturbations?
 - Peut-on analyser un système de test plutôt que celui en production?
 - Trouver le bon équilibre entre ampleur et fréquence d'analyse
 - Une évaluation approfondie, impliquant des scans authentifiés et avec agent, fournit des données de vulnérabilité très détaillées, mais peut prendre beaucoup de temps et consommer les ressources des assets.

Configurer les outils d'analyse

- Configurer les outils d'analyse de vulnérabilités
 - Maintenir les outils d'analyse à jour.
 - Des failles sont trouvées tous les jours, il est important de maintenir l'outil à jour.
 - Configurer les types de vérifications.
 - Par exemple, désactiver les vérifications liées à des systèmes d'exploitation qui ne sont pas utilisées dans l'entreprise.
 - Par exemple, désactiver les vérifications liées à des protocoles qui sont bloqués par les pare-feux.
 - Attention que l'utilisation de BYOD pourrait permettre d'utiliser ces protocoles interdit derrière un pare-feu périmétrique.
 - Déterminer la localisation de l'analyse
 - De quel endroit du réseau seront lancés les scans?
 - Depuis un agent ou depuis le réseau (Réseau interne? Externe? Les deux? Depuis quel VLAN?)

Configurer les outils d'analyse

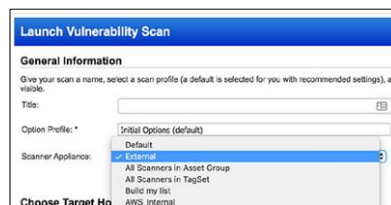
- Configurer les outils d'analyse de vulnérabilités (suite)
 - Niveaux de sensibilité des analyses (Scan sensitivity level)
 - **Plug-in**
 - Chaque plug-in effectue une vérification pour une vulnérabilité spécifique.
 - Ces plug-ins sont souvent regroupés en familles en fonction du système d'exploitation, de l'application ou du périphérique qu'ils impliquent.
 - La désactivation des plug-in inutiles améliore la vitesse de l'analyse. La désactivation de certains plug-in est parfois nécessaire éviter d'avoir un effet néfaste sur l'hôte distant.
 - **Templates**
 - Différents *templates* regroupant une série de scans sont préconfigurés (host discoveries, malware scan, Internal PCI network scan, ...)
 - Possible de créer ses propres templates.
 - **Les paramètres de sensibilité de l'analyse déterminent les types de vérifications que l'analyseur effectuera**
 - Il est rarement utile d'effectuer des analyses complètes en utilisant tous les tests de vulnérabilité disponibles.
 - Souvent, la personnalisation permet que l'analyse atteigne ses objectifs tout en minimisant la possibilité de perturber l'environnement cible.

Configurer les outils d'analyse

- Configurer les outils d'analyse de vulnérabilités (suite)
 - Déterminer le moment et la fréquence des analyses
 - A définir en fonction du contexte
 - Besoin de minimiser au maximum les risques? Fréquence imposée par un règlement? Fréquence limitée par des contraintes techniques ou commerciales?
 - » Par exemple, ne pas surcharger des serveurs par des scans approfondis en pleine période d'intense activités de ces serveurs.
 - Commencer modestement, puis étendre la fréquence et la portée selon les besoins et ressources à disposition.
 - Analyse en continu
 - La tendance consiste à effectuer des analyses permanentes et à la surveillance continue, vérifiant les vulnérabilités aussi souvent que les ressources d'analyse le permettent.

Configurer les outils d'analyse

- Configurer les outils d'analyse de vulnérabilités (suite)
 - Analyse à distance
 - Des dispositifs de sécurité (Fw, IPS, ...) sur le chemin entre le scanner et la cible peuvent affecter les résultats de l'analyse
 - Fournissant donc une vue inexacte de la sécurité de la cible → mieux si l'on connaît la topologie.
 - Les analyses à distance peuvent parfois difficilement confirmer l'existence d'une vulnérabilité (faux positif).
 - Dans ces cas, permettre au scanner de se connecter au matériel (credentialed scan) ou de disposer d'un agent installé améliore la précision de l'analyse.
 - Principe du moindre privilège : utiliser un compte avec accès en lecture seule.



Configurer les outils d'analyse

- Configurer les outils d'analyse de vulnérabilités (suite)

- Analyses furtives

- Repérer un scan de vulnérabilités

- Des scans peuvent générer des interruptions de service, des messages d'erreur et des entrées de journal.
 - Ces éléments peuvent attirer l'attention de l'équipe de cybersécurité et l'amener à ajuster ses défenses, ce qui pourrait entraver le test en cours.

- Scan furtif

- Ce type de scan évite d'utiliser des tests qui pourraient attirer l'attention des équipes sécurité.
 - Utile dans un pentest lorsque l'équipe de cybersécurité de l'organisation n'est pas au courant qu'un test de pénétration est en cours.

- Fournir les informations d'identification pour accéder aux serveurs cibles

- Les scans accrédités nécessitent des identifiants.

Configurer les outils d'analyse

- Configurer les outils d'analyse de vulnérabilités (suite)

- VM et conteneur

- Les communications entre machines virtuelles et/ou applications conteneurisées peuvent avoir lieu entièrement dans les limites de l'environnement de virtualisation.
 - Certains services pourraient alors ne pas être détectés par les analyses basées sur le réseau.
 - Disposer d'un agent installé améliore la précision de l'analyse.

- Automatiser le processus

- Configurer les analyses pour générer des rapports automatiques et un système d'alerte lorsque des vulnérabilités sont découvertes.
 - Le scanner n'est capable de détecter que les vulnérabilités connues, il doit donc être mis à jour régulièrement.

- ...

Exercice

- Recherche de vulnérabilité

- Définir une personne par semaine pour la recherche des vulnérabilités

- Fournir un rapport sur les vulnérabilités concernant le matériel et les logiciels utilisés dans l'infrastructure.
 - Rapport à poster sur Teams (source de la recherche + résultats).

→ Complétez le fichier sur teams (même fichier que la liste des équipes)

Exercice

- Définir les responsables (Durée : 10 minutes)

- Définir un responsable pour chacune des tâches suivantes.

- Le schéma topologique, la plan adressage, le plan de nommage, l'inventaire, procédures de mise à jour (3 personnes : FortiGate, Sw, R), la conformité sécuritaire.

- Définir un responsable par semaine pour la recherche des vulnérabilités

- Fournir un rapport sur les vulnérabilités concernant le matériel et les logiciels utilisés dans l'infrastructure.
 - Rapport à poster su Teams (source de la recherche + résultats).

- Définir un responsable par site/agence pour la vérification de la sécurité

- Vérification de la conformité du site/agence par rapport au CCB Cyberfundamentals Framework.

- Un responsable n'est pas nécessairement celui qui fait tout mais celui qui s'assure que c'est fait.

- Par exemple, chaque groupe réalise le schéma topologique de son site/agence.

→ Complétez le fichier sur teams (même fichier que la liste des équipes)

Exercice

- Plan d'adressage

- Objectifs :

- Créez un plan d'adressage permettant de planifier l'attribution des adresses IP aux équipements du réseau.

- Consignes

- Durée : 30 minutes
 - Exercice individuel pendant 15 minutes.
 - Ensuite, faites des groupes de 3 à 5 personnes et continuez l'exercice 15 minutes.

Exercice

- Plan de nommage

- Objectifs :

- Créez un plan de nommage permettant de définir l'attribution des noms de machines aux équipements du réseau.

- Consignes

- Durée : 30 minutes
 - Exercice individuel pendant 15 minutes.
 - Ensuite, faites des groupes de 3 à 5 personnes et continuez l'exercice 15 minutes.

Exercice

• Inventaire du matériel

– Objectifs :

- Mettez à jour l'inventaire du matériel disponible pour la réalisation du projet.
- Vérifiez si la quantité de matériel disponible est suffisante pour la réalisation du projet.
- Attribuez le matériel aux sites/agences.

– Consignes

- 6 personnes (2 par armoire réseau)
- 2 personnes (2 armoires « stock ») + ajouter aussi les consommables

Exercice

• Planification des tâches

– Objectifs :

- Chaque site/agence doit créer sa liste des tâches qui devront être réalisées afin de disposer d'un réseau fonctionnel et sécurisé.
 - Ce début de liste pourra être complété au fur et à mesure des séances de cours théorique (voir tâches 3 de ces séances).
- Cette liste vous permettra de planifier vos séances de TP.

• Travail d'équipe

– Chaque étudiant réalise une partie des tâches du projet global.

- Si vous travaillez régulièrement à plusieurs sur la même tâche, le projet n'avancera pas.
- Pour chaque tâche réalisée, un seul étudiant sera noté.

Organisation du travail

- Travail d'équipe

- Chaque étudiant réalise une Partie des tâches du projet global.

- Si vous travaillez régulièrement à plusieurs sur la même tâche, le projet n'avancera pas. Pour chaque tâche réalisée, un seul étudiant sera noté.

Exemple : configurer l'accès (SSH, IP, user) sur le routeurs et le switch de sa topologie = 1 tâche (car copier-coller).
 Configurer l'accès au FortiGate = une autre tâche.

Cyberfundamentals Framework

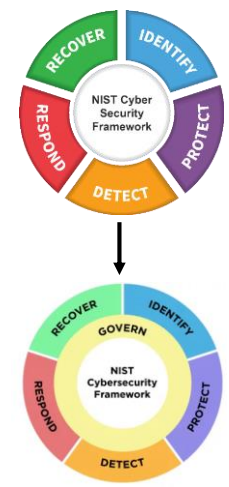
CCB Cyberfundamentals Framework

- CCB (Center for Cybersecurity Belgium)
 - Autorité nationale en charge de la cybersécurité en Belgique.



CCB Cyberfundamentals Framework

- CCB Cyberfundamentals Framework
 - Le cadre des cyberfondamentaux de la CCB
 - Ensemble de mesures concrètes visant à :
 - protéger les données,
 - réduire de manière significative le risque des cyber-attaques les plus courantes,
 - accroître la cyber-résilience d'une organisation.
 - Le cadre est construit autour de cinq fonctions principales :
 - **Identifier** : Connaître les menaces cyber et gérer les risques relatifs aux actifs essentiels.
 - **Protéger** : Mettre en place des mesures de protection pour atténuer les risques.
 - **Détecter** : Assurer une détection rapide des événements de cybersécurité.
 - **Répondre** : Mettre en place des contrôles pour réagir aux incidents de cybersécurité et en limiter l'impact.
 - **Récupérer** : Mettre en œuvre des mesures pour restaurer les services après un incident cyber.
 - **Gouvernance** (NIST 2.0) : Importance de l'aspect décisionnel de la cybersécurité.



CCB Cyberfundamentals Framework

- « Niveau d'assurance »

- Small, basic, essential, important

- Pour répondre à la gravité de la menace à laquelle une organisation est exposée plusieurs niveaux « d'assurance » sont proposés.
- **Small** : permet à une organisation de procéder à une première évaluation de sécurité, destiné aux micro-organisations ou aux organisations ayant des connaissances techniques limitées.
- **Basic** : contient les mesures de sécurité de l'information standard pour toutes les entreprises, utilisant des technologies et des processus qui sont généralement déjà disponibles.
- **Important** : conçu pour minimiser les risques de cyberattaques ciblées par des acteurs disposant de compétences et de ressources communes, en plus des risques connus en matière de cybersécurité.
- **Essential** : va plus loin et répond également au risque de cyber-attaques avancées menées par des acteurs disposant de compétences et de ressources étendues.

CCB Cyberfundamentals Framework

- CCB Cyberfundamentals Framework :

- SMALL

Table of Contents

Introduction.....	3
1 PROTECT ALL LOGINS WITH MULTI-FACTOR AUTHENTICATION	4
2 INSTALL ALL SECURITY UPDATES IMMEDIATELY	4
3 INSTALL ANTIVIRUS.....	5
4 SECURE YOUR NETWORK.....	5
5 BACKUP YOUR DATA	6
6 ADMINISTRATION RIGHTS	6
7 FINAL RECOMMENDATIONS	7

CCB Cyberfundamentals Framework

- CCB Cyberfundamentals Framework :
– Essential

Table of Contents

Introduction	6
IDENTIFY	
ID-AM-1: Physical devices and systems used within the organization are inventoried	8
ID-AM-2: Software platforms and applications used within the organization are inventoried	9
ID-AM-3: Organizational communication and data flows are mapped	10
ID-AM-4: External information systems are catalogued	11
ID-AM-5: Resources are prioritized based on their classification, criticality, and business value	12
ID-AM-6: Cybersecurity roles, responsibilities, and authorities for the entire workforce and third-party stakeholders (e.g., suppliers, customers, partners) are established	13
ID-BE-1: The organization's role in the supply chain is identified and communicated	14
ID-BE-2: The organization's place in critical infrastructure and its industry sector is identified and communicated	14
ID-BE-3: Priorities for organizational mission, objectives, and activities are established and communicated	15
ID-BE-4: Dependencies and critical functions for delivery of critical services are established	15
ID-BE-5: Resilience requirements to support delivery of critical services are established for all operating states (e.g. under duress/attack, during recovery, normal operations)	16
ID-GV-1: Organizational cybersecurity policy is established and communicated	17

DE-DE-2: Detection activities comply with all applicable requirements	63
DE-DE-3: Detection processes are tested	63
DE-DE-4: Event detection information is communicated	63
DE-DE-5: Detection processes are continuously improved	64
RESPOND	
RS-RP-1: Response plan is executed during or after an incident	65
RS-CO-1: Personnel know their roles and order of operations when a response is needed	66
RS-CO-2: Incidents are reported consistent with established criteria	66
RS-CO-3: Information is shared consistent with response plans	67
RS-CO-4: Coordination with stakeholders occurs consistent with response plans	67
RS-CO-5: Voluntary information sharing occurs with external stakeholders to achieve broader cybersecurity situational awareness	67
RS-AN-1: Notifications from detection systems are investigated	68
RS-AN-2: The impact of the incident is understood	68
RS-AN-3: Forensics are performed	69
RS-AN-4: Incidents are categorized consistent with response plans	69
RS-AN-5: Processes are established to receive, analyse, and respond to vulnerabilities disclosed to the organization from internal and external sources	70
RS-MI-1: Incidents are contained	71
RS-MI-2: Incidents are mitigated	71
RS-MI-3: Newly identified vulnerabilities are mitigated or documented as accepted risks	71
RS-IM-1: Response plans incorporate lessons learned	72
RS-IM-2: Response and Recovery strategies are updated	72
RECOVER	
RC-RP-1: Recovery plan is executed during or after a cybersecurity incident	73
RC-MI-1: Recovery plan is continuously improved	74

Cyberfundamentals Framework - BASIC

- ID-AM-1
– Inventaire des équipements physiques.
 - Fonction : Identifier (ID)
 - Catégorie : Asset Management (AM)
 - Sous-catégorie : 1
- ID-AM-2
– Inventaire des plateformes logicielles, des applications et des bases de données.



The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy.

ID-AM-1: Physical devices and systems used within the organization are inventoried.

An inventory of assets associated with information and information processing facilities within the organization shall be documented, reviewed, and updated when changes occur.

Guidance

- This inventory includes fixed and portable computers, tablets, mobile phones, Programmable Logic Controllers (PLCs), sensors, actuators, robots, machine tools, firmware, network switches, routers, power supplies, and other networked components or devices.
- This inventory must include all assets, whether or not they are connected to the organization's network.
- The use of an IT asset management tool could be considered.

References

CIS Controls V8 (ETSI TR 103 305 1 V4.1.1), Critical Security Control 1
IEC 62443-2-1:2010, Clause 4.2.3.4
IEC 62443-3-3:2013, SR 7.8
ISO/IEC 27001:2022 (NBN ISO/IEC 27001:2023), Clause 7.5, 8.1, Annex A (see ISO 27002)
ISO/IEC 27002:2022 (NBN EN ISO/IEC 27002:2022), Control 5.9, 5.11, 7.9, 8.1

Cyberfundamentals Framework - BASIC

- ID.AM-3 : *Organizational communication and data flows are mapped*
 - Dressez une liste des types de données traitées
 - Par exemple, données clients, données financières, données RH, données de production, etc.
 - Définir les flux de données
 - Cartographiez les itinéraires empruntés par les données pour circuler dans et en dehors de votre organisation. Les flux de données peuvent être représenté graphiquement pour plus de clarté.
 - Par ex. les données clients transitent du site Web vers le logiciel CRM via une API REST. (Navigateur → serveur Web → API CRM).
 - Outils : Visio, draw.io, Lucidchart, ...
 - Identifiez les utilisateurs, systèmes ou entités tiers impliqués dans chaque flux de données
 - Équipes *marketing* et *finance* ont accès aux données clients, données stockées sur le serveur CRM. Données transmises aux partenaires XX et YY via une API sécurisée.
 - Identifiez les risques et vulnérabilités potentielles dans chaque flux
 - Par ex. absence de chiffrement des données client sur le serveur.

Cyberfundamentals Framework - BASIC

- ID.AM-3 : *Organizational communication and data flows are mapped (cont.)*
 - Identifiez les risques et vulnérabilités potentielles dans chaque flux
 - Par exemple, absence de chiffrement des données client sur le serveur, transfert des données via un canal non chiffré, authentification simple par mot de passe pour l'accès aux données sur le serveur.
 - Appliquer des contrôles
 - Par exemple, chiffrer les données stockées sur le serveur, implémentation de TLS pour les flux API sensibles, restriction des accès au système à partir d'adresses IP internes, journalisation des appels API pour surveiller les flux, ...

Chapitre 2

Introduction à l'UTM FortiGate

Cours basé sur FortiOS 7.4

Objectifs

- A l'issue de ce chapitre, l'étudiant doit être capable de
 - Dessiner une architecture réseau simple protégée par un pare-feu périmétrique.
 - Se connecter à un UTM FortiGate.
 - Configurer les accès d'administration.
 - Configurer les interfaces et une passerelle par défaut.
 - Configurer l'UTM pour qu'il agisse en tant que serveur DHCP.
 - Choisir entre le mode de fonctionnement NAT/route et transparent.
 - Sauvegarder et restaurer un fichier de configuration.
 - Mettre à jour le firmware de l'UTM.

Introduction

- FW → NGFW + Fabric
 - Les pare-feux sont devenus des dispositifs multifonctionnels
 - Filtrage Web, IPS, contrôle d'application, proxy, routage, antivirus, DLP, VPN, DNS, DHCP, ...
 - Ils peuvent être déployés pour jouer différents rôles afin de répondre à différentes exigences
 - Pare-feu de nouvelle génération
 - Pare-feu de segmentation interne
 - Pare-feu de data center
 - Pare-feu distribué
 - Ils peuvent faire partie d'un écosystème de sécurité
 - Fortinet Security Fabric : Les différents équipements peuvent s'échanger des informations.

Administration du FortiGate

- FortiGate
 - Solution hardware
 - **Avantages**
 - Dimensionnée pour supporter le nombre d'utilisateurs précisé par le modèle.
 - Peut intégrer des puces spécialisées pour accélérer certains traitements de données.
 - **Security Processing Units (SPU)**
 - Content processors (CP)
 - Security processors (SP)
 - Network processors (NP)
 - System-on-a-Chip Processor (SoC) : CP + NP.
 - Solution virtualisée (FortiGate VM)
 - **Déploiement, démontage et adaptation plus rapides**
 - Intéressant dans les réseaux à grande échelle qui changent rapidement (SDN).
 - VMware, Hyper-V, KVM, Citrix Xen Server, Azure, Amazon AWS, ...
 - **Même fonctionnalités mais pas d'accélération matérielle**

Administration du FortiGate

• Administration du FortiGate

– Connexion CLI

- RJ45-série + émulateur de terminal.
- USB vers FortiExplorer.
- Via le réseau : SSH, Telnet.

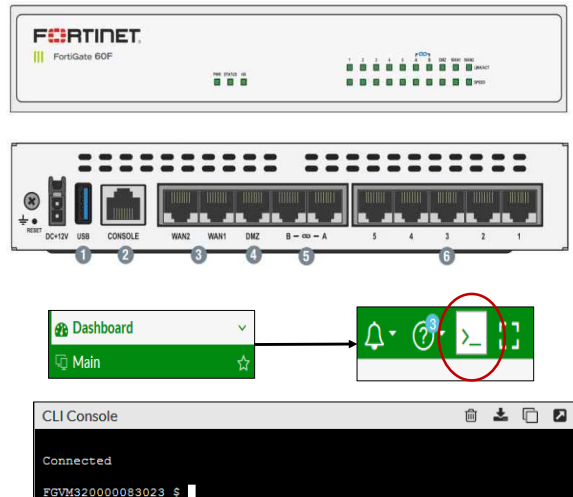
– Modes d'administration

• GUI et CLI

- CLI permet de scripter les configurations.

• FortiExplorer

- Compatible iOS et Android.



Administration du FortiGate

• Configuration par défaut

– Adresse IP par défaut : 192.168.1.99/24

- Entrée de gamme: interface "port1" ou "internal".
- Milieu et haut de gamme : interface de gestion dédiée (MGMT).

– Protocoles activés par défaut sur cette interface

- SSH, HTTPS, PING.
- Entrée de gamme : DHCP server activé sur l'interface "port1" ou "internal"

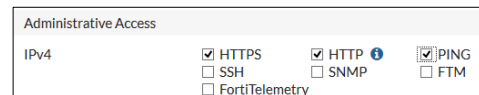
– Identifiants par défaut

- User : admin
- Password : (champ vide)

• **ATTENTION : Les deux champs sont sensibles à la casse.**

– Accès console disponible

- Via un émulateur de terminal (PuTTY, Tera Term,...).



Administration du FortiGate

- Administration du FortiGate (suite)

- Commandes CLI

- Système d'aide (commande suivie du caractère « ? »).

- Exemples

- # get system status

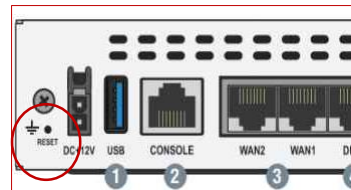
```
FGT60D4Q16066986 # get system status
Version: FortiGate-60D v5.2.13,build0762,171212 (GA)
Virus-DB: 16.00560(2012-10-19 08:31)
Extended DB: 1.00000(2012-10-17 15:46)
IPS-DB: 5.00555(2014-10-07 01:21)
IPS-ETDB: 0.00000(2001-01-01 00:00)
Serial-Number: FGT60D4Q16066986
...
```

- # show system interface ?

Administration du FortiGate

- Autres commandes utiles

- Reset du boîtier possible via un bouton sur la face arrière.



```
# execute ping 172.20.120.16
# execute factoryreset
```

```
# config system interface
edit <interface name>
set ip <ip_address> <netmask>
set allowaccess ping http https ssh
end
```

```
# get router info routing-table all

S>* 0.0.0.0/0 [10/0] via 172.30.147.254, port1
C>* 169.254.0.0/16 is directly connected, haport0
C>* 172.30.144.0/22 is directly connected, port1...
```


- Virtual Domain

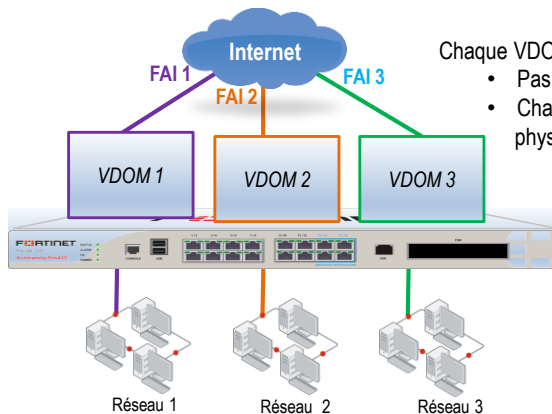
- Domaine virtuel

- **Les VDOM sont une virtualisation au sein de FortiOS**
 - Ils permettent de disposer de plusieurs pare-feux virtuels sur un équipement unique.
 - **Permet de subdiviser les stratégies de sécurité en plusieurs domaines**
 - Chaque VDOM possède des politiques de sécurité et des tables de routage indépendantes.
 - **Permet d'attribuer des comptes administrateurs différents pour la gestion des différents VDOM**

- Chaque interface est membre d'un seul VDOM.

- **Les VDOM sont comme des périphériques indépendants**
 - Par défaut, le trafic d'un VDOM ne peut pas aller vers un autre VDOM.
 - Deux interfaces dans des VDOM différents peuvent avoir la même adresse IP, sans problèmes de chevauchement.
 - **L'interface sur laquelle un paquet arrive détermine quel VDOM traite le trafic**

- Multi VDOM : exemple 1, VDOM indépendants

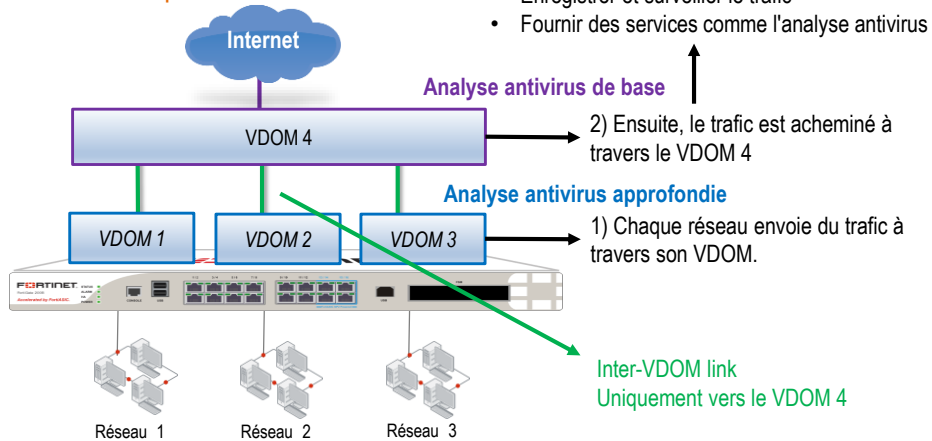


Chaque VDOM est complètement séparés des autres

- Pas de communication entre les VDOM.
- Chaque VDOM dispose de sa propre interface physique vers Internet.

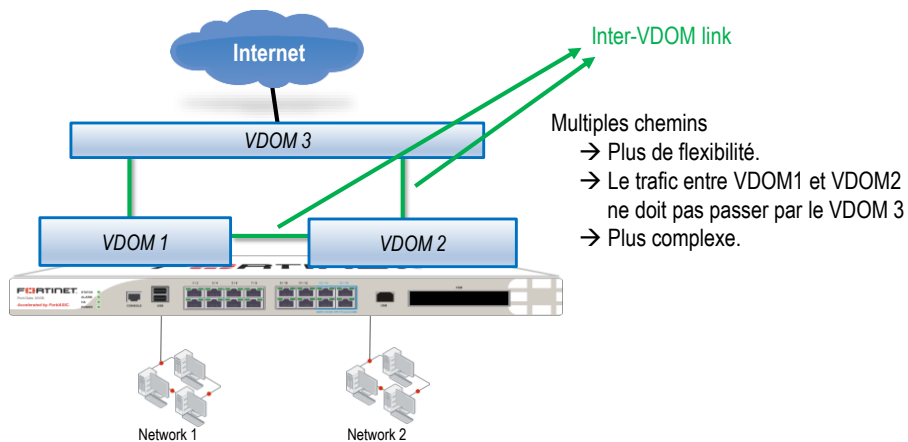
VDOM

• Multi VDOM : exemple 2



VDOM

• Multi VDOM : exemple 3, VDOM maillés



Administration du FortiGate

• Types de comptes

– System > Administrators

- **Local user** = compte local
- **Remote** = AD ou LDAP
- **PKI** = certificat numérique

☐ SMS
☐ Two-factor Authentication
☐ Restrict login to trusted hosts
☐ Restrict admin to guest account provisioning only

Dashboard > Security Fabric > FortiView > Network > System > **Administrators** > Admin Profiles

+ Create New
 Administrator

REST API Admin
 SSO Admin

New Administrator

User Name: admin1
 Type: **Local User**
 Match a user on a remote server group
 Match all users in a remote server group
 Use public key Infrastructure (PKI) group

Password:
 Confirm Password:
 Comments: Write a comment...
 Administrator Profile: super_admin
 Email Address:

Administration du FortiGate

• Administrator Profiles

– Les profils administrateurs

- Sont associés à un compte administrateur.
- Définissent ce que l'administrateur peut faire une fois connecté avec tel compte.

– Le profil *super_admin*

- Il a tous les droits, par défaut ce profil est utilisé par le compte *admin*.
- Ce profil ne peut pas être modifié ou supprimé.

– Le profil *prof_admin*

- Par défaut, il a tous les droits mais uniquement sur son VDOM.
- Pas d'accès aux paramètres globaux

– Les profils personnalisés (custom)

- On donne accès à ce que l'on souhaite
 - RO ou RW ou Pas d'accès.

Administrator Profile: super_admin

Access Permissions

Access Control	Permissions	Set All
Security Fabric	None Read Read/Write	
FortiView	None Read Read/Write	
User & Device	None Read Read/Write	
Firewall	None Read Read/Write Custom	
Log & Report	None Read Read/Write Custom	

☒ Override Idle Timeout
 Never Timeout ☐
 Offline 10 1-480 minutes

Permet d'augmenter le délai d'inactivité par profil

Administration du FortiGate

- Options des profils

Two-factor authentication

Deux méthodes d'authentification sont utilisées pour autoriser l'accès.

Restrict login to trusted hosts

L'administrateur peut uniquement se connecter à l'UTM à partir des adresses ou étendues d'adresses IP spécifiées. 0.0.0.0/0 autorise n'importe quelle IP

Administration du FortiGate

- Options des profils (suite)

- Exemple avec un FortiToken (à acheter).

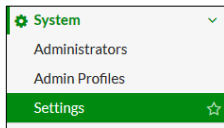
- Le FortiToken devra être préalablement enregistré sur l'équipement.
- Le FortiToken génère un code à entrer sur le boîtier en plus de son mot de passe.



Password
+
FortiToken



Administration du FortiGate



L'accès HTTPS et le portail SSL
 utilisent le port 443.
 → modifier le port HTTPS.

Minuteur d'inactivité.
 Commun à tous les profils.

Vous pouvez autoriser ou refuser
 les connexions concurrentes.

Administration Settings

HTTP port: 80

Redirect to HTTPS: ☐

HTTPS port: 443

HTTPS server certificate:

SSH port: 22

Telnet port: 23

Idle timeout: 5 Minutes (1 - 480)

Allow concurrent sessions: ☒

Password Policy

Password scope: ☐ Off ☒ Admin ☐ IPsec ☐ Both

Minimum length: 8

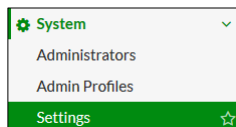
Character requirements: ☐

Allow password reuse: ☒

Password expiration: ☐

Administration du FortiGate

- Password Policy
 - Vous pouvez définir des règles pour la création de mots de passe forts.



Password Policy

Password scope: ☐ Off ☒ Admin ☐ IPsec ☐ Both

Minimum length: 8

Character requirements: ☒

Upper case: 0

Lower case: 0

Numbers (0-9): 0

Special: 0

Allow password reuse: ☒

Password expiration: ☒ 90 Days

Administration du FortiGate

- System settings et interfaces

The screenshot shows the FortiGate configuration interface. On the left, the 'Edit Interface' window is open for 'port3'. It shows fields for Name, Alias, Type (Physical Interface), Role (Undefined), Address (10.0.1.254/255.255.255.0), and Administrative access. The 'Administrative access' section for IPv4 has checkboxes for HTTPS, FMG-Access, TELNET, Security Fabric Connection, HTTP, SSH, FTM, PING, SNMP, and RADIUS Accounting. The 'Administration Settings' window on the right shows ports for HTTP (80), HTTPS (443), Telnet (23), and SSH (22), along with an Idle Timeout of 30 and a checked 'Allow multiple concurrent' option. A red arrow points from the 'Administrative access' section to the 'Administration Settings' window. A red box with text is also present.

Le choix des protocoles est adaptable à chaque interface.

Administration du FortiGate

- Protocoles dont le FortiGate est le destinataire

- Security Fabric Connection

- FortiTelemetry

- Utilisé pour la gestion des FortiClients et de la « Security Fabric ».
- » N'est pas utilisé pour l'accès administratif au FortiGate.

- CAPWAP

- Utilisé pour la gestion de FortiAP, FortiSwitch et FortiExtender depuis un FortiGate.

- FMG-Access

- Utilisé spécifiquement pour communiquer avec des équipements FortiManager.

- RADIUS accounting

- Utilisé lorsque le FortiGate a besoin d'écouter et de traiter des paquets RADIUS dans le cas d'une authentification unique (SSO).

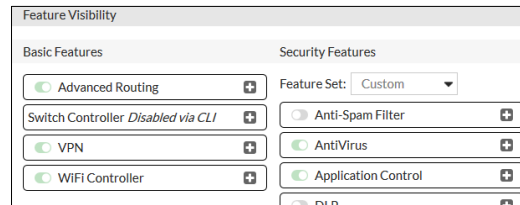
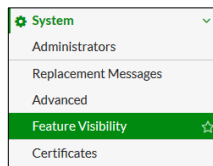
- FTM (FortiToken Mobile)

- Utilisé pour prendre en charge les demandes d'authentification provenant d'une application FortiToken Mobile.

Administration du FortiGate

• Fonctionnalités masquées

- Certains paramètres et fonctions ne sont pas accessibles directement
 - Des paramètres de débogage notamment sont accessibles uniquement en CLI.
 - D'autres sont masqués par défaut pour des raisons d'ergonomie.
- On peut faire apparaître (ou masquer) certaines de ces fonctions via
 - **System > Features Visibility**

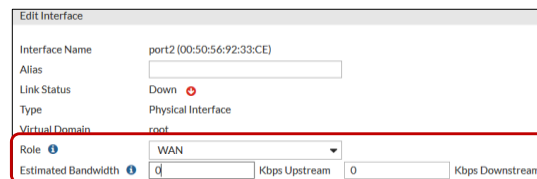
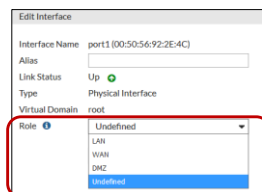
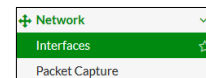


Les fonctions masquées dans le GUI ne sont pas désactivées

Administration du FortiGate

• Configurer une interface en mode NAT

- **Interface role**
 - Permet d'afficher dans la GUI uniquement les paramètres utiles pour ce rôle.
 - Évite certaines erreurs de configuration.
- Quatres types
 - LAN, WAN, DMZ, Undefined.
 - "Undefined" donne accès à tous les paramètres de l'interface.



Paramètres disponibles pour une interface de type WAN

Administration du FortiGate

- Configurer une interface en mode NAT (suite)

- Alias

- Client DHCP

Distance administrative de la passerelle par défaut.

Policy & Object > IPv4 Policy

Seq.#	Name	Source	Destination	Schedule	Service	Action	NAT
5	vpn_WinPhoneVPN_remote	WinPhoneVPN_range	all	always	ALL	Accept	Enabled

Administration du FortiGate

- Agrégation de liens

- Utilise LACP.
- Maximum 4 interfaces physiques.

- Interfaces VLAN

- Les interfaces peuvent être :

- Physiques

- Les trames envoyées ou reçues par une interface physique ne sont jamais étiquetées, elles appartiennent au VLAN natif.

- Logiques (par exemple les interfaces VLAN)

- Une interface physique peut être "divisée" en deux ou plusieurs interfaces logiques.

- Le tag VLAN identifie à quel VLAN appartient une trame.

- FortiGate en mode NAT/route

- Agit au niveau de la couche 3 (réseau), les tags VLAN peuvent être

- ajoutés (en sortie),

- supprimés (en entrée),

- réécrits en fonction d'une décision de routage (routage inter-VLAN).

- Une interface L2 peut ajouter/supprimer mais pas modifier le tag VLAN

- Internal interface

Par défaut, interfaces commutées.

Status	Name	Members	IP/Netmask	Type	Access	Ref.
Hardware Switch (1)						
	internal		172.16.1.254 255.255.255.0	Hardware Switch (6)	PING HTTPS SSH SNMP HTTP FMG-Access CAPWAP	2
Physical (4)						
	dmz		10.10.10.1 255.255.255.0	Physical Interface	PING HTTPS HTTP FMG-Access CAPWAP	0

VLAN

- Isoler une interface

Enlever une interface du groupe

Ajouter une interface au groupe

VLAN

- Créer et configurer une interface VLAN

Route statique par défaut

- Configurer une passerelle par défaut

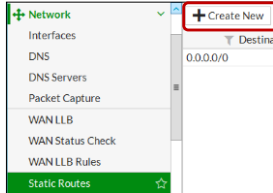
- DHCP

- Le FortiGate peut obtenir dynamiquement sa configuration de passerelle par défaut via un serveur DHCP (du FAI par ex.).

- Configuration statique

- Une route par défaut est généralement nécessaire pour pouvoir communiquer avec les réseaux distants (Internet par exemple).

Network > Static Routes



Spécifique à Fortinet
Voir chapitre sur le routage

Serveur DHCP

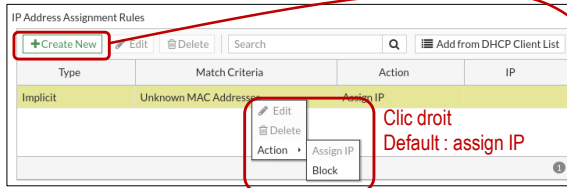
- Serveur DHCP en mode NAT

- Chaque interface peut fournir un pool DHCP différent.

Network > Interfaces

Serveur DHCP

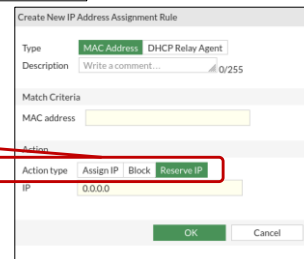
- **Serveur DHCP en mode NAT (suite)**
 - Network > Interfaces > IP Address Assignment Rule > Create New



Clic droit
Default : assign IP

Permet de

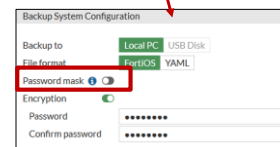
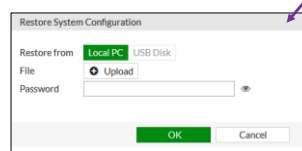
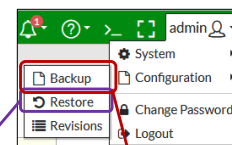
- Toujours réassigner la même IP au même hôte.
- Empêcher une adresse MAC de recevoir une IP
- Lier une adresse IP à une adresse MAC.



92

Sauvegarde et restauration

- **Sauvegarde et restauration**
 - Exporter la configuration dans un fichier (sur un périphérique externe)
 - Le fichier de configuration peut être chiffré (optionnel).
 - S'il y a des VDOM, on peut sauvegarder leur configuration individuellement.
 - Sauvegarde automatique lors de la fermeture de la session.
 - Uniquement disponible sur certains modèles.
 - Restaurer une configuration
 - La restauration est uniquement possible
 - Sur un même modèle d'équipement.
 - Ayant le même firmware si le fichier est chiffré.
 - La restauration nécessite le redémarrage du boîtier.



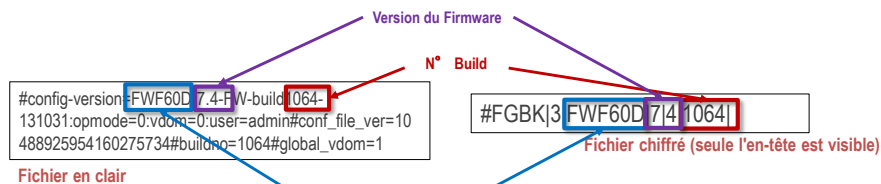
93

Sauvegarde et restauration

Fichier de configuration

Format du fichier de configuration

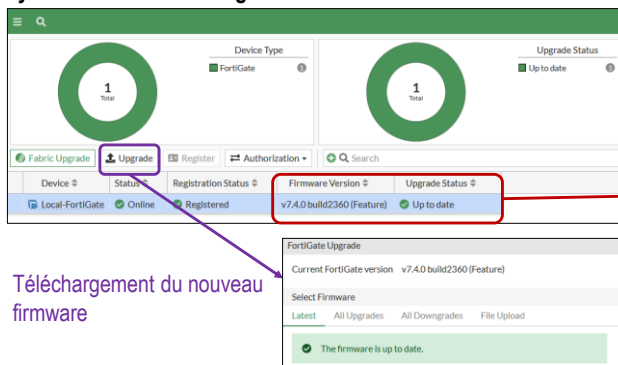
- Contient uniquement les paramètres modifiés et quelques paramètres par défaut mais essentiels (→ taille réduite).
- L'en-tête renseigne le Firmware et le modèle de FortiGate.
- Si le fichier est chiffré, la restauration est uniquement possible si
 - Le FortiGate est de même modèle et de même Firmware/Build
 - Le mot de passe est fourni.
 - Non chiffré, seul le même modèle est requis.



Mise à jour

Mise à jour du Firmware

System > Firmware & Registration



Version courante et notification de nouvelle version.

Téléchargement du nouveau firmware

ATTENTION de lire la « release notes » et de respecter « l'upgrade path »
<https://docs.fortinet.com/upgrade-tool>



Mise à jour

- Mise à jour du Firmware (suite)

Upgrade Path Tool Table

Choose a product:

FortiGate / FortiOS

Product Model

FortiGate-60F

Current Version

7.0.0

Target Upgrade Version

7.4.1F

Recommended Upgrade Path

Following is the recommended migration path for your product

Version	Build Number	Release Notes
7.0.0	0066	Release Notes
7.0.7 F	0367	Release Notes
7.2.3 F	1262	Release Notes
7.4.0 F	2360	Release Notes
7.4.1 F	2463	Release Notes

Mise à jour

- Etapes de mise à jour du Firmware

- Sauvegarder la configuration
- Télécharger une copie du firmware actuel
 - Dans le cas où il faudrait revenir à la version antérieure.
- Se connecter en console
 - Permet de réagir rapidement si la mise à jour ne fonctionne pas.
- Lire la release notes
 - Chaque version de FortiOS a sa propre version de configuration.
 - Pour passer d'une version à une autre il faut s'assurer que l'upgrade path est supporté par le FortiGate.
 - L'upgrade path et les bugs connus sont renseignés dans la release notes.
- Mettre à jour

Mise à jour

- **FortiGate**

- Fortiguard Subscription Services (FSS)

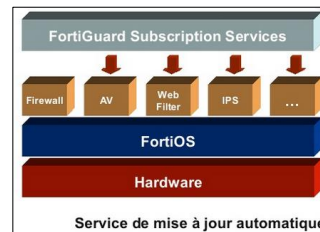
- Les éléments de l'UTM (FW, AV, IPS, ...) se connectent au service FSS pour télécharger les mises à jour, monitorer les licences, etc.

- Mises à jour

- **Antivirus, IPS**
 - update.fortiguard.net
 - TCP port 443 (SSL)

- Requêtes en temps réel

- **Filtrage Web, filtrage DNS et Antispam**
 - service.fortiguard.net
 - Protocole propriétaire en UDP port 53 ou 8888
 - securewf.fortiguard.net
 - En HTTPS port 443, 53 ou 8888



Source : Source : Fortinet Training Services. Introduction to Fortinet UTM

Mise à jour

- **Fortiguard Subscription Services (FSS)**

- Le Fortiguard Distribution Network (FDN) est un réseau mondial de serveurs

- Il distribue des mises à jour aux périphériques Fortinet.
 - FortiGate, FortiMail, FortiWeb, ...
 - Une dizaine de serveurs primaires.
 - Une centaine de serveurs secondaires.
 - Nécessite un contrat FSS.

- FortiManager

- Outil de gestion et de mise à jour centralisé pour les grandes installations (Via FDN).
 - Nécessite un contrat FSS.



Mise à jour

Fortiguard Subscription Services (suite)

– Caractéristiques

- Le mode d'accès par défaut est de type anycast.
- La connexion est forcée en HTTPS port 443.
- FGT obtient une seule IP pour le nom de domaine de chaque service FortiGuard.
- Depuis FortiOS 6.4, la vérification des certificats SSL tiers et de l'agrafage OCSP ont été implémentées pour tous les serveurs FortiGuard (4h, 7j).
- Liste des serveurs : <https://docs.fortinet.com/document/fortigate/6.4.0/ports-and-protocols/622145/anycast-and-unicast-services>

Server	Domain name and IP address
Object download	globalupdate.fortinet.net - 173.243.140.6
Querying service (webfiltering, antispam)	globalguardservice.fortinet.net - 173.243.140.16
FortiGate Cloud logging	globallogctrl.fortinet.net - 173.243.132.25
FortiGate Cloud management	globalmgrctrl.fortinet.net - 173.243.132.26
FortiGate Cloud messaging	globalmsgctrl.fortinet.net - 173.243.132.27

Mise à jour

System information

Dashboard > Status

System Information	
Hostname	FortiGate-VM_Demo
Serial number	FGVMMLTM24023123
Firmware	v7.4.5 build2702 (Mature)
Mode	NAT
System time	2024/12/19 04:18:31
Uptime	5d 17h 36m 25s
WAN IP	96.45.36.73

System > FortiGuard

License Information		
Entitlement	Status	
Advanced Malware Protection	✔ Licensed (Expiration Date: 2025/03/28)	
Attack Surface Security Rating	✔ Licensed (Expiration Date: 2025/03/28)	
Data Loss Prevention (DLP)	✔ Licensed (Expiration Date: 2025/03/28)	
Email Filtering	❗ Expired (Expiration Date: 2024/04/15)	Renew
Intrusion Prevention	✔ Licensed (Expiration Date: 2025/03/28)	
Operational Technology (OT) Security Service	⚠ Not Licensed	Purchase
Web Filtering	✔ Licensed (Expiration Date: 2025/03/28)	

FortiGuard Updates

Next Update: 2024/12/19 04:24:00

[Update Licenses & Definitions Now](#)

❗ Unable to connect to FortiGuard servers.

Compléments

Introduction au FortiGate

Firewall policies

Introduction

- **FortiGate**
 - UTM
 - Unified Threat Management (FW, IPS, antivirus, filtrage Web, DLP, ...)
 - Sources de documentation
 - <https://www.fortinet.com>
 - <https://docs.fortinet.com> (best practices, hardening, admin guide, ...)
 - <https://community.fortinet.com/> (Knowledge Base)
 - <https://video.fortinet.com> (Fortinet Video Library)
 - <https://www.youtube.com/user/SecureNetworks> (Fortinet's YouTube channel)
 - <https://support.fortinet.com> (Enregistrer les boitiers, ouvrir des tickets de support, ...)
 - <https://www.fortiguard.com> (conseils, infos sur les menaces, ...)
 - <https://www.fortinet.com/blog> (Fortinet Blog)
 - FortiGate Demo
 - Accès à une VM en ligne (en RO, nombreux menus non disponibles).
 - <https://fortigate-vm.fortidemo.com/>

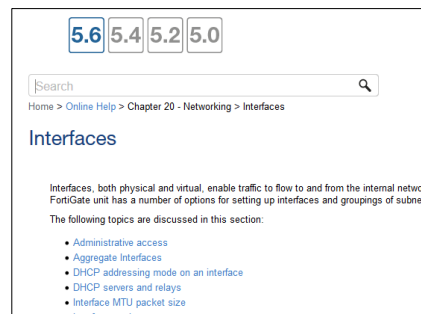
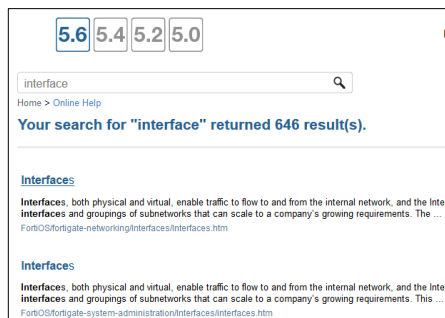
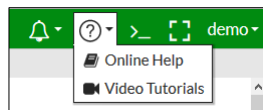
Introduction

- Programme de certification NSE (Network Security Expert)



Administration du FortiGate

- Aide en ligne



Administration du FortiGate

- Aide en ligne (suite)

5.6 5.4 5.2 5.0 Home Video FortiGuard

Search

Home > Online Help > Chapter 20 - Networking > Interfaces > Administrative access

Administrative access

Interfaces, especially the public-facing ports, can potentially be accessed by those who may not want to have access to the FortiGate unit. When setting up the FortiGate unit, you can set one or more protocols that an administrator must use to access the FortiGate unit, including:

- HTTPS
- Ping
- FortiManager Access (FMG-Access)
- CAPWAP
- SSH
- SNMP
- FTM
- RADIUS Accounting
- FortiTelemetry

The following example adds an IP address 172.20.120.100 to the WAN1 interface, as well as administrative access to HTTPS and SSH. As a good practice, set administrative access when you are setting the IP address for the port.

To add an IP address on the WAN1 interface - web-based manager

1. Go to **Network > Interface**.
2. Select the WAN1 interface row and select **Edit**.
3. Select the **Addressing Mode of Manual**.
4. Enter the IP address for the port of 172.20.120.100/24.
5. For **Administrative Access**, select **HTTPS** and **SSH**.
6. Select **OK**.

To create an IP address on the WAN1 interface - CLI

```
config system interface
edit wan1
set ip 172.20.120.100/24
```

Administration du FortiGate

- Configurer une interface
 - En mode NAT/route, une interface est inutilisable tant qu'elle n'a pas d'adresse IP(*).

Network Interfaces Packet Capture

Physical	Name	IP/Netmask	Type	Access	Virtual Domain	Ref
port1	172.30.72.73/255.255.255.0	Physical Interface	PING HTTPS SSH SNMP	root	2	
port2	0.0.0.0/0.0.0.0	Physical Interface	HTTP	root	0	
port3	0.0.0.0/0.0.0.0	Physical Interface		root	0	

Addressing mode: Manual | DHCP | **Auto-managed by FortiPAM** | One-Arm Sniffer

IP/Netmask: 10.128.6.1/255.255.255.0

Network size: 256 (255.255.255.0)

Create address object matching subnet

PPPoe (masquée par défaut)

FortiGate-VM64 (port2) # set mode pppoe

(*) Permet d'utiliser l'interface pour sniffer le trafic (Promiscuous mode). L'interface n'a pas d'IP, elle ne peut pas envoyer de trafic.

Service payant, FortiPAM permet d'attribuer automatiquement des adresses IP en fonction de la taille du réseau configuré. Evite les chevauchements d'adresses au sein de la même Security Fabric.

Récupération de mot de passe

- Récupérer l'accès administrateur (Non valable sur les VM)

- Se connecter en console

- Éteindre puis démarrer le matériel. Pas un reboot, il faut éteindre physiquement le FortiGate.

- Entrer le login en moins de 60s

- Login : maintenir
 - Password : bcpb<N°-de-série>
 - Toutes les lettres du numéro de série doivent être en lettres capitales.
 - "bcpb" et le n° de série doivent être accolés (Par exemple **bcpbFGT60F3G10AK6F23**).

```
.....
Reading boot image 126540 bytes
Initializing firewall...
System is started
Login: maintainer
```

- Modifier le mot de passe

- Vous obtenez un accès à la console pour modifier le mot de passe.

```
# config system admin
edit admin
set password MotDeP@sse
end
```

Si VDOM activé :

```
# config global
config system admin
edit admin
set password MotDeP@sse
end
```



108

Administration du FortiGate

- Deux modes de fonctionnement (Modes of Operation)

- 1) Transparent mode (bridge mode)

- **Le FortiGate est « transparent », au même titre qu'un commutateur de couche 2**
 - Il n'est pas vu comme un équipement de couche 3 à traverser.
 - Il ne route pas les paquets mais commute les trames en fonction des adresses MAC.
- **Toutes ses interfaces sont situées dans le même réseau**
 - Une seule adresse IP, utilisée pour la gestion du périphérique.
- **Certaines fonctionnalités ne sont pas disponibles**
 - Par ex. : Policy-based routing ou passerelle SSL.
- **Utilisation**
 - Pour inspecter le trafic lorsque la modification de la configuration du réseau lui-même n'est pas envisageable.
- **Attention aux boucles de couche 2**
 - L'introduction d'un équipement de couche 2 pourrait créer une/des boucles.



109

Administration du FortiGate

2) NAT/route mode

- **Fonctionne dans la couche 3 OSI**
 - Chaque interface est dans un sous-réseau distinct et dispose de sa propre IP.
 - Interfaces inutilisables tant qu'une IP n'est pas configurée.
 - » Sauf en mode One-Arm-Sniffer
 - Se base sur la table de routage pour transférer les paquets.
- **Protection périmétrique**
 - Mode généralement utilisé lorsque le FortiGate est situé entre le réseau privé et les réseaux publics.
 - Permet au FortiGate de masquer les adresses IP du réseau privé à l'aide de la NAT.
- **Internal Segmentation Firewall (ISFW)**
 - Peut aussi être utilisé pour protéger plusieurs segments d'une infrastructure réseau.

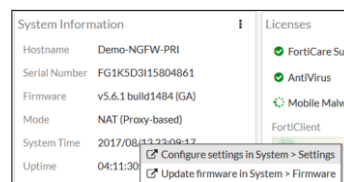
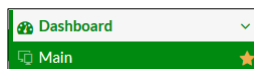


– Important de choisir le mode au début de l'installation

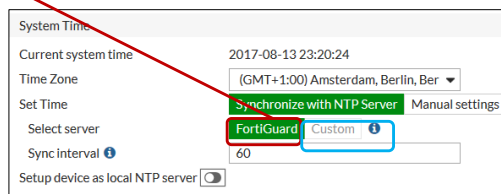
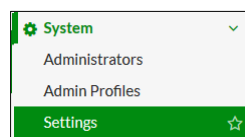
- Un changement de mode effacera une bonne partie de la configuration réalisée dans l'autre mode.

NTP

• Configurer l'horloge

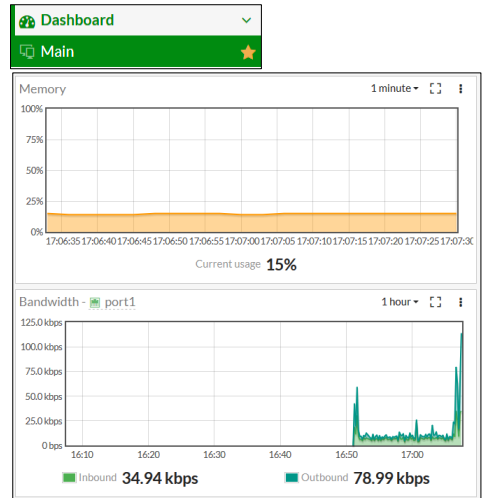


Synchronisation avec les serveurs FortiGuard



Dashboard

- **System information**
 - De nombreux widget sont disponibles dans le dashboard offrant de la visibilité sur l'ensemble des fonctions du FortiGate.



Chapitre 3

Règles de pare-feu

Firewall policies

Objectifs

- A l'issue de ce chapitre, l'étudiant doit être capable de
 - Identifier les composantes d'une règle de pare-feu.
 - Identifier comment le pare-feu établit une correspondance entre le trafic et les règles de pare-feu.
 - Configurer et gérer des règles de pare-feu.
 - Gérer les journaux de trafic des règles de pare-feu.
 - Choisir et configurer le mode d'inspection des paquets.

Firewall Policies

- Règles de pare-feu (Policy & Objects > Firewall Policy)

– Caractéristiques

Nouvelle
session

- Une règle définit à quel trafic elle s'applique et comment traiter ce trafic.
- Importance de l'ordonnancement des règles : la 1^{ère} correspondance s'applique.
- Règle par défaut : deny all (Policy0).

– Critères

- Interfaces source et destination (From, To).
- Adresses IP Source et destination.
- Horaire (Schedule).
- Service (Protocole et numéro de port).

On ne peut pas la supprimer
 La seule option modifiable est
 la journalisation

Si correspondance → Action

Tous doivent correspondre

Seq.#	Name	From	To	Source	Destination	Schedule	Service	Action	NAT	Security Profiles	Log	Bytes
1	Implicit Deny	☐ any	☐ any	☐ all	☐ all	☒ always	☒ ALL	☒ DENY			☒ Disabled	0 B

Firewall Policies

• Règles de pare-feu (suite)

– Action = Accept

- Si le trafic est autorisé par la règle, alors l'UTM inspecte les profils de sécurité.



Seq.#	Name	From	To	Source	Destination	Service	Action	NAT	Security Profiles	Log
2	Mobile	lan	wan1	all Mobile Devices	all	DNS HTTP HTTPS	✓ Accept	✓ Enabled	WEB PROX SSL	✓ All
3	Internet	lan	wan1	all	all	DNS HTTP HTTPS	✓ Accept	✓ Enabled		✓ All
4	Implicit Deny	any	any	all	all	ALL	Deny			✗ Disabled

- Si les profils de sécurité laissent passer le trafic, l'UTM vérifie si d'autres traitements doivent être appliqués.
 - Authentification, NAT, journalisation, QoS, ...

Firewall Policies

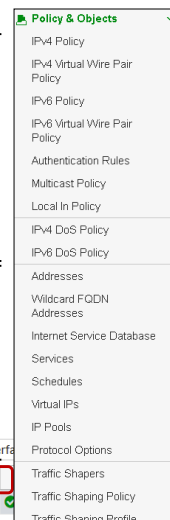
• Règles de pare-feu (suite)

– Différents types de règles

- Certains critères de correspondance ne sont pas utilisables dans tous les cas.
 - Par exemple certains critères IPv6 pour du trafic IPv4.
- Dès lors, il existe plusieurs types de règles de pare-feu.

– Différents objets utilisés dans les règles

- Certains objets sont prédéfinis, d'autres peuvent être créés.
- Exemples d'objets :
 - Interface, zone, adresse, utilisateur, service, profils de sécurité...



Seq.#	Name	From	To	Source	Destination	Schedule	Service	Action	NAT	Security Profiles
1	Implicit Deny	any	any	all	all	always	ALL	Deny		

Firewall Policies

• Règles de pare-feu (suite)

– Vue par paire d'interfaces

- **Par défaut, les règles sont classées par paires d'interfaces**
 - Par exemple, les règles pour LAN vers DMZ sont classées dans une autre section que celles pour LAN vers WAN.
- **La règle par défaut (Implicit, Policy0) interdit tout type de trafic**
 - On ne peut ni modifier, ni supprimer cette règle.

– Ordre des règles

- Il est possible de modifier l'ordre des règles par un simple "glisser/déposer".

Indique l'ordre de traitement des règles

Policy & Objects > Firewall Policy

Seq	Name	Source	Destination	Schedule	Service	Action	NAT
1	Test2	all	all	always	ALL	Accept	Enabled
2	port3 - port1 (2 - 7)	all	all	always	PING	Deny	Disabled
3	Full_Access	all	all	always	ALL	Accept	Enabled
	Implicit (1 - 1)	all	all	always	ALL	DENY	Enabled

Firewall Policies

• Règles de pare-feu (suite)

– Vue par séquence

- Il est également possible de classer les règles par numéro de séquence.

– Identification d'une règle

- **Attention** : le numéro de séquence change lorsque l'on déplace une règle.
- C'est la colonne **ID** (masquée par défaut) qui **identifie** réellement une règle.

ID	Name	From	To	Source	Destination	Schedule	Service	Action
2	Block_FTP	LAN (port3)	ISP1 (port1)	all	all	always	FTP	DENY
1	Full_Access	LAN (port3)	ISP1 (port1)	LOCAL_SUBNET	DMZ	always	ALL	ACCEPT
3	DMZ	LAN (port3)	DMZ (port2)	DMZ	all	always	ALL	ACCEPT
4	Block_ICMP	any	any	all	all	always	ALL_ICMP	DENY

Seq	Source	Destination	Schedule	Service	Action	NAT
1	all	all	always	ALL	ACCEPT	Disable
2	all	all	always	ALL	DENY	

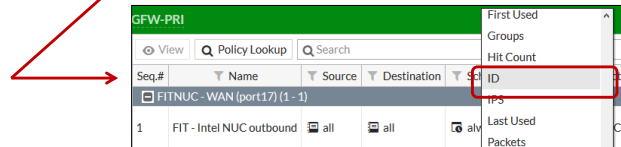
Si une des règles s'applique à un groupe ou à toutes les interfaces (en entrée ou en sortie), le mode par séquence est le seul utilisable.

Firewall Policies

• Règles de pare-feu (suite)

– Ajouter la colonne ID dans l'affichage GUI (conseillé)

- Un clic droit dans la ligne de menu ouvre un menu contextuel.



– Identification d'une règle en CLI

- En CLI, une règle est toujours identifiée par son ID (pas par son numéro de séquence).

```
config firewall policy
  move <policy_id> {before | after} <policy_id>
end
```

Firewall Policies

• Règles de pare-feu (suite)

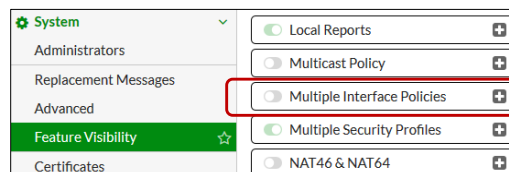
– Zone

- Une zone est un regroupement d'interfaces (physiques et/ou virtuelles).
- Les zones permettent de faciliter la configuration des règles de pare-feu.

– Multiple Interface Policies

- Par défaut, en GUI il est seulement possible d'utiliser une interface individuelle comme interface d'entrée (incoming) ou de sortie (outgoing).

Pour utiliser plusieurs interfaces (ou toutes les interfaces : any), il faut activer l'option "Multiple Interface Policies" depuis le menu "Feature Visibility".



Firewall Policies

• Règles de pare-feu (suite)

– Configurer une zone

- Il faut supprimer toute référence à une interface pour pouvoir l'ajouter à une zone.



- Une fois associées à une zone, vous ne pouvez plus faire référence à cette interface individuellement.

Network > Interfaces

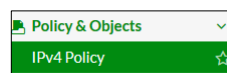
+ Create New ▾				By Type		By Role	Alphabetically
Interface				Name	IP/Netmask	Type	
Zone							
Virtual Wire Pair				port1	10.200.1.1 255.255.255.0	Physical Interface	
				port2	10.200.2.1 255.255.255.0	Physical Interface	
				port3	10.0.1.254 255.255.255.0	Physical Interface	
				port8	0.0.0.0 0.0.0.0	Physical Interface	
				port9	0.0.0.0 0.0.0.0	Physical Interface	
				port10	0.0.0.0 0.0.0.0	Physical Interface	
Zone (5)							
				DMZ		Zone	
				port4	192.168.1.1 255.255.255.0	Physical Interface	
				port5	192.168.10.1 255.255.255.0	Physical Interface	
				port6	192.168.20.1 255.255.255.0	Physical Interface	
				port7	0.0.0.0 0.0.0.0	Physical Interface	

Firewall Policies

• Règles de pare-feu (suite)

– Création ou modification d'une règle de pare-feu

- Soit "Create new" soit éditer la règle sélectionnée.



Always
Recurring
One time
↓
Pre-expiration event log

Quand doit s'appliquer la règle

Les services autorisés ou refusés

L'action à effectuer

Interfaces source et destination

Objets Source et destination

Name = Mandatory!

Name: FSA-Mgmt Access
 Incoming Interface: WAN (port17)
 Outgoing Interface: FSA-DMZ
 Source: all
 Destination: FSA-Slave-IP, FSA-VIP
 Schedule: always
 Service: ALL_ICMP, HTTP, HTTPS, OFTP, SSH, SYSLOG
 Action: ACCEPT, DENY, LEARN, IPsec

Firewall Policies

- Correspondance de la source (Matching by source)

- Il est **nécessaire** de définir au moins une source.

- Il est possible de définir plus précisément la source en spécifiant d'autres paramètres :

- Un utilisateur source.
- Un périphérique source.
- ...

Firewall Policies

- Correspondance de la source (suite)

- La source **DOIT** être définie par un des éléments suivants :

- Une adresse ou un ensemble d'adresses IP.
- Un réseau ou sous-réseau.
- Une zone géographique.
- Un FQDN.
- L'adresse d'un Fabric connector (adresse dynamique).
- Un objet de la base de données "Internet service" (ISDB).

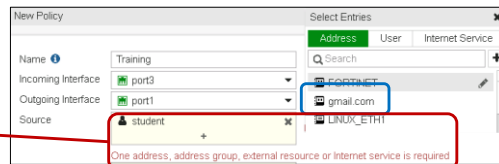


L'UTM doit pouvoir faire des
résolution de noms

Firewall Policies

- **Correspondance de la source (suite)**
 - La source **PEUT**, en plus d'un objet adresse, être définie par :
 - **Un utilisateur ou un groupe d'utilisateurs source :**
 - Un compte local.
 - Un compte sur un serveur distant (Active Directory, LDAP, RADIUS).
 - FSSO (Fortinet Single Sign-On).
 - Un utilisateur PKI (certificate).
 - **Un périphérique source**
 - Peut être défini manuellement sur l'UTM ou via le service "Device Identification".

Un utilisateur ne peut pas
être utilisé seul comme source
du trafic



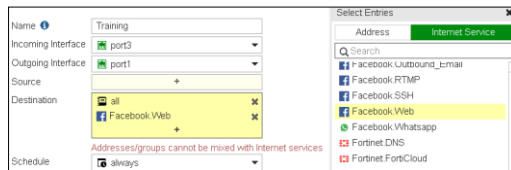
Firewall Policies

- **Correspondance de la destination (Matching by Destination)**
 - Comme la source, la destination doit être définie par :
 - Une adresse ou un ensemble d'adresses IP.
 - Un réseau ou sous-réseau.
 - Un FQDN.
 - Une zone géographique.
 - L'adresse d'un Fabric connector.
 - Un objet de la base de données "Internet service"
- **Internet Service DataBase (ISDB)**
 - **Base de données**
 - Elle contient une liste d'adresse IP, de protocoles et de numéros de port utilisés par les services Internet les plus courants.
 - Elle est mise à jour régulièrement par Fortiguard.

Name	Rep...	Direction	
Internet Service Database	3/1403		
Microsoft Outlook	5	Both	1,021
Google Google Bot	4	Source	31
Facebook Whatsapp	5	Destination	1,823

Firewall Policies

- **Internet Service (suite)**
 - **Source d'une règle de pare-feu**
 - Si Internet Service est utilisé dans le champ source d'une règle, il n'est pas possible d'utiliser un autre objet adresse dans ce même champ source.
 - **Destination d'une règle de pare-feu**
 - Si Internet Service est utilisé dans le champ destination d'une règle:
 - Il n'est pas possible d'utiliser un autre objet adresse dans ce même champ destination.
 - Il n'est pas possible de sélectionner le champ « Service » de la règle.



Firewall Policies

- **Internet Service (suite)**
 - **Geographic Based Internet Service Database**
 - Offre un contrôle plus précis en permettant de définir des objets ISDB sur base d'un pays, d'une region ou d'une ville.
 - **Référencement**
 - Les objets ISDB sont référencés, dans les règles de pare-feu, par leur nom plutôt que par leur ID.

Policy & Objects > Internet Service Database

+ Create New ▾ Edit

Geographic Based Internet Service

New Internet Service

Name	Training-location-ISDB	Master Internet Service Name	Google-Other
Type	Predefined Geographic Based	Master Internet Service ID	65536
Country/Region	United Kingdom	Direction	Destination
Region	England	Entries	View/Edit Entries
City	London		

Firewall Policies

- Correspondance du service

- Protocole et N° de port

- L'UTM vérifie le protocole (TCP, UDP, ...) ainsi que les N° de port.
 - De nombreux objets sont prédéfinis et peuvent être modifiés, d'autres peuvent être créés.

Service Name	Category	Details	IP/Port	Show in Service List	Port
General (5)					
ALL	General	ANY		☒	0
ALL_ICMP	General	ICMP/ANY		☒	0
Web Access (2)					
HTTP	Web Access	TCP/80	0.0.0.0	☒	1
HTTPS	Web Access	TCP/443	0.0.0.0	☒	2
File Access (0)					

Exemples d'objets « Service » prédéfinis

Firewall Policies

- Correspondance du service (suite)

- Modifier un objet

Edit Service

Name: ALL_TCP

Comments: 0/255

Color: [Change]

Show in Service List: ☒

Category: General

Protocol Options

Protocol Type: TCP/UDP/SCTP

Address: IP Range FQDN 0.0.0.0

Destination Port: TCP 1 - 65535 Source Port: Low - High

Specify Source Ports: ☒

Configuring Firewall Policies

- Configuration des règles de pare-feu

Dashboard		
FortiView	>	
Network	>	
System	>	
Policy & Objects	>	
IPv4 Policy	>	



Stateful → le trafic de retour est automatiquement autorisé.

Lorsqu'une règle ou un objet est créé, il est associé à un UUID (Log, FortiManager).

Choisir un nom unique et qui a du sens.
Obligatoire par défaut.

Les choix opérés sont affichés en surbrillance.

Configuring Firewall Policies

- Nommage des règles et objets de pare-feu

- Restrictions et conseils

- Le nom d'une règle ne peut pas dépasser 35 caractères.
- Caractères acceptés
 - Les lettres (de A à Z, Majuscule ou minuscule).
 - Les nombres (de 0 à 9).
 - Les caractères spéciaux : "-" et "_"
- Désactiver l'obligation de nommer les règles : Feature visibility > Allow Unnamed Policies

- Caractères spéciaux

- Certains caractères spéciaux peuvent être utilisés mais pas dans les noms des règles de pare-feu (< > () # " ' ')..
 - Mots de passe, commentaires,

Configuring Firewall Policies

- *Firewall policies and Security profiles*

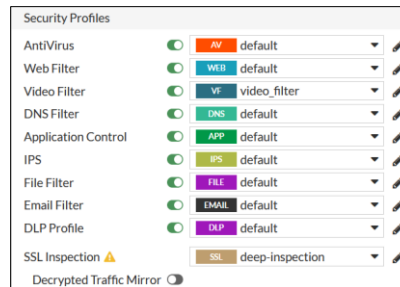
- Les règles de pare-feu

- Fournissent les instructions pour contrôler si le trafic est autorisé ou refusé.
- Sont basées sur les interfaces, les adresses IP, l'horaire et le service.

- Les profils de sécurité

- Un profil de sécurité est un groupe d'options et de filtres que l'on peut appliquer à une règle de pare-feu.

Si le trafic est autorisé par la règle de pare-feu, alors on peut l'inspecter plus en profondeur via les profils de sécurité

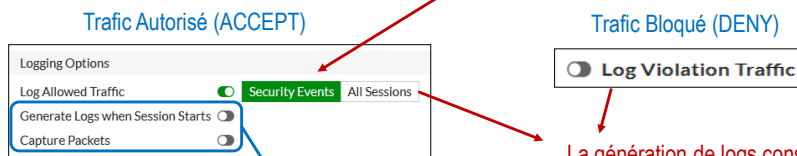


134

Configuring Firewall Policies

- *Journalisation (Logging)*

- Par défaut, seuls les événements de sécurité (Security Events) liés aux profils de sécurité activés sont journalisés.



Disponible uniquement pour les appareils disposants d'un stockage interne.



La génération de logs consomme des ressources et peut diminuer les performances de l'UTM.



135

Configuring Firewall Policies

- Journalisation (suite)

- Détection d'une violation

- Lorsqu'un profil de sécurité détecte une violation, l'UTM enregistre l'attaque.
 - La quantité de logs peut être importante et réduire les performances.

- Table des sessions

- Les sessions refusées peuvent être enregistrées dans la table des sessions.
 - Cela évite de devoir effectuer une recherche de règle de pare-feu pour chaque nouveau paquet correspondant à la session refusée, ce qui réduit l'utilisation du CPU et la génération de journaux.

Active l'enregistrement des sessions refusées dans la table des sessions

Permet de fixer la durée pendant laquelle les sessions restent dans la table des sessions.

```
config system setting
set ses-denied-traffic enable
end
config system global
set block-session-timer <1-300>
end
```

Exemples de journaux

- Forward Traffic log example

- Il est possible de trier les journaux

Log & Report
 Forward Traffic
 Local Traffic

#	Date/Time	Source	Destination	Application Name	Security Events	Result	Log Details
1	00:06:59	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
2	00:06:29	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
3	02-12-23:54	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
4	02-12-23:51	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
5	02-12-23:42	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
6	02-12-23:36	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
7	02-12-23:30	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
8	02-12-23:21	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
9	02-12-23:18	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
10	02-12-23:06	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	
11	02-12-23:06	10.0.0.2	10.0.0.255	UDP/138		Deny: policy violatio	

General
 Date 02/12/2018
 Time 23:51:29
 Duration 0s
 Session ID 69656
 Virtual Domain root
Source
 IP 10.0.0.2
 Source Port 138
 Country Reserved
 Source Interface port1
Security
 Level
 Threat Level high
 Threat Score 30

Exemples de journaux

- *Security log example*
 - Par défaut, ils sont visibles dans le menu Forward Traffic

Date/Time	Source	Destination	Security Events	Log Details
06-28-07:17	10.0.1.10	52.32.150.180 (ec2-52-32-150-180.us-west-2.compute.amazonaws.com)		
06-28-07:17	10.0.1.10	188.40.238.250 (fpps.itcon.info)		
06-28-07:17	10.0.1.10	188.40.238.250 (fpps.itcon.info)		
06-28-07:17	10.0.1.10	188.40.238.252 (secure.eicar.org)		
06-28-07:17	10.0.1.10	188.40.238.250 (fpps.itcon.info) ?	1	Security AntiVirus Agent: Firefox/47.0 FortiSandbox Checksum: 275a021b6fb6489e54d Submitted to FortiSandbox: false Details: host: 188.40.238.250 Threat Level: critical Direction: incoming Detection Type: Virus Event Type: Infected File Name: eicar.com.txt Message: File is infected. Profile Name: anotherAV Quarantine Skip: File was not quarantined. Reference: http://www.fortinet.com URL: http://www.eicar.org/doi... Virus/Botnet: EICAR_TEST_FILE Virus ID: 2172
06-28-07:17	10.0.1.10	188.40.238.250 (fpps.itcon.info)		
06-28-07:17	10.0.1.10	188.40.238.250 (fpps.itcon.info)		
06-28-07:17	10.0.1.10	188.40.238.252 (secure.eicar.org)		
06-28-07:17	10.0.1.10	188.40.238.250 (fpps.itcon.info)		
06-28-07:17	10.0.1.10	188.40.238.250 (fpps.itcon.info)		
06-28-07:16	10.0.1.10	52.85.63.60 (server-52-85-63-60.lhr50.r.cloudfront.net)		
06-28-07:16	10.0.1.10	72.21.91.29 (ocsp.digicert.com)		

Configuration de la journalisation

- *Configuration*
 - Il est possible de spécifier quel sous-type de trafic devra être journalisé concernant les types de journaux « Event » et « Local Traffic »

Log & Report > Log Settings

Log Settings

Event Logging

All
 Customize

☒ System activity event
 ☒ VPN activity event

☒ User activity event
 ☒ Router activity event

☒ WiFi activity event
 ☒ Explicit web proxy event

☒ Endpoint event
 ☒ HA event

☒ Compliance Check Event
 ☒ Security audit event

Local Traffic Log

All
 Customize

☒ Log Allowed Traffic
 ☒ Log Denied Unicast Traffic

☒ Log Local Out Traffic
 ☒ Log Denied Broadcast Traffic

Trafic « de » et « vers » le FortiGate

Configuration de la journalisation

- Anonymiser les logs
 - Parfois requis par le règlement ou la législation

```
# config log setting
set user-anonymize enable
end
```

```
# execute log display
Date=2021-02-04 time=10:06:10 logid=0215013713 type=utm
subtype=webfilter eventtype=ftgd_allow level=notice vd="root"
policyid=2 identidx=1 sessionid=42342848 user="anonymous"
group="ldap_users" srcip=192.168.0.2 srcport=62423
srcintf="port3" dstip=193.190.65.24 dstport=80 dstintf="port1"
service="http" hostname="www.heh.be"
profieltype="Webfilter_Profile" profile="default"
status="passthrough" reftype="direct" url="/" sentbyte=304
rcvbyte=60135 msg="URL belongs to an allowed category in
policy" method=domain class=0 cat=140 catdesc="custom1"
```

Configuring Firewall Policies

- Grouper des service et/ou des adresses

Seq.#	ID	Name	Source	Destination	Schedule	Service	Action	NAT
port3 - port1 (1 - 4)								
1	5	Email	LAN_1 LAN_2	all	always	Email Access	Accept	Enabled
2	4	Web-FTP	LAN_1 LAN_2	all	always	HTTP HTTPS DNS FTP	Accept	Enabled

Edit Address Group

Group Name: LAN

Members: LAN_1, LAN_2

Show in Address List: ☒

New Service Group

Group Name: Web-FTP

Members: HTTP, HTTPS, DNS, FTP

Seq.#	ID	Name	Source	Destination	Schedule	Service	Action	NAT
port3 - port1 (1 - 4)								
1	5	Email	LAN_1	all	always	Email Access	Accept	Enabled
2	4	Web-FTP	LAN	all	always	Web-FTP	Accept	Enabled

Configuring Firewall Policies

- Combiner des règles de pare-feu
 - Il est possible de combiner plusieurs règles afin de réduire leur nombre

ID	Name	Source	Destin...	Schedule	Service	Action	NAT	Security Profiles	Log
port3 → port1 2									
2	Training2	LOCAL	all	always	FTP Web Access	✓ ACCEPT	✓ Enabled	av default web default ssl deep-inspection	UTM
1	Training1	LOCAL	all	always	ALL_ICMP	✓ ACCEPT	✓ Enabled		✓ All

Les règles diffèrent au niveau du service, des profils de sécurité et des logs → choix à faire.

Modes d'inspection

- Flow-based Vs Proxy-based inspection mode*
 - Mode flux (Pas de proxy)
 - Bloque les menaces en temps réel au fur et à mesure que le FortiOS les identifie.**
 - Nécessite moins de ressources de traitement que le mode proxy-based.
 - Mode recommandé pour donner la priorité au débit du trafic.
 - Supporte moins de fonctions de sécurité.
 - Le mode proxy
 - Consiste à mettre le trafic en mémoire tampon et à l'examiner dans son ensemble avant de déterminer une action.
 - Permet plus d'option de sécurité telles que :
 - Le filtrage Vidéo, les options du filtrage web (par exemple : les quotas d'utilisation, le « safe search » ou encore l'option « web-profile override » du profil de filtrage Web), le Web Application Firewall, ...

Modes d'inspection

- *Flow-based Vs Proxy-based inspection mode (suite)*

Policy & Objects > Firewall Policy

Create New Policy

Name	Internet_Access		
Type	Standard ZTNA		
Incoming Interface	LAN (port3)	+	✕
Outgoing Interface	ISP1 (port1)	+	✕
Source	LOCAL_SUBNET	+	✕
Destination	all	+	✕
Schedule	always		▼
Service	ALL	+	✕
Action	✔ ACCEPT ✗ DENY		
Inspection Mode	Flow-based	Proxy-based	

Configuring Firewall Policies

- Menus de configuration
 - Des menus contextuels contiennent des options pour configurer les règles
 - Les menus sont accessibles via un clic droit.

The screenshot shows the Palo Alto Networks firewall rule configuration interface. The 'Name' field is highlighted with a red box. The rule is named 'port3-port1 (1-3)'. The 'Action' column shows 'Web Access' for rule 1 and 'ALL' for rule 2, both with 'ACCEPT' and 'Enabled' status. Red boxes highlight the 'Name' field and the 'Web Access' and 'ALL' action buttons.

Chaque colonne peut être filtrée



A screenshot of the 'Filter' button in the 'Resize to Contents' menu. The button is green with the text 'Filter' in white. A red arrow points to the button.

- Policy
 - Filter by ID
 - Copy
 - Paste
 - Insert Empty Policy
 - Show Matching Logs
 - Show in FortView
 - Edit
 - Edit in CLI
 - Delete Policy

Configuring Firewall Policies

- Supprimer un objet

- L'objet est-il utilisé?

- On ne peut pas supprimer un objet qui est utilisé dans une règle.
- Il faut d'abord modifier la règle utilisant l'objet à supprimer.
- Comment savoir dans quelle(s) règle(s) un objet est utilisé?

Qu'est-ce qu'un objet utilisé ?

On ne peut pas supprimer un objet qui est utilisé dans une règle.

Il faut d'abord modifier la règle utilisant l'objet à supprimer.

Comment savoir dans quelle(s) règle(s) un objet est utilisé ?

ALL est utilisé comme adresse destination dans la règle 3

ALL est utilisé par 1 groupe d'adresses et par 2 règles de FW

Managing Firewall Policies

- Policy Lookup ou Policy match

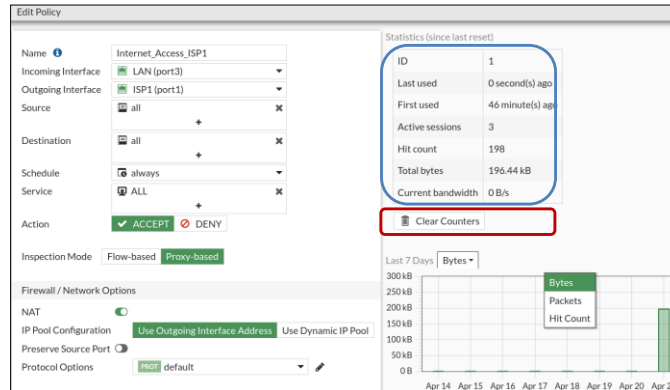
- Permet de rechercher si une règle correspond à un type de trafic

- Les critères varient en fonction du protocole choisi (TCP, ICMP,...).
- Vérifie : la route (recherche l'interface de sortie), Reverse path forward (RPF), Destination NAT (virtual IP).

[illegible]

Managing Firewall Policies

- Informations en temps réel sur les règles de pare-feu
 - L'édition d'une règle affiche des informations sur celle-ci



Conseils

- Conseils pour la création de règles de pare-feu
 - Testez et soyez prudent
 - Toute modification de configuration prend effet immédiatement et peut interrompre un service.
 - Dans la mesure du possible, tester les règles pendant une fenêtre de maintenance avant de les déployer en production.
 - Prévoyez du temps en cas de problèmes.
 - Soyez précis
 - Essayez de configurer des règles de pare-feu aussi précise que possible.
 - Utiliser le modèle de sécurité positif
 - Tout ce qui n'est pas explicitement autorisé est interdit.

- **Conseils pour la création de règles de pare-feu (suite)**
 - **Journalisez**
 - Une bonne configuration de la journalisation peut vous aider à analyser, diagnostiquer et résoudre les problèmes.
 - **Documentez**
 - Expliquez par écrit la raison d'être des différentes règles.
 - **Processus continu**
 - Vérifiez régulièrement la politique de pare-feu afin de :
 - Supprimer les règles temporaires obsolètes créées depuis la dernière révision.
 - Corriger les éventuels écarts par rapport aux conventions en vigueur.
 - Vérifier la cohérence des règles ajoutées depuis la dernière révision : origine, utilité, précision, ...

Chapitre 4

NAT

Network Address Translation

Objectifs

- A l'issue de ce chapitre, l'étudiant doit être capable de
 - Expliquer le fonctionnement des fonctions NAT statique, dynamique et PAT.
 - Expliquer les modes de configuration "Policy NAT" et "Central NAT".
 - Configurer une stratégie de pare-feu pour exécuter SNAT et DNAT.

NAT

- Rappel
 - Translation d'adresses
 - **SNAT** - Source Network Address Translation.
 - Nom donné à la fonction NAT/PAT qui « traduit » l'adresse source d'un paquet IP.
 - **DNAT** - Destination Network Address Translation.
 - Nom donné à la fonction NAT/PAT qui « traduit » l'adresse de destination d'un paquet IP.
 - **PAT** - Port Address Translation.
 - Modification de l'adresse source et du port source dans un paquet.
 - NAT overload.
 - **NAT64, NAT46**
 - IPv4 ↔ IPv6
 - **NAPT** Network Address and Port Translation
 - Acronyme parfois utilisé pour désigner à la fois du NAT et du PAT.

NAT

- Rappel (suite)

- Avantages principaux du NAT

- Assure la cohérence des schémas d'adressage du réseau interne.
- Permet d'économiser les adresses publiques.
- Améliore la sécurité en empêchant de connaître les adresses utilisées en interne.

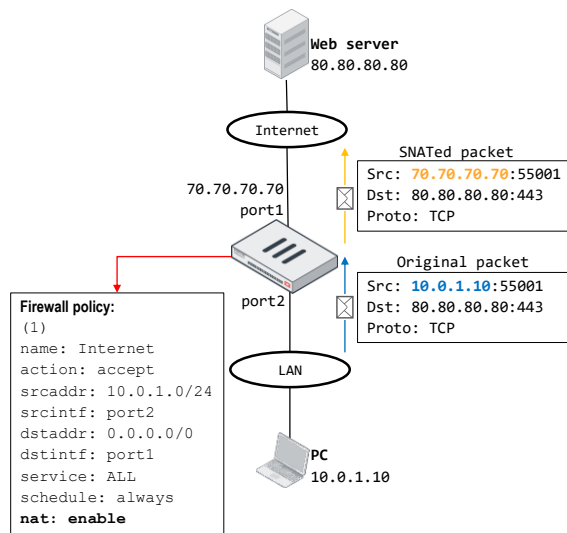
- Inconvénients principaux

- Dégradation des performances, notamment pour les applications temps réel.
- Certaines applications ne sont pas compatibles avec la NAT.
 - Complexification des transmissions tunnel.
- Perte de la traçabilité IP de bout en bout.
 - Plus difficile de suivre un paquet subissant plusieurs traductions.
 - Dépannage plus difficile.

NAT

- Rappel (suite)

- Principe du NAT



Source : Fortinet Inc., FortiGate Administrator

NAT

- Deux méthodes de configuration de la NAT

- Firewall Policy NAT mode

- **SNAT et DNAT doivent être configurés pour chaque règle de pare-feu**
 - SNAT utilise l'adresse de l'interface de sortie ou le pool IP configuré.
 - DNAT utilise l'adresse IP virtuelle (VIP) configurée comme adresse de destination.
 - **Méthode utilisée dans les petits réseaux**
 - Dans lesquels il y a peu de NAT et chaque IP NAT est associée à des politiques et des profils de sécurité distincts.

- Central NAT mode

- **Permet la création de plusieurs règles NAT centralisée**
 - Les règles sont lues dans l'ordre jusqu'à trouver une correspondance.
 - Configuration par VDOM.
 - **Permet de définir et de contrôler la traduction d'adresse avec plus de précision**
 - Par exemple, il est possible de contrôler la traduction des ports, plutôt que de laisser l'UTM choisir automatiquement.
 - **Utile dans les réseaux plus complexes avec de nombreuses règles de pare-feu devant réaliser du NAT**

Firewall Policy NAT

- SNAT en utilisant l'interface de sortie

- Outgoing interface (interface de sortie)

- Remplace l'adresse IP source par l'adresse de l'interface de sortie.
 - Le NAT est activé (NAT Overload).

- « *Preserve source port* » :

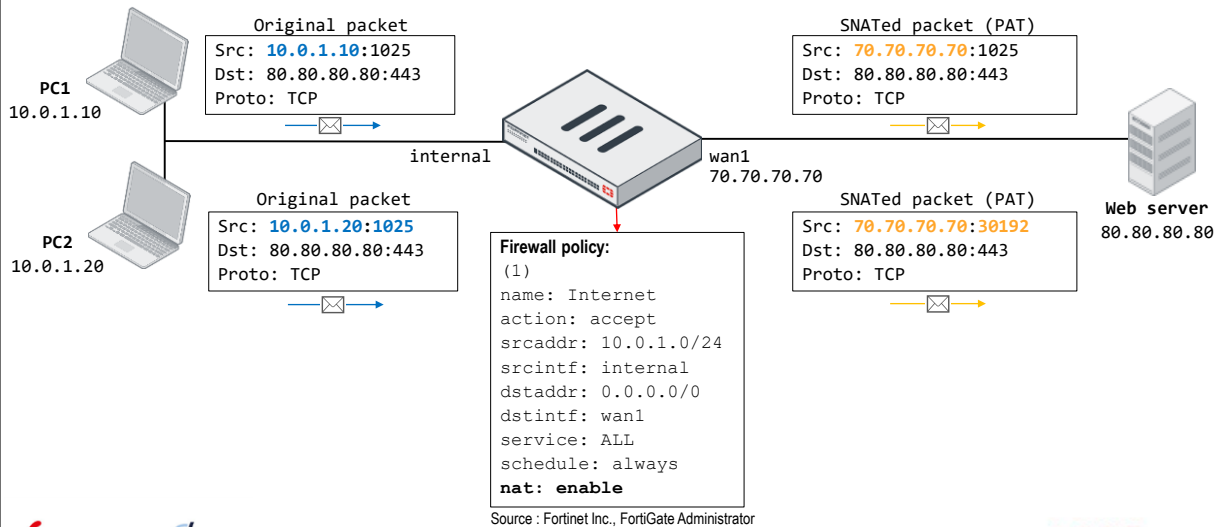
- Désactive la traduction de port.
 - Une seule connexion possible pour un même N° de port source.

Policy & Objects > Firewall Policy

Create New Policy

Name	Full_Access
Type	Standard ZTNA
Incoming Interface	LAN (port3)
Outgoing Interface	ISP1 (port1)
Source	LOCAL_SUBNET
IP/MAC Based Access Control	
Destination	all
Schedule	always
Service	ALL
Action	ACCEPT DENY
Inspection Mode	Flow-based Proxy-based
Firewall/Network Options	
NAT	
IP Pool Configuration	Use Outgoing Interface Address Use Dynamic IP Pool
Preserve Source Port	
Protocol Options	default

Firewall Policy NAT



158

Firewall Policy NAT

- **SNAT en utilisant un pool d'adresses IP (IP pool)**

1. **IP pool type : Overload**

- Le NAT utilise les adresses du pool plutôt que l'adresse de l'interface de sortie.
- Par défaut le pool est de type overload (PAT).

2. **IP pool type : One-to-one**

- **Correspond au NAT dynamique**

- Translation d'une adresse IP source vers la première IP disponible du pool NAT.
- Premier arrivé, premier servi. Plus d'adresse dans le pool, plus de nouvelles communications possibles.

- **La translation de port est désactivée**

- Pas de PAT, le port source est conservé.
- S'il n'y a plus d'IP disponibles dans le pool, la connexion est refusée.

New Dynamic IP Pool

Name:

Comments:

Type: **Overload** | One-to-One | Fixed Port Range | Port Block Allocation

External IP address/range:

ARP Reply: ☒

159

Firewall Policy NAT

- Carrier-Grade NAT

- NAT utilisés par les fournisseurs d'accès à Internet (FAI) pour gérer la pénurie d'adresses IPv4.
- Principe
 - Le routeur du client effectue une première traduction NAT.
 - Quand les données atteignent le réseau du FAI, le CGN traduit l'adresse IP privée du client (déjà traduite une première fois par le routeur local) en une adresse IP publique partagée.
 - Chaque connexion est associée à un port source unique, pour différencier les sessions de différents clients partageant la même adresse publique.
- Deux types :
 - IP pool type : Fixed port range
 - IP pool type : Port block allocation

Firewall Policy NAT

- Virtual IP (VIP)

- Objets utilisés pour faire de la DNAT (si pas de Central NAT)
 - Permet de mapper une adresse IP externe à une adresse IP interne (trafic entrant, généralement vers un serveur interne).
- Par défaut, le type de VIP est NAT statique (One-to-one mapping)
 - Pour le trafic entrant correspondant à une VIP, l'adresse de destination est traduite, le FW remplacera l'adresse de l'interface d'entrée par l'adresse définie dans l'objet VIP. **Peut importe le protocole et le port utilisé.**
 - Pour le trafic sortant (pas seulement les réponses) dont l'IP source = la VIP, le FW remplacera l'adresse source par l'adresse définie dans l'objet VIP.
- FQDN est un autre type de VIP
 - Permet de configurer les objets d'adresse FQDN en tant qu'adresses IP externes et internes.
 - Permet à FortiGate de mettre automatiquement à jour les adresses IP.
- Routage
 - Les VIP doivent être routables vers l'interface externe.
 - FortiOS répond aux requêtes ARP pour les VIP ou les pool IP.
- Balancement de charge possible
 - Si plusieurs serveurs internes sont accessibles depuis la même IP externe.

Firewall Policy NAT

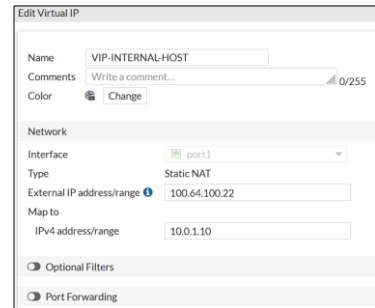
- Virtual IP (VIP)

- Objets utilisés pour faire de la DNAT (si pas de Central NAT)

- Permet de mapper une adresse IP externe à une adresse IP interne (trafic entrant, généralement vers un serveur interne).

- Par défaut, le type de VIP est NAT statique (One-to-one mapping)

- Pour le trafic entrant correspondant à une VIP
 - C'est à destination de l'adresse « externe » définie dans la VIP (ici 100.64.100.22), peu importe le protocole et le port utilisé.
 - Cette adresse de destination (100.64.100.22) est traduite, le FW la remplacera par l'adresse définie dans l'objet VIP (ici 10.0.1.10).
 - Pour le trafic sortant dont l'IP source est définie dans la VIP (10.0.1.10) :
 - Le FW remplacera cette adresse source par l'adresse externe définie dans l'objet VIP (100.64.100.22) (il effectue donc aussi du SNAT).
 - Ce comportement par défaut peut être modifié.



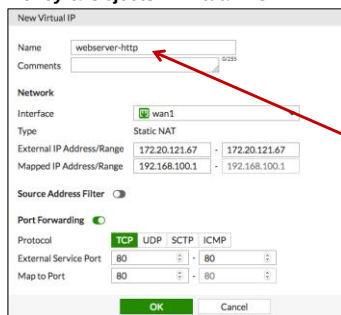
Firewall Policy NAT

- Redirection de port (Port forwarding)

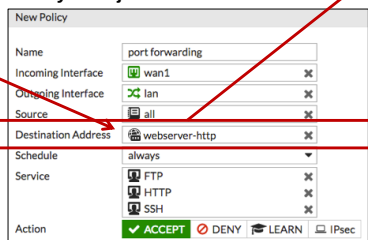
- Exemple de création d'une VIP pour faire du Port Forwarding.

- Avec le Port Forwarding, vous pouvez réutiliser la même adresse externe et la mapper à différentes adresses et ports internes (One-to-one mapping désactivé).

Policy & Objects > Virtual IPs



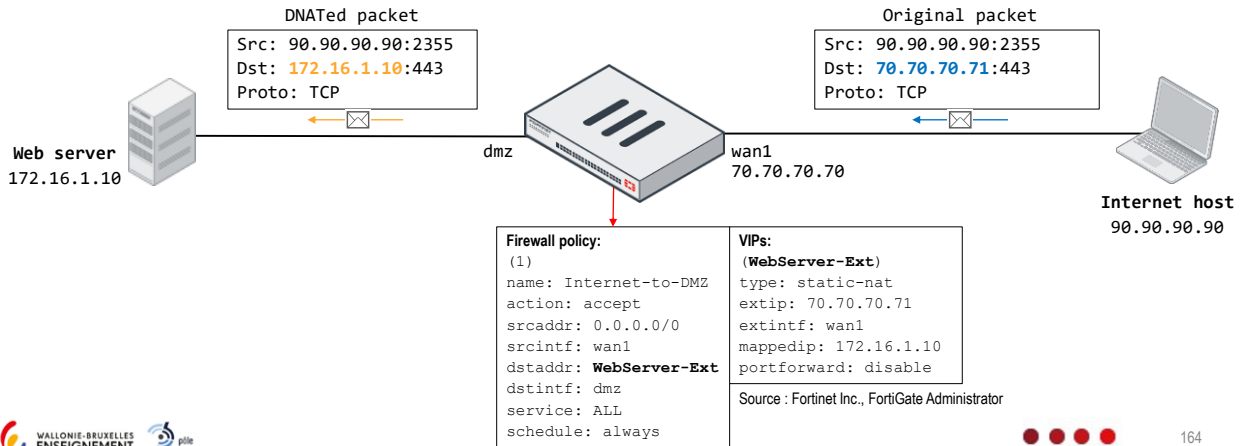
Policy & Objects > Virtual IPs



Une VIP est utilisée dans le champ destination d'une règle de pare-feu

Firewall Policy NAT

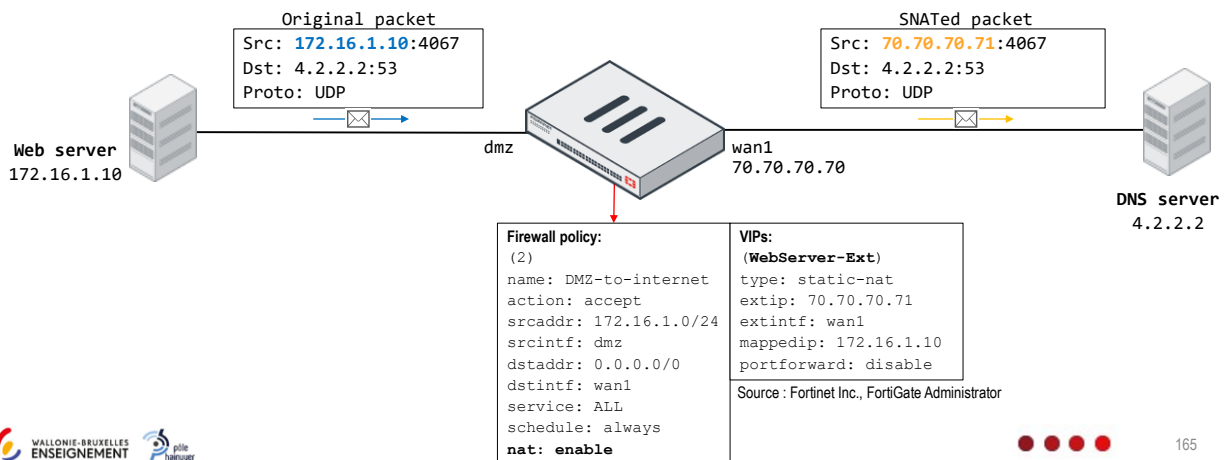
- Exemple de VIP de type NAT statique (trafic entrant)



164

Firewall Policy NAT

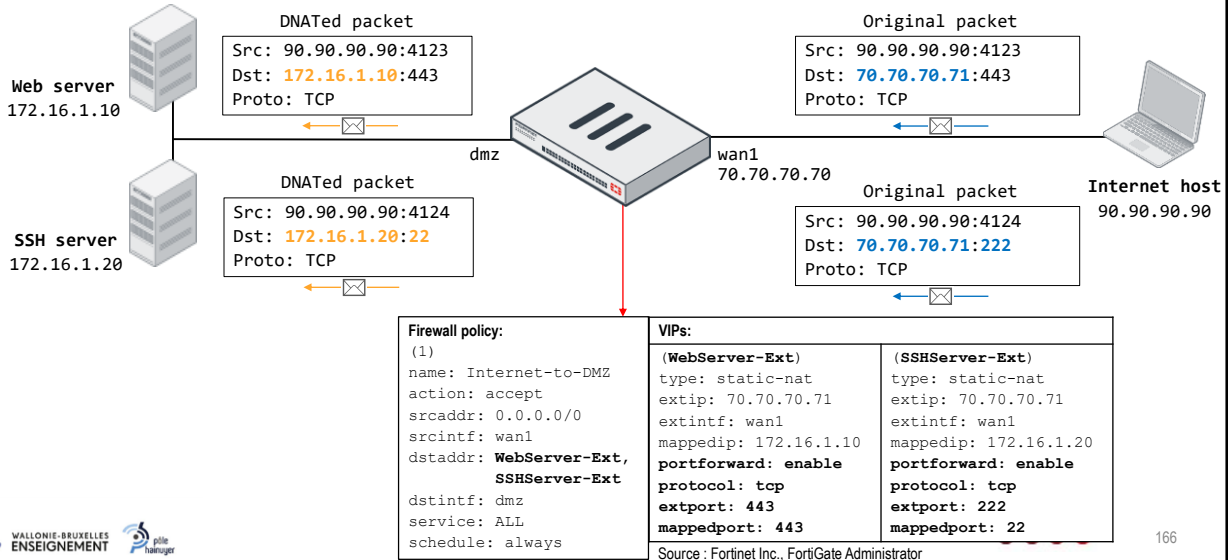
- Exemple de VIP de type NAT statique (trafic sortant)



165

Firewall Policy NAT

- Exemple de VIP de type **port forwarding**



166

Firewall Policy NAT

- Règles de pare-feu et Virtual IP
 - Par défaut les objets adresses ne matchent pas les VIP



- Attention : les VIP et les objets « adresse » de pare-feu sont des objets de types différents.
→ Par défaut, l'objet adresse "ALL" d'une règle de pare-feu n'inclut pas les VIP.

ID	Name	Source	Destination	Schedule	Service	Action
WAN (port1) → LAN (port3) ②						
2	Deny	Deny_IP	all	always	ALL	DENY
3	Allow_access	all	Web_server	always	ALL	ACCEPT



167

Firewall Policy NAT

• Règles de pare-feu et Virtual IP (suite)

– Solution 1

- Permettre aux objets d'adresses de correspondre à l'adresse VIP en activant l'option "match-vip" en CLI.

Depuis FortiOS 7, uniquement possible pour les règles dont l'action est « deny ».

```
config firewall policy
edit <Deny_policy_ID >
set match-vip enable
end
```

– Solution 2

- Utiliser l'adresse VIP dans la règle de pare-feu.

ID	Name	Source	Destination	Schedule	Service	Action
2	Deny	Deny_IP	Web_server	always	ALL	DENY
3	Allow_access	all	Web_server	always	ALL	ACCEPT

```
config firewall policy
edit <policy ID for deny>
set dstaddr <VIP>
end
```



168

Firewall Policy NAT

• ARP reply

– La configuration d'une VIP ou un pool IP, active l'ARP reply

- Le FortiGate va répondre aux requêtes ARP entrantes pour l'adresse externe configurée dans les VIP et les pools IP.
- Généralement pas nécessaire
 - car les tables de routage des périphériques adjacents contiennent les informations correctes sur le saut suivant.
- Si la configuration du routage n'est pas tout à fait correcte, l'activation de l'ARP reply peut résoudre le problème.
 - C'est pourquoi il est préférable de garder l'ARP Reply activée.



169

Chapitre 5

Routage

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Mettre en œuvre le routage en fonction de divers critères.
 - Routage statique (static) et routage basé sur des règles (Policy-based).
 - Équilibrer la charge du trafic sur de multiples chemins.
 - Bloquer le trafic provenant d'adresses IP usurpées.
 - Diagnostiquer les problèmes de routage.

Routage

- NAT/route mode

- Route lookup

- En mode NAT (mode par défaut), le FortiGate agit comme un routeur IP (couche 3).
 - Le FortiGate recherche, dans sa table de routage, une route correspondant à l'IP de destination du paquet.
 - Le routage se fait avant la plupart des actions du pare-feu (notamment avant les règles et l'application des profils de sécurité).

- Stateful

- **Pour chaque session, FortiGate effectue deux recherches de route (route lookups) :**
 - Pour le premier paquet envoyé par l'expéditeur.
 - Pour le premier paquet de réponse provenant du répondeur.
 - **Table des sessions**
 - Une fois terminé ces recherches, FortiGate écrit les informations de routage dans sa table de sessions.
 - Les paquets suivants sont acheminés en fonction de la table de session et non de la table de routage.
 - Exception : si une modification de la table de routage impacte une session, les informations de cette route sont effacées de la table de sessions.

Routage

- RIB et FIB

- Routing Information Base

- Table de routage standard contenant les routes actives (meilleures routes).

- Forwarding Information Base

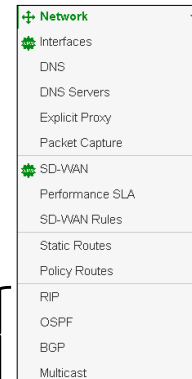
- Table de routage vue du point de vue du noyau
 - Composée principalement des entrées de la RIB et d'entrées spécifiques au système.
 - Utilisée pour la recherche de routes (et donc pas la RIB).
 - Visible uniquement en CLI :

```
# get router info kernel
tab=255 vf=0 scope=253 type=3 proto=2 prio=0 0.0.0.0/0.0.0.0/0->10.0.1.0/32 pref=10.0.1.254 gwy=0.0.0.0 dev=5(port3)
tab=255 vf=0 scope=254 type=2 proto=2 prio=0 0.0.0.0/0.0.0.0/0->10.0.1.254/32 pref=10.0.1.254 gwy=0.0.0.0 dev=5(port3)
tab=255 vf=0 scope=253 type=3 proto=2 prio=0 0.0.0.0/0.0.0.0/0->10.0.1.255/32 pref=10.0.1.254 gwy=0.0.0.0 dev=5(port3)
tab=255 vf=0 scope=253 type=3 proto=2 prio=0 0.0.0.0/0.0.0.0/0->10.200.1.0/32 pref=10.200.1.1 gwy=0.0.0.0 dev=3(port1)
...
```

Routage

- NAT/route mode (suite)
 - Les routes peuvent être configurées manuellement ou dynamiquement
 - Plusieurs protocoles de routage dynamique sont supportés
 - RIP, OSPF, IS-IS et BGP.
 - System > Feature Visibility > Advanced Routing
 - Distance administrative

Directly connected	0
DHCP gateway	5
Static routes	10
EBGP routes	20
OSPF routes	110
RIP routes	120
IBGP routes	200



Routes statiques

- Configuration d'une route statique
 - Priorité
 - Permet d'insérer dans la table de routage une **route statique** non utilisée (VPN).
 - La priorité peut aussi être configurée pour les routes BGP.

New Static Route

Destination ⓘ **Subnet** | Named Address | Internet Service

0.0.0.0/0.0.0.0

Device

Gateway 0.0.0.0

Administrative Distance ⓘ 10

Comments 0/255

Status ☒ Enabled ☐ Disabled

Advanced Options

Priority ⓘ 0

OK Cancel

Static Routes	
Destination	Gateway
0.0.0.0	172.17.11.1
10.0.1.0/24	
10.0.2.0/24	
172.17.10.128/25	

Si plusieurs routes statiques ont la même distance administrative, la priorité est utilisée pour déterminer le meilleur chemin. La plus faible valeur de priorité l'emporte.

Routes statiques

- Objet Adresse

- Un objet adresse de pare-feu de type *subnet* ou *FQDN*, peut être utilisé par son nom comme destination d'une ou plusieurs routes statiques

Policy & Objects > Addresses

Définition d'un objet "adresse"

Subnet

Subnet

IP Range

FQDN

Geography

Dynamic

Device (MAC Address)

Edit Address

Category: Address

Name: REMOTE_SUBNET

Type: IP/Netmask

Subnet / IP Range: 10.0.2.0/255.255.255.0

Interface: any

Show in Address List: ☒

Static Route Configuration: ☒

Comments:

OK Cancel

Network > Static Routes

New Static Route

Destination: Subnet Named Address Internet Service

Device: port2

Gateway: 0.0.0.0

Administrative Distance: 10

Comments:

Status: Enabled Disabled

Advanced Options

OK Cancel

Il faut activer ce paramètre pour que l'objet soit disponible dans **Network > Static Routes**

Une fois activé, l'objet adresse est disponible dans la liste déroulante de destination des routes statiques.

Routing Table Monitor

- Routing IPv6

- Configuration d'une route statique en IPv6

System > Feature Visibility > IPv6

Core Features

Advanced Routing ☒

IPv6 ☒

Switch Controller ☐

VPN ☒

WIFI Controller ☒

Network > Static Routes

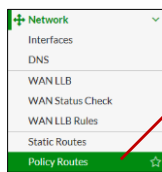
+ Create New	Edit	Clone	Delete
IPv4 Static Route			
IPv6 Static Route			
0.0.0.0/0	10.200.1.254	port1	

Policy-Based Routing

- « Policy-based routes »
 - Plus flexibles que les routes statiques
 - Elles offrent plus d'options de routage
 - Par exemple, lorsque deux liens peuvent être utilisés (un lent et un rapide) il est possible d'acheminer les paquets moins prioritaires vers le lien lent.
 - Elles sont prioritaires sur la table de routage
 - Les *Policy-based routes* utilisées avec l'action *Forward Traffic* ont priorité sur les routes statiques et dynamiques.
 - Ainsi, si un paquet correspond à une *Policy-based route*, la table de routage (R.T.) n'est pas utilisée.
 - Elles sont maintenues dans la *Policy Routing Table*, séparée de la R.T.
 - Il doit cependant exister une route active (route + interface de sortie) vers la destination.
 - Policy-based
 - Les règles sont lue dans l'ordre.
 - Une nouvelle règle est placée à la fin de la liste.

Policy-Based Routing

Policy routes



En plus des interfaces src/dst et IP src/dst, les critères suivants sont utilisables :

New Routing Policy

If incoming traffic matches:

Protocol: TCP UDP SCTP **ANY** Specify 0

Incoming Interface: +

Source address / mask: Examples: 10.80.0.1/24, 192.168.1.2/24

Destination address / mask: Examples: 10.80.0.1/24, 192.168.1.2/24

Type of Service: Bit Pattern 0x00 Bit Mask 0x00

Pour ne pas utiliser un paramètre, il faut laisser le champ vide.

Si correspondance, deux actions sont possibles :

1) **Forward Traffic** : Acheminer le paquet vers l'interface de sortie et la passerelle configurées.

Then:

Action: **Forward Traffic** Stop Policy Routing

Outgoing Interface: ▼

Gateway Address: 0.0.0.0

Comments: 0/255

Status: **Enabled** Disabled

2) **Stop Policy Routing** : utiliser la table de routage

Then:

Action: Forward Traffic **Stop Policy Routing**

Comments: 0/255

Status: **Enabled** Disabled

Internet Services

- Internet services

- Base de données régulièrement mise à jour par les services FortiGuard

- Internet services est une DB qui contient une liste d'adresses IP, de protocoles IP et de numéros de port utilisés par les services Internet les plus courants.

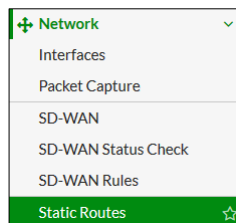
- Routage du trafic

- Permet de router les paquets (de sélectionner l'interface de sortie), en fonction du services Internet de destination.

Name	Protocol Number	Port	# of Entries
CNN-SMTP(S)	TCP	25	8
CNN-Web	TCP	80,443	1113
Dropbox-DNS	UDP	53	4
Dropbox-NetBIOS.Name.Service	UDP	137	5
Dropbox-Web	TCP	80,443	4657
iBay-DNS	UDP	53	12
iBay-NetBIOS.Name.Service	UDP	137	1
iBay-SMTP(S)	TCP	25	4
iBay-Web	TCP	80,443	6713
Facebook-DNS	UDP	53	8
Facebook-FTP(S)	TCP	21	1
Facebook-NetBIOS.Name.Service	UDP	137	8
Facebook-NetBIOS.Session.Service	TCP	445	3

Internet Services

- Route statique utilisant Internet Services



Utilisé comme destination dans une route statique

- Ces routes ne sont pas ajoutées à la table de routage mais à la policy routing table.
 - Bien que l'on configure une route statique (Network > Static Routes).
- Ces routes peuvent être affichée en CLI (routes actives).

```
# diagnose firewall proute list
```


Routing Table Monitor

- Affichage des routes via le *dashboard*
 - Seules les routes actives (meilleurs chemins) sont affichées

Cliquez dans cette fenêtre

Dashboard > Network > Static & Dynamic Routing

Static & Dynamic Routing

Type: Connected, Static

Interfaces: port1, port5, port4, port3

6 Total

6 Total

Static & Dynamic Routing

Static & Dynamic

Policy

BGP Neighbors

BGP Paths

OSPF Neighbors

SD-WAN Routes

Best Fit All Columns

Reset Table

Select Columns

Type

Network

Gateway IP

Interfaces

Distance

Metric

Up Since

Apply

Cancel

182

Routing Table Monitor

- "Route Lookup"
 - Fonction permettant de rechercher une route
 - Recherche dans la « routing table » et la « policy route table ».

Monitor > Routing Monitor

Refresh

Route Lookup

View

Create Address

Search

Type

Network

Gateway

Static

0.0.0.0/0

10.200.1.254

Connected

10.0.1.0/24

0.0.0.0

OSPF (External type 2)

10.1.1.0/24

10.0.1.252

FortiGate

NGFW_PRI

IPv6

Destination

IP or FQDN

Destination Port

1-65535

Source

IP or FQDN

Protocol

TCP

Source Interface

Search

Close

La route correspondante est surlignée dans la R.T ou la P.R.T.

Refresh

Route Lookup

View

Create Address

Search

Static & Dynamic

Policy

Type

Network

Gateway IP

Interfaces

Distance

Metric

Static

0.0.0.0/0

10.200.1.254

port1

10

0

Connected

10.0.1.0/24

0.0.0.0

port3

0

0

OSPF (External type 2)

10.1.1.0/24

10.0.1.252

port3

110

10

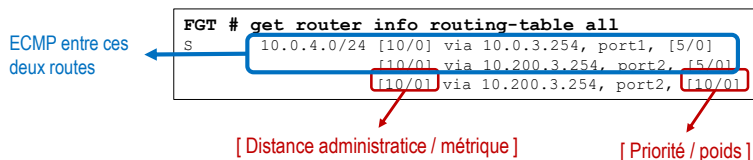
183

Equal Cost Multi-path (ECMP)

- **Équilibrage de charge à coût égal**
 - Conditions : les routes doivent avoir les mêmes attributs
 - Même réseau de destination
 - Même distance (administrative)
 - Même métrique
 - Même priorité (si ce sont des routes statiques)
 - Avantages de l'ECMP
 - Utile pour les services critiques qui nécessitent une haute disponibilité.
 - Améliorer la bande passante en répartissant la charge des sessions sur plusieurs interfaces.

Equal Cost Multi-path (ECMP)

- **Équilibrage de charge à coût égal (suite)**
 - Le paramètre "Priorité"
 - Paramètre spécifique à Fortinet pour départager les routes statiques ECMP.
 - Si plusieurs routes statiques ont les mêmes valeurs d'attributs mais une priorité, différente, elles sont toutes insérées dans la table de routage.
 - Seule(s) celle(s) ayant la valeur de priorité la plus faible est/sont utilisée(s).



Equal Cost Multi-path (ECMP)

- Méthodes de balancement de charge ECMP

- Source IP (default)
 - Les sessions d'une même adresse IP source utilisent la même route.
- Source-destination IP
 - Les sessions avec la même paire IP source + IP destination utilisent la même route.
- Weighted
 - S'applique uniquement aux routes statiques.
 - Les sessions sont distribuées en fonction du poids des interfaces ou des routes.
 - Route A de poids 5 (5/8 du trafic), route B de poids 3 (3/8 du trafic) (8 vient de 5+3).
- Usage (Spillover)
 - La première route ECMP est utilisée jusqu'à ce que la bande passante de l'interface atteigne le seuil débordement configuré.

Equal Cost Multi-path (ECMP)

- Configuration d'ECMP

- Si le SD-WAN est désactivé, l'algorithme ECMP est configuré en CLI

```
# config system settings
  set v4-ecmp-mode [source-ip-based | weight-based | usage-based |
  source-dest-ip-based]
end
```

- Configuration du poids d'une interface ou d'une route

```
# config system interface
  edit <interface name>
    set weight <0 to 255>
  end
```

```
# config router static
  edit <id>
    set weight <0 to 255>
  end
```

- Spillover : la configuration du seuil se fait au niveau de l'interface (en kbps)

```
# config system interface
  edit <interface name>
    set spillover-threshold <0 to 16776000>
    set ingress-spillover-threshold <0-16776000>
  end
```

Reverse Path Forwarding Check

- RPF

- Protection contre l'usurpation d'adresse IP (anti-spoofing)

- Permet au routeur de vérifier si une adresse source est potentiellement joignable.
 - Si activé, le contrôle est exécuté uniquement sur le premier paquet de toute nouvelle session.
 - Ou sur le paquet suivant un changement de route.

```
config system interface
edit <interface>
set src-check [ enable | disable ]
end
```

- Deux modes

- Loose (Feasible path)

- Le paquet est accepté s'il y a une route active vers l'IP source via l'interface entrante.

- Strict

- Le paquet est accepté si :
 - » Il y a une route active vers l'IP source via l'interface entrante ET si cette route est la meilleure route vers l'IP source.

```
config system setting
set strict-src-check [ disable | enable ]
end
```



188

Reverse Path Forwarding Check

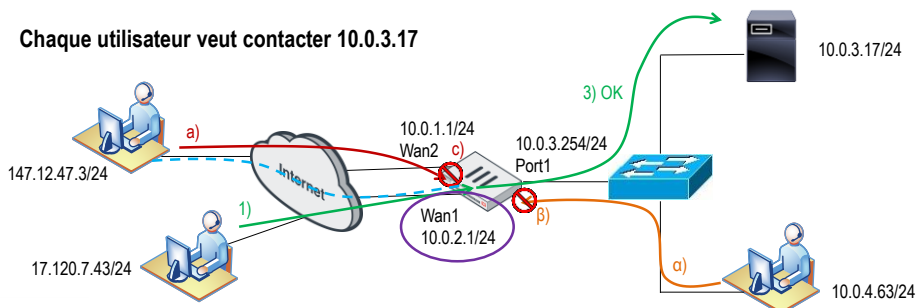
- Principe RPF

2) RPF check : ok

b) RPF check :
 Pas de route active vers 147.12.47.3.
 via l'interface entrante Wan2

Subnet	Interface	Type	Distance	Priority
0.0.0.0/0	wan1	Static	10	0
10.0.1.0/24	wan2	Connected	0	0
10.0.2.0/24	wan1	Connected	0	0
10.0.3.0/24	Port1	Connected	0	0

Chaque utilisateur veut contacter 10.0.3.17



189

Reverse Path Forwarding Check

Principe RPF (suite)

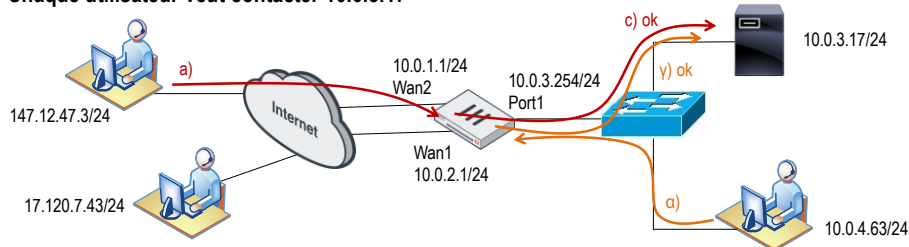
b) RPF check : ok

Des routes ont été ajoutées pour éviter que le RPF ne bloque le trafic

β) RPF check : ok

FortiGate routing table				
Subnet	Interface	Type	Distance	Priority
0.0.0.0/0	wan1	Static	10	0
0.0.0.0/0	wan2	Static	10	5
10.0.1.0/24	wan2	Connected	0	0
10.0.2.0/24	wan1	Connected	0	0
10.0.3.0/24	Port1	Connected	0	0
10.0.4.0/24	Port1	Connected	0	0

Chaque utilisateur veut contacter 10.0.3.17



Reverse Path Forwarding Check

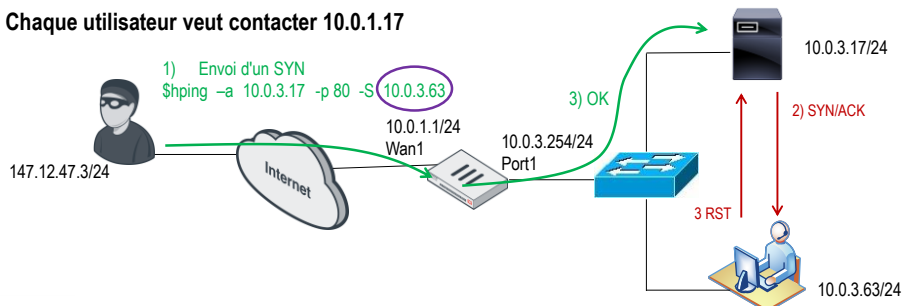
Loose RPF

2) RPF check : ok

Il existe une route active vers 10.0.3.63 via l'interface entrante

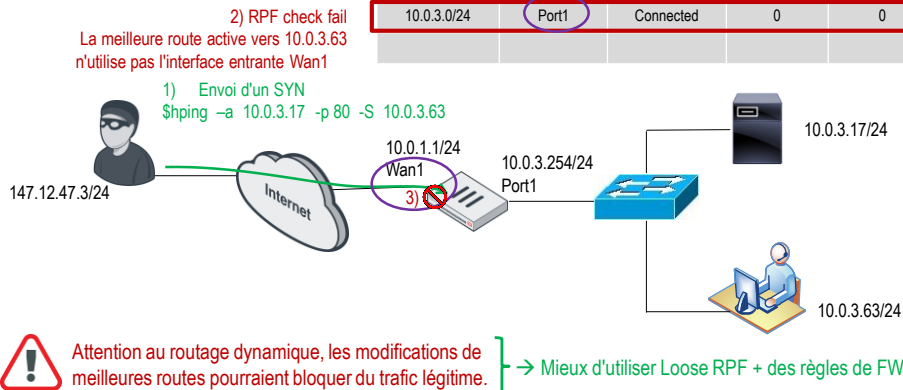
FortiGate routing table				
Subnet	Interface	Type	Distance	Priority
0.0.0.0/0	wan1	Static	10	0
10.0.1.0/24	wan1	Connected	0	0
10.0.3.0/24	Port1	Connected	0	0

Chaque utilisateur veut contacter 10.0.1.17



Reverse Path Forwarding Check

- Strict RPF



Diagnostiquer les problèmes de routage

- Afficher la table de routage (uniquement les routes actives)

```
# get router info routing-table all

Codes: K - kernel, C - connected, S - static, R - RIP, B - BGP
O - OSPF, IA - OSPF inter area
N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
E1 - OSPF external type 1, E2 - OSPF external type 2
i - IS-IS, L1 - IS-IS level-1, L2 - IS-IS level-2, ia - IS-IS inter area
* - candidate default

S* 0.0.0.0/0 [10/0] via 172.25.176.1, port1
O 10.200.2.0/24 [110/2] via 192.167.1.130, port2, 01:01:30
C 10.200.3.0/24 is directly connected, port3
B 10.250.2.0/24 [200/0] via 10.200.3.1, port3, 00:45:12
C 172.25.176.0/24 is directly connected, port1
C 192.167.1.0/24 is directly connected, port2
S 192.168.1.0/24 [10/0] via 192.167.1.130, port2, [25/0]
```

Distance/Metric

Priority/Weight

Diagnostiquer les problèmes de routage

- Afficher les routes actives et inactives

```
#get router info routing-table database

Codes: K - kernel, C - connected, S - static, R - RIP, B - BGP
O - OSPF, IA - OSPF inter area
N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
E1 - OSPF external type 1, E2 - OSPF external type 2
i - IS-IS, L1 - IS-IS level-1, L2 - IS-IS level-2, ia - IS-IS inter area
> - selected route, * - FIB route, p - stale info
```

```
S 0.0.0.0/0 [20/0] via 10.200.2.254, port2
S *> 0.0.0.0/0 [10/0] via 10.200.1.254, port1
C *> 10.0.1.0/24 is directly connected, port3
C *> 10.200.1.0/24 is directly connected, port1
C *> 10.200.2.0/24 is directly connected, port2
S 8.8.4.5/32 [10/0] via 10.255.255.5, port4 inactive
```

Route de secours
(Standby route)

Routes actives

Route inactive : Interface éteinte,
down ou considérée comme
morte par le LHM.

Diagnostiquer les problèmes de routage

- Afficher la Policy routing table
 - 3 types de policy route

```
#diagnose firewall proute list
list route policy info(vf=root):

id=1 flags=0x0 tos=0x00 tos_mask=0x00 protocol=6 sport=1:65535 iif=9 dport=443
oif=11 gwy=100.64.1.254
destination(1): 0.0.0.0-255.255.255.255
source wildcard(1): 10.0.1.10/255.255.255.255
```

Regular Policy route" (ID < 65535)

```
id=4261412866 static route-2 flags=0x0 tos=0x00 tos_mask=0x00 protocol=0
sport=0:0 iif=0 dport=1-65535 oif=11 gwy=100.64.1.254
source wildcard(1): 0.0.0.0/0.0.0.0
destination wildcard(1): 0.0.0.0/0.0.0.0
internet service(1): Apple-App.Store(196723)
```

ISDB route (ID < 65535 et pas
de champ vwl_service)

```
id=2130903041(0x7f030001) vwl_service=1(Critical-DIA) vwl_mbr_seq=1 2
dscp_tag=UxRf UxRf flags=0x0 tos=0x00 tos_mask=0x00 protocol=0 sport=0-65535
iif=0 dport=1-65535 path(2) oif=3(port1) oif=4(port2)
source(1): 10.0.1.0-10.0.1.255
destination wildcard(1): 0.0.0.0/0.0.0.0
internet service(3): GoToMeeting(4294836966,0,0,0, 16354)
Microsoft.Office.365.Portal(4294837474,0,0,0, 41468)
Salesforce(4294837976,0,0,0, 16920)
hit_count=0 last_used=2022-02-23 05:46:43
```

ISDB route (ID > 65535 et un
champ vwl_service)

Diagnostiquer les problèmes de routage

- Connaître l'interface de sortie utilisée

Log & Report > Forward Traffic

Date/Time	Source	Device	Destination	Application Name	Result	Policy ID	Destination Interface
11 seconds ago	10.0.1.200		208.91.112.52 (fortinet-public-dns-52.fortinet.com)		✓ 3.07 kB / 13.12 kB	Full_Access (1)	port1
13 seconds ago	10.0.1.200		208.91.112.53 (fortinet-public-dns-53.fortinet.com)		✓ 3.48 kB / 14.79 kB	Backup_Access (2)	port2
29 seconds ago	10.0.1.200		208.91.112.63 (ntp1.fortiguard.com)		✓ 76 B / 76 B	Backup_Access (2)	port2
30 seconds ago	10.0.1.200		208.91.112.61 (ntp1.fortiguard.com)		✓ 76 B / 76 B	Full_Access (1)	port1
39 seconds ago	10.0.1.200		208.91.112.62 (ntp2.fortiguard.com)		✓ 76 B / 76 B	Full_Access (1)	port1
45 seconds ago	10.0.1.200		208.91.112.60 (ntp2.fortiguard.com)		✓ 76 B / 76 B	Full_Access (1)	port1
Minute ago	10.0.1.10		54.186.52.97 (autopush.prod.mozaws.net)		✓ 6.01 kB / 9.76 kB	Full_Access (1)	port1
2 minutes ago	10.0.1.10		8.8.8.8 (dns.google)		✓ 92 B / 120 B	Backup_Access (2)	port2
2 minutes ago	10.0.1.10		8.8.8.8 (dns.google)		✓ 92 B / 108 B	Backup_Access (2)	port2

Ajouter la colonne "Destination" permet de voir l'interface de sortie utilisée par le paquet.

Diagnostiquer les problèmes de routage

- Capture de paquets en CLI (GUI sur les modèles avec disque dur)
 - FortiOS intègre un outil de capture de paquets (sniffer)
 - Permet de vérifier quand les paquets arrivent et quelles interfaces d'entrée et de sortie sont utilisées pour les acheminer.

– Syntaxe

```
# diagnose sniffer packet <interface> <filter> <level>
<verbosity> <count> <timestamp> <frame size>
# diag sniffer packet any "host 10.1.1.1" none 4 0 1
```

- <interface> : nom de l'interface physique ou logique.
- <filter> : utilise le format tcpdump.
- <level> : Niveau de verbosité, valeur de 1 à 6.
- <count> : arrêter automatiquement le sniffing après avoir capturé un nombre spécifique de paquets. Sinon, arrêt avec CTRL+C. 0 signifie compter indéfiniment.
- <timestamp> : active l'horodatage (a – temps absolu ; l (L minuscule) – temps local).
- <frame size> : permet de spécifier la longueur maximale de la trame (max. 65K).

Diagnostiquer les problèmes de routage

- Niveau de verbosité

- Niveau 4

- Permet de voir rapidement si les paquets arrivent au FortiGate et si FortiGate les achemine ou les abandonne.

- Niveau 6

- Fourni plus d'informations qui peuvent être exportées vers un fichier .pcap à l'aide d'un script Perl.
 - Le contenu du fichier pcap peut être analysé avec Wireshark.

Level	En-tête IP	Charge utile IP	En-tête Ethernet	Nom de l'interface
1	V			
2	V	V		
3	V	V	V	
4	V			V
5	V	V		V
6	v	V	V	V

Diagnostiquer les problèmes de routage

- Capture de paquets en GUI

- Uniquement disponible si le FortiGate dispose d'un stockage interne.

Network > Packet Capture

New Packet Capture Filter

Interface: port1

Maximum Captured Packets: 10

Enable Filters: ☒

Host(s): 10.200.1.254

Port(s): 80

VLAN(s):

Protocol: 6

Include IPv6 Packets: ☐

Include Non-IP Packets: ☐

OK Cancel

→ "any" non disponible

Chapitre 6

VPN IPsec

Introduction

- Objectifs

- Comprendre et expliquer les systèmes de cryptographie symétrique et asymétrique.
- Comprendre et expliquer les avantages de la technologie VPN.
- Comprendre et expliquer les VPN de sites à sites et d'accès à distance.
- Comprendre et expliquer le fonctionnement de l'Infrastructure à clé publique (PKI).
- Comprendre et expliquer les principes de sécurisation utilisés dans le cadre IPsec.

- **Communications sécurisées**
 - **Systèmes distribués**
 - **De nombreuses applications et systèmes informatiques sont maintenant distribués.**
 - Télétravailleurs, partenaires commerciaux, agences, ...
 - **Les flux de communication regroupent de nombreuses informations sensibles**
 - Données d'authentification, commandes de pilotage d'équipements industriels, informations confidentielles, ...
 - **Une interconnexion sécurisée est nécessaire.**
 - Comment assurer l'accès sécurisé, fiable et économique à des réseaux parfois situés à de grandes distances ?

- **Communications sécurisées (suite)**
 - **Réseau WAN ou Internet?**
 - **Relier les sites avec des liaisons WAN ou louées à un opérateur**
 - Sécurisé et fiable.
 - Cher, pas envisageable pour les télétravailleurs.
 - **Utiliser les réseaux publics (Internet)**
 - Bon marché,
 - Ils ne sont pas sécurisés.
 - » On ne sait pas par où passent les données.
 - » Des interceptions, écoutes de données, attaques MITM, etc., sont possibles.
 - **Le Virtual Private Network (VPN)**
 - Utiliser les réseaux publics bon marchés et les sécuriser avec un VPN.

Introduction

- Virtual Private Network (VPN)
 - "Assemblage" de diverses technologies
 - Tunneling, authentification, chiffrement, échange de clés, ...
 - Permet de créer une connexion réseau privée de bout en bout
 - En s'appuyant sur des réseaux tiers comme Internet ou des extranets.
 - Les machines connectées par un VPN peuvent communiquer entre elles comme si elles étaient au sein d'un même réseau local.
 - Virtual
 - Le protocole de tunneling du VPN va construire un chemin virtuel après avoir identifié l'émetteur et le destinataire.
 - Le réseau est virtuel car il n'est pas matérialisé par des liaisons physiques dédiées à cet usage.
 - Private
 - Toutes les données envoyées dans le tunnel seront chiffrées.
 - Les machines ou réseaux interconnectés peuvent communiquer mais ne sont pas vu de l'extérieur.

Introduction

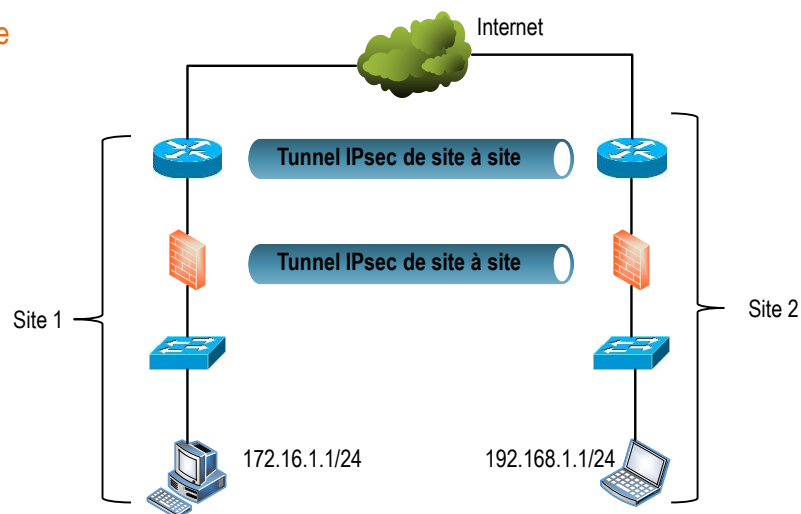
- Remarques
 - Intranet VPN
 - Relie le site central, les bureaux distants, les succursales d'une entreprise.
 - Tous ces sites bénéficient des mêmes politiques qu'un réseau privé (sécurité, qualité de service (QoS), gestion).
 - Extranet VPN
 - Permet d'étendre la connectivité à certaines ressources du réseau à ses clients, fournisseurs et partenaires.
 - Les différents sites ne peuvent généralement pas se voir entre eux.
 - Un VPN ne chiffre pas nécessairement les données
 - Il est nécessaire d'y appliquer des méthodes cryptographiques pour établir des connexions sécurisées.
 - On parlera alors, par exemple, de **VPN IPsec** ou **VPN SSL**.
 - Cependant, lorsque l'on parle de VPN, on sous-entend généralement une connexion sécurisée avec chiffrement.

VPN de site à site

- VPN de site à site (point à point)
 - Utilisé pour connecter entre eux des réseaux entiers
 - Les hôtes internes n'ont pas connaissance de l'existence d'un VPN.
 - Le VPN est configuré entre les passerelles VPN situées des deux côtés de la connexion
 - La passerelle VPN encapsule/décapsule et chiffre/déchiffre l'ensemble du trafic sortant/entrant.
 - Une passerelle VPN peut être un routeur, un pare-feu ou tout autre équipement de sécurité disposant de fonctionnalités VPN.
 - Le VPN est statique : il est toujours actif

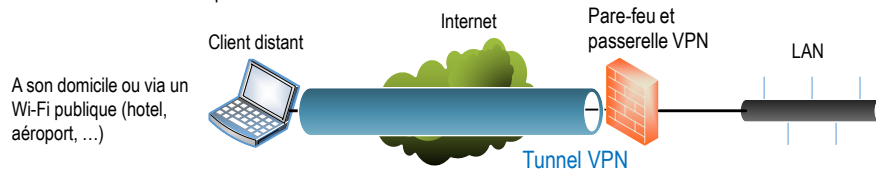
VPN de site à site

- VPN de site à site



VPN d'accès

- **VPN d'accès (Dial up, point à multipoint)**
 - Utilisé pour connecter un intranet à des télétravailleurs
 - Généralement via une connexion haut débit (DSL, sans fil ou par câble).
 - Le VPN d'accès n'est pas configuré de manière statique
 - Le VPN d'accès peut être activé et désactivé à la demande.
 - Peut nécessiter l'installation d'un logiciel client VPN ou non (clientless) sur le PC.
 - Architecture client/serveur.
 - Un client VPN demande l'accès sécurisé au réseau de l'entreprise par l'intermédiaire d'une passerelle VPN.

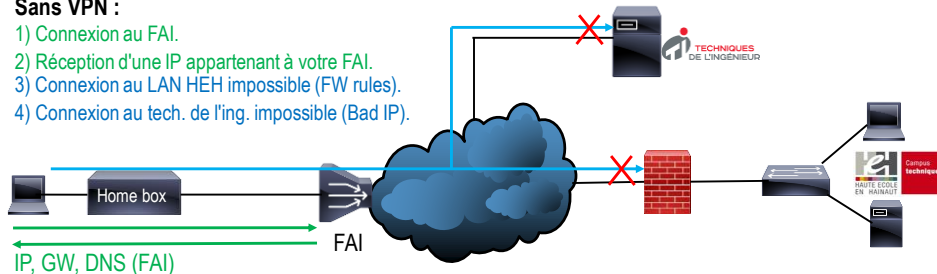


VPN d'accès

- **VPN d'accès (à distance)**
 - Exemple du VPN de la HEH
 - Permet de vous connecter à une machine d'un labo normalement inaccessible de l'extérieur du campus.
 - Permet de vous connecter à un serveur externe au campus mais dont l'accès est réservé aux ordinateurs du réseau HEH (par ex. Techniques de l'ingénieur, ...).

Sans VPN :

- 1) Connexion au FAI.
- 2) Réception d'une IP appartenant à votre FAI.
- 3) Connexion au LAN HEH impossible (FW rules).
- 4) Connexion au tech. de l'ing. impossible (Bad IP).



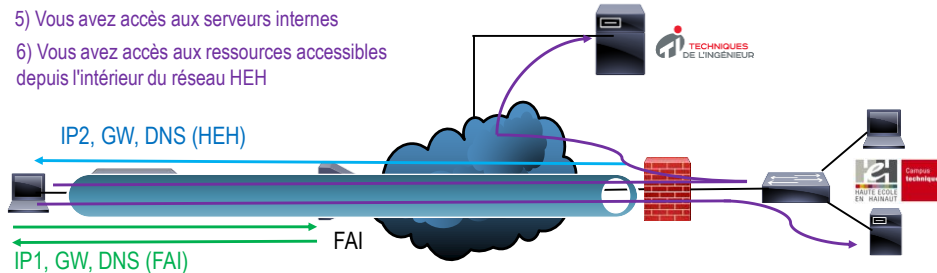
VPN d'accès

- VPN d'accès (à distance)

- Exemple du VPN de la HEH (suite)

Avec VPN :

- 1) Connexion au FAI.
- 2) Réception d'une IP appartenant à votre FAI.
- 3) Le client VPN établit une connexion VPN au LAN du campus
- 4) La passerelle VPN de la HEH vous fournit une 2^e IP, comme si vous étiez physiquement connecté au LAN HEH.
- 5) Vous avez accès aux serveurs internes
- 6) Vous avez accès aux ressources accessibles depuis l'intérieur du réseau HEH



Avantages et inconvénients

- Principaux avantages des VPN

- Sécurité

- Le VPN inclut des protocoles permettant le chiffrement, l'authentification et l'anti-rejeu.
- Les communications peuvent être sécurisées avec des droits d'accès adaptés selon les utilisateurs.
- Il sécurise les données à la couche réseau (et pas à la couche application).
 - C'est vraiment un mécanisme de sécurité de bout en bout au niveau réseau.

- Productivité - flexibilité

- Le réseau de l'entreprise et les applications sont disponibles de presque n'importe où et en toute sécurité.

- Réduction des coûts

- Utilisation d'Internet de manière sécurisée, plus besoin de payer des liaisons WAN.
- Face à cette concurrence, les opérateurs WAN ont baissé leurs prix.
 - Analyse performance/coût à réaliser.

Avantages et inconvénients

- Principaux avantages des VPN (suite)

- Évolutivité

- Lorsque les VPN utilisent Internet, il est alors facile
 - d'augmenter le nombre d'utilisateurs,
 - d'augmenter le volume de données,
 - de connecter de nouveaux sites.

- Compatibilité

- Les VPN sont compatibles avec les technologies haut débit telles que DSL, câble, sans fil, etc.
- IPsec est supporté nativement par un grand nombre d'équipements (PC, routeur, smartphones, Pare-feu, ...)
 - Ne nécessite donc généralement pas d'investissements lourds.

Avantages et inconvénients

- Principaux inconvénients des VPN sur Internet

- Les niveaux de services ne sont généralement pas garantis

- Si l'entreprise a besoin de débit garantis, il faut se envisager de déployer des VPN sur les réseaux WAN des FAI.
- La fiabilité et la performance n'est pas sous le contrôle direct d'une organisation mais repose sur un FAI et sa qualité de service.

- Source potentielle de lenteur

- Due à la charge processeur pour réaliser le chiffrement.
- Due à la distance entre l'utilisateur et son fournisseur VPN.

- Confidentialité?

- Si vous passez par un fournisseur de service VPN, il est possible que certains d'entre eux gardent des logs de votre activité.

- Terminologie

- La cryptologie

- Science qui étudie le chiffrement des informations d'un message afin d'en assurer la confidentialité, l'authenticité et/ou l'intégrité.
 - Englobe la cryptographie et la cryptanalyse.

- La cryptographie

- Étude des techniques permettant de coder (ou chiffrer) un message en clair.
 - Selon les techniques utilisées il est possible d'assurer la confidentialité, l'intégrité et/ou l'authenticité d'une information (ou message).

- La cryptanalyse

- Étude des procédés de décryptage.

- Chiffrement

- Action de transformer un message en clair en un message inintelligible pour un tiers (le message est dit chiffré) ne disposant pas des outils nécessaires au déchiffrement.

- Terminologie (suite)

- Le cryptosystème

- Système de chiffrement basé sur des transformations mathématiques permettant de chiffrer des données.

- Attaque (dans le cadre de la cryptologie)

- Tentative de cryptanalyse.
 - Une attaque peut être légale, les concepteurs offrant parfois des primes à ceux qui arrivent à casser leur algorithme de chiffrement.

- Casser (un code)

- Le fait de mener à bien une attaque, de trouver le moyen d'accéder à ce qui était protégé par chiffrement.

Chiffrement

- Techniques de chiffrement

- Elles utilisent des transformations mathématiques

- Substitutions, permutations, transpositions, XOR, addition modulo-N, multiplication modulo-N, ...
- Il est bien sur possible d'utiliser des combinaisons des ces fonctions mathématiques.

- Exemple de message chiffré

- Quel est la signification cachée dans ce message chiffré?

ZETPODA NU TNEMETROPMOC ESIRUCES DNAUQ SUOV ZEFRUS

Confidentialité avec chiffrement

- Techniques de chiffrement

- Quel est la signification cachée dans ces messages chiffrés?

NAVANT L
 ERIEZ PA
 MELN ' AV
 AIBUOSE
 XDUTE'DI
 E'LEDELL

2315313134 5234423114

- Conclusion

- Si l'algorithme de chiffrement est trop simple, il y a peu de chance que le message reste secret longtemps.
- Si l'algorithme de chiffrement est suffisamment complexe, il sera difficile, voire impossible dans un temps raisonnable, de retrouver le message original.

Chiffrement

- Techniques de chiffrement

- Le carré de polybe est une technique de chiffrement par substitution.

23 15 31 31 34 52 34 42 31 14
 H E L L O W O R L D

	1	2	3	4	5
1	A	B	C	D	E
2	F	G	H	I/J	K
3	L	M	N	O	P
4	Q	R	S	T	U
5	V	W	X	Y	Z

Chiffrement

- Techniques de chiffrement

- Enigma : Machine électromécanique

- Utilisée par les allemands pour chiffrer et déchiffrer des messages lors de la guerre 40-45.

- Alan Turing : Mathématicien et cryptologue britannique

- Il a participé à la conception d'une machine (le Kolossus), destinée à décrypter les messages secret allemands.

- Principe du chiffrement est toujours le même

- Un message à transmettre.
- Un algorithme de chiffrement.
- Une ou plusieurs clés.



- **Les systèmes de chiffrement actuels**
 - Toujours basés sur des opérations mathématiques
 - Pas de simples substitutions mais, par exemple, basé sur le fait qu'il est difficile de factoriser des grands nombres.
 - Utilisation de clés de chiffrement
 - **Les algorithmes modernes dépendent toujours d'une clé pour leur fonctionnement.**
 - L'algorithme étant normalisé, il peut être connu de tout le monde.
 - Pour que le secret soit assuré, il faut que cet algorithme utilise un paramètre supplémentaire qui soit secret : **une clé secrète.**
 - **Une clé est un paramètre utilisé en entrée d'une opération cryptographique.**
 - Une clé est une suite de bits qui peut représenter peut être un mot, une phrase, des données quelconques, ...

- **Exemple de factorisation**

Rappel : factoriser une expression, c'est la transformer en un produit de 2 ou plusieurs facteurs.

- **Le nombre $N =$**

3107418240490043721350750035888567930037346022842727
 5457201619488232064405180815045563468296717232867824
 3791627283803341547107310850191954852900733772482278
 3525742386454014691736602477652346609

- **est décomposable en :**

- **$P =$** 6347336458092538484431338838650908598417836700330
 92312181110852389333100104508151212118167511579

- **$Q =$** 1900871281664822113126851573935413975471896789968
 515493666638539088027103802104498957191261465571

→ Pour trouver P et Q, il a fallu faire travailler 80 processeurs
 Opteron de 2.2GHz pendant 5 mois.

Source : <https://opendclassrooms.com/courses/la-cryptographie-asymetrique-rsa/comment-creer-on-nos-cles>

Chiffrement

- Degré de sécurité

- Dépend de la longueur de clé de l'algorithme de chiffrement

- Plus la clé est longue, plus le nombre de possibilités à essayer dans le cadre d'une attaque par brute force est important.
 - L'évolution de la puissance de calcul des machines oblige à utiliser des clés de plus en plus longues.

- Dépend de la complexité de l'algorithme.

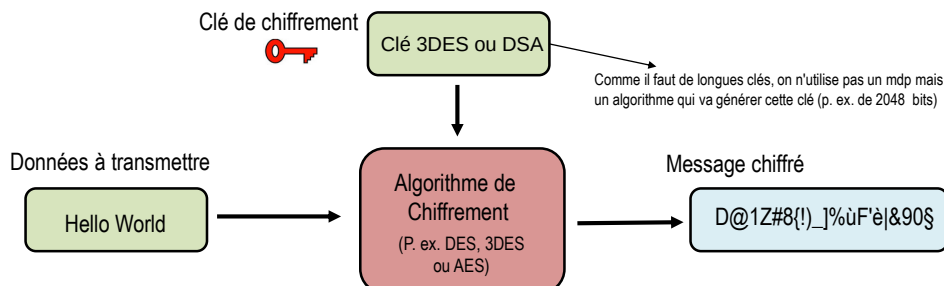
- Si l'algorithme consiste juste à substituer des 0 par des 1, il y a peu de chance que le message reste secret longtemps.
 - HELLO WORLD → HELLO WORLD

Chiffrement symétrique

- Chiffrement symétrique

- Principe

- Les données à transmettre et une clé de chiffrement sont soumis à un algorithme de chiffrement.
 - L'algorithme de chiffrement effectue des opérations mathématiques entre les données à chiffrer et la clé de chiffrement. → Il en ressort un message chiffré.

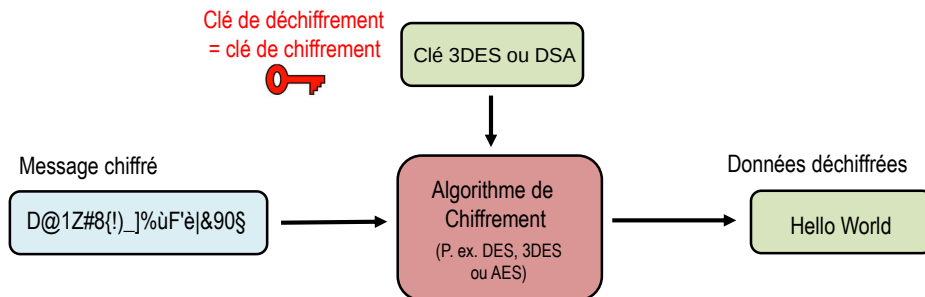


Chiffrement symétrique

- Chiffrement symétrique (suite)

- Le déchiffrement

- Est réalisé par le même algorithme.
 - Nécessite d'utiliser la même clé secrète (d'où la symétrie).



Chiffrement symétrique

- Chiffrement symétrique (suite)

- Appelé aussi chiffrement à clé secrète

- Utilise la même clé secrète pour le chiffrement et le déchiffrement.
 - Exemple d'algorithmes symétriques : DES, 3DES, AES, IDEA, Blowfish.

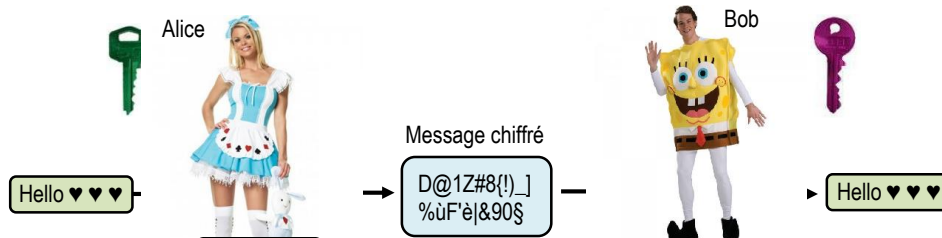
- Inconvénients

- La clé doit rester secrète!
 - Comment garder la clé secrète tout en devant la "partager" entre plusieurs périphériques/personnes?
 - Comment échanger les clés secrètes de manière sûre?
 - Nécessite potentiellement autant de clés que de destinataires.

Chiffrement asymétrique

- Chiffrement asymétrique

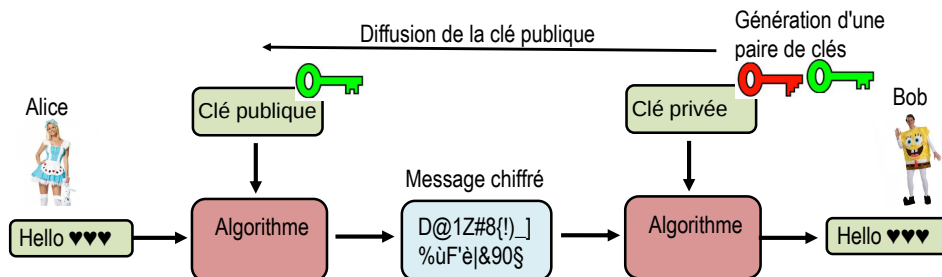
- Utilise deux clés différentes : une pour le chiffrement et une pour le déchiffrement.
 - Si les deux clés sont secrètes, on a toujours un problème d'échange de secret.
 - Une variante est le chiffrement à publique.
 - RSA est un exemple d'algorithme de chiffrement à clé publique.
 - Basé sur la difficulté de factorisation des nombres très grands.



Chiffrement à clé publique

- Principe du chiffrement à clé publique

- Une clé publique (généralement utilisée pour chiffrer)
 - La clé est publique peut être distribuée à n'importe qui voulant envoyer un message.
- Une clé privée (généralement utilisée pour déchiffrer)
 - Seule la personne disposant de la clé privée pourra déchiffrer un message chiffré avec la clé publique correspondante.
 - Cette clé est vraiment privée, elle ne doit **jamais** être partagée ou distribuée.



Chiffrement à clé publique

- Chiffrement asymétrique

- Inconvénients

- Nécessite un traitement plus long que par clé symétrique.
 - RSA est de 1000 à 10000 fois plus lent que le DES.
- Nécessite d'avoir échangé des clés publiques avant l'échange de données.
- Sensible aux attaques de type MITM
 - La clé publique reçue est-elle valide? → comment authentifier cette clé?



Hello, je suis Bob, voici ma clé publique

Hello, je suis Alice, voici ma clé publique

Hachage

- Fonction de hachage

- C'est quoi?

- Une fonction qui calcule, à partir de données, une empreinte d'identification unique de ces mêmes données.
 - Empreinte ≈ Hash ≈ Condensé ≈ Condensat ≈ Message Digest
- Impossible de retrouver le fichier original à partir du hachage.
- 1 seul bit de différence entre deux fichiers donnera deux empreintes complètement différentes.

- Utilité

- Vérifier l'intégrité des données.

- Exemples d'algorithmes de hachage

- MD5, SHA, Tiger, Whirlpool.

J'adore écrire des A

J'adore écrire des C

Hachage

dnbfcnliué'y(bè"t\$ "(ky

&u!çè(à\$î qoµebng

• Fonction de hachage (suite)

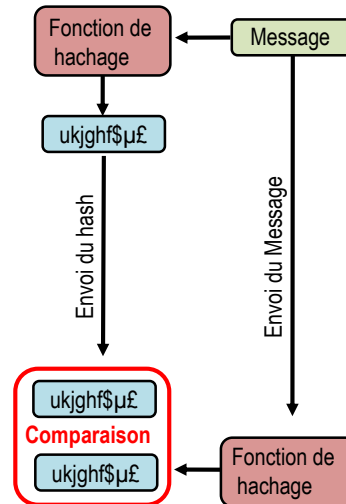
– Principe

- Envoi du message ET de son empreinte.
- Réception du message et hachage de celui-ci.
- Comparaison des deux empreintes.

– Inconvénients

- Ne permet pas de vérifier que l'expéditeur est celui que l'on croit.
- Si l'attaquant intercepte le message et l'empreinte, il peut modifier le message et recalculer une nouvelle empreinte pour les envoyer au destinataire.

hachage



hachage

• Les familles SHA

– SHA-1

- Produit un hash de 160 bits.
- Recommandé de ne plus l'utiliser depuis 2010.
- Microsoft, Google et Mozilla ont annoncé que leurs navigateurs respectifs cesseraient d'accepter les certificats SHA-1 au plus tard en 2017.

– SHA-2

- Contient les fonctions de hachage qui utilisent le même algorithme mais produisent en sortie un résultat de taille différente.
- Basé sur les mêmes principes que SHA-1 mais toujours utilisable actuellement.
- SHA-224, SHA-256, SHA-384 et SHA-512.

– SHA-3

- Basé sur une nouvelle famille de fonctions (algorithme Keccak) dont la conception est très différente de SHA-1 et de SHA-2.
- Offre une solution supplémentaire pour remplacer SHA-1.

Intégrité des données

• Keyed Hash Message Authentication Code

– HMAC à clé

- Algorithme permettant de vérifier l'intégrité et l'authenticité des données.
- Offre une meilleure sécurité qu'un simple checksum ou qu'un hachage seul.
- Les VPN utilisent un code HMAC à clé.

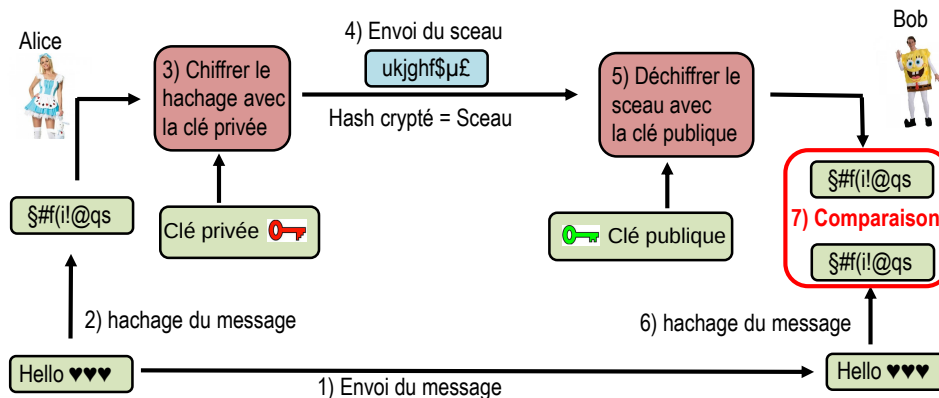
– Principe

- **L'algorithme utilise une fonction de hachage en combinaison avec une clé secrète.**
 - A l'émission : envoi des données et du hachage.
 - A la réception : calcul du hachage à partir des données reçues et de la clé secrète puis comparaison des hachages reçu et calculé.
- **Seul le destinataire disposant aussi de la clé secrète pourra obtenir le même hachage.**

Signature électronique

• Signature électronique

- Signature reposant sur un système de chiffrement à clé publique permettant d'authentifier l'émetteur d'un document.



Signature électronique

• Signature électronique (suite)

- Procédé garantissant l'authenticité de l'auteur d'un message
 - Même rôle qu'une signature manuscrite.
 - Possible de signer de nombreuses manières.
 - Ajouter un son, un texte, une image, ... → pas sécurisé
- Signer avec un système à clés asymétriques garanti l'authentification et
 - **L'intégrité d'un message**
 - Le contenu du message n'a pas été modifié car le hash calculé est identique à celui reçu.
 - **La non répudiation d'un message**
 - Elle empêche l'expéditeur de nier être l'auteur du message.
 - En effet, si le message a pu être déchiffré, il a nécessairement été chiffré avec la clé privée de l'émetteur.
- Réelle garantie?
 - Comment être certain que la clé publique que l'on reçoit est bien celle de l'utilisateur à qui elle est associée?



Source : http://blog.sellandsign.com/wp-content/uploads/2014/10/Fotolia_8211417_S-300x212.jpg

Signature numérique

• Signature numérique

- L'objectif est de s'assurer que la clé publique est fiable
 - La parade contre les attaques MITM consiste à utiliser une paire de clés asymétriques **certifiées** par une tierce partie fiable.
 - Ces tierces parties délivrent ce que l'on appelle des **certificats** contenant une clé publique.



La clé publique  distribuée est maintenant validée par un certificat



– Remarques

- La signature numérique possède la même valeur que la signature manuscrite.
- Les termes signature électronique et signature numérique sont souvent utilisés sans distinction.
- Dire que l'on signe avec un certificat signifie techniquement que l'on signe avec la clé privée, et que l'on vérifie la signature avec la clé publique liée au certificat.
- Un document signé ne veut pas dire qu'il est chiffré.

Certificat

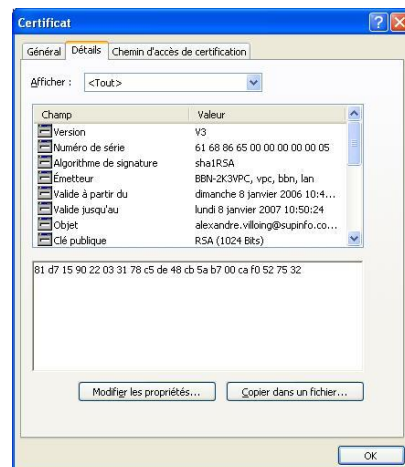
- **Le certificat électronique**

- C'est un petit fichier, une sorte de carte d'identité
 - Il permet d'attester le lien entre une paire de clés et une entité.
 - L'entité peut être une personne, une entreprise, un serveur, un site Web,
- De nouveau, qui peut garantir que les informations dans le certificat sont vraies?
 - **Autorité de certification (CA)**
 - Le certificat ne peut fonctionner que s'il est émit par une autorité autorisée à émettre des certificats.
 - Cette autorité peut être une entreprise spécialisée dans la vente de certificats.
 - » Par exemple : Verisign, Comodo,, ...
 - Potentiellement, n'importe qui peut émettre des certificats.
 - » Feriez-vous confiance à ce genre de certificat?
 - **Valeur d'un certificat**
 - Est donc proportionnelle à la confiance que l'on accorde à l'autorité qui a autorisé ce certificat.
 - » De la même manière qu'il faut avoir confiance en son notaire.

Certificat

- **Structure d'un certificat (norme X509)**

- **Version** : version X509 de ce certificat.
- **Numéro de série** : Numéro de série du certificat.
- **Algorithme de signature**: identifiant du type de signature utilisée.
- **Emetteur** : Distinguished Name (DN) de l'autorité de certification qui a émis ce certificat.
- **Valide à partir de**: la date de début de validité de certificat.
- **Valide jusqu'à** : la date de fin de validité de certificat.
- **Objet**: Distinguished Name (DN) de détenteur de la clé publique.
- **Clé publique** : infos sur la clé publique de ce certificat.
- **Contraintes de base** : extensions génériques optionnelles
- **Utilisation de la clé** : l'objet d'utilisation de la clé.
- **Algorithme thumbprint** : algorithme de signature.
- **Thumbprint** : signature numérique de l'autorité de certification sur l'ensemble des champs précédents.



- Signature du certificat

- Signature par la CA

- L'ensemble des informations (informations + clé publique du demandeur) est signé par l'autorité de certification.
 - Une fonction de hachage crée une empreinte de ces informations.
 - Cette empreinte est chiffrée à l'aide de la clé privée de l'autorité de certification.

- Vérification du certificat

- La clé publique de l'autorité de certification permet aux utilisateurs de vérifier la signature du certificat, donc son authenticité.

- Signature du certificat (suite)

- Les certificats autosignés

- Ils sont, par exemple, signés par un serveur local de l'entreprise.
 - A réserver à un usage interne.

- Avantages

- Ils sont gratuits.
 - Permettent de garantir la confidentialité des échanges au sein d'une organisation.
 - Car ils permettent de s'assurer que les clés de chiffrement sont valables.
 - Permettent d'authentifier les utilisateurs.

- Inconvénients

- A usage interne uniquement.
 - Ils sont considérés comme non fiables
 - Ils déclenchent des alertes (navigateurs).
 - L'administrateur sait qu'ils sont fiables et incite les utilisateurs à ignorer ces alertes.
 - Les utilisateurs pourraient avoir un mauvais comportement face à une vraie alerte.

- Exemples d'utilisation des certificats

- Le certificat de signature

- Il permet d'associer l'identité d'une personne à une clé publique.
 - Utilisation
 - Pour signer des messages électroniques
 - Pour s'authentifier lors d'une session sécurisée.

- Le certificat serveur

- Il associe l'identité d'un serveur à une clé publique.
 - Ce type de certificat est installé sur le serveur.
 - Le certificat serveur le plus répandu actuellement est le certificat SSL.
 - Utilisation
 - Pour garantir la sécurité des échanges entre un serveur et ses clients lors de l'établissement d'une session sécurisée.
 - » Par exemple lors d'un achat en ligne sur un site e-commerce.

- Exemples d'utilisation des certificats (suite)

- Le certificats VPN

- Il permet d'associer certains nœuds du réseau (routeurs, firewalls, concentrateurs...) à une clé publique.
 - Utilisation
 - Pour garantir la sécurité des échanges entre différents sites (par ex. un siège central et ses filiales) à travers des tunnels VPN.

- Le certificat de signature de code

- Il permet de signer un programme, un script ou un logiciel pour garantir son authenticité par la signature de son développeur.
 - Il permet aussi de le protéger contre le risque de piratage.

Certificat

- **Certificat logiciel ou "matériel"**
 - Le certificat est généralement un document numérique.
 - Il peut se présenter sous la forme d'une clé USB ou d'une carte à puce.
 - La clé USB est équipée d'une puce électronique contenant la clé privée et le certificat numérique attestant de l'identité du détenteur par l'autorité de certification.
 - La clé est généralement protégée par un code PIN.
 - Pour signer un document ou s'authentifier sur une application il suffit d'introduire la clé USB et de taper le code PIN.



Par GAllegre — Travail personnel, CC BY-SA 3.0, <https://commons.wikimedia.org/w/index.php?curid=19234871>

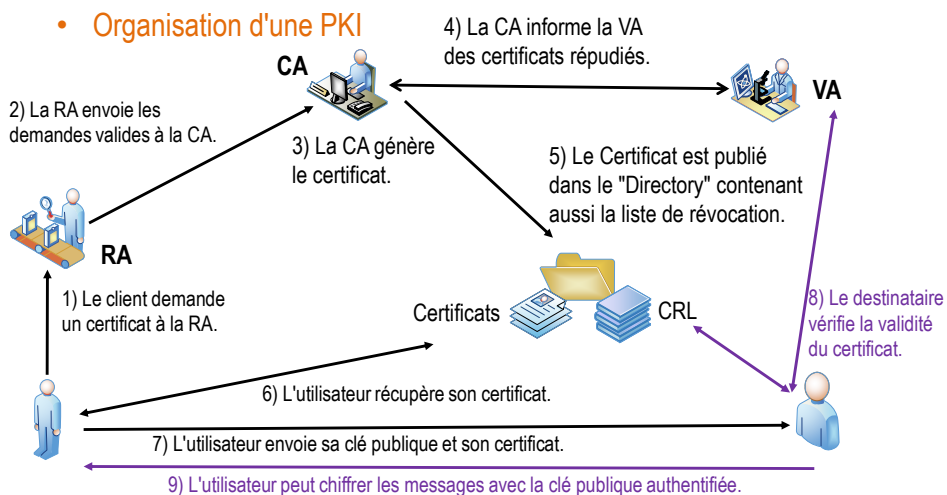
Certificat

- **Certification Authority (CA)**
 - **Rôle de l'autorité de certification**
 - **Créer, valider, délivrer et de gérer les certificats**
 - Les certificats sont publiés dans un composant appelé "The Directory".
 - La CA peut révoquer un certificat avant la fin de la date de validité en cas de compromission d'une clé (à la demande du client).
 - » Les certificats révoqués sont listés dans la CRL (Certificate Revocation List) située dans The Directory.
 - En général, la CA se charge uniquement de créer les certificats et gérer la liste de révocation.
 - **La CA peut tout assurer ou déléguer certaines tâches**
 - **Déléguer à une autorité de dépôt (ou Opérateur de Certification).**
 - L'hébergement des clés privées des certificats.
 - **Déléguer à une autorité d'enregistrement (RA : Registration Authority)**
 - Le recueil des demandes de certificats (accepte ou non la demande).
 - Le contrôle de l'identité des personnes ainsi que les critères d'attribution.

Certificat

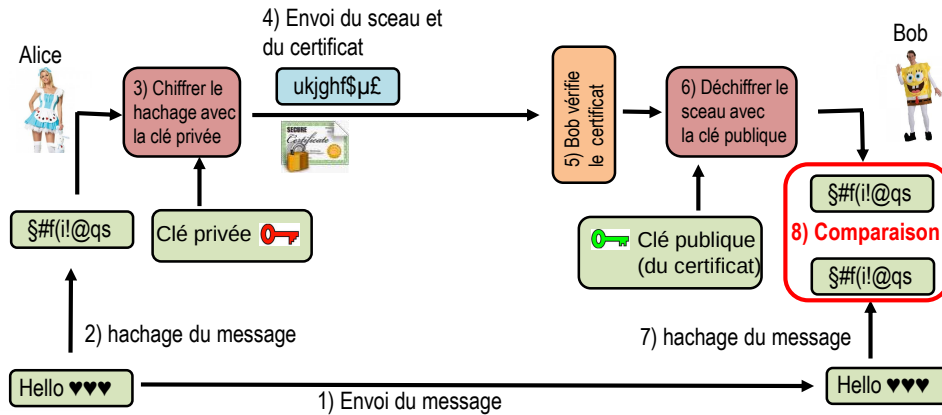
- **Certification Authority (CA) (suite)**
 - La CA peut tout assurer ou déléguer certaines tâches (suite)
 - **Déléguer à une autorité de validation (VA : Validation Authority).**
 - La VA fournira la preuve de la validité d'un certificat à un moment donné.
 - **Déléguer à une autorité d'estampillage du temps (TSA : Time Stamp Authority)**
 - La TSA garanti une horodatage des données, fournissant la preuve qu'une donnée existait avant un moment donné.
 - Permet de garantir des dates de livraisons de documents, de soumissions d'offre ou encore des services notariaux électroniques.
- **Public Key Infrastructure (PKI)**
 - **Infrastructure de Gestion de Clé (IGC)**
 - C'est l'ensemble des intervenants, (CA, RA, VA, ...), des composants (serveurs, clé usb, ...), des procédures (vérifications, validations) et des logiciels (applications, algorithmes, ...) permettant de gérer le cycle de vie des certificats.

Certificat



Certificat

- Signature électronique avec certificat



Certificat

- FortiGate peut utiliser des certificats pour l'authentification
 - FortiGate récupère l'identité de l'utilisateur ou de la machine en vérifiant la valeur du champ **Subject** ou **Subject Alternative Name**.

Field	Value
Version	V3
Serial number	7e 9b 8a 8d 00 00 00 00 6b
Signature algorithm	sha1RSA
Signature hash algorithm	sha1
Issuer	fortinet-us-FGT-NPS-CA, forti...
Valid from	Tuesday, September 06, 2016...
Valid to	Wednesday, September 06, 2...
Subject	Derek McCallister, Training, Otta...
Public key	RSA (1024 Bits)
Certificate Template Name	EFS
Enhanced Key Usage	Encrypting File System (1.3.6...
Key Usage	Key Encipherment (20)
SMIME Capabilities	[1]SMIME Capability: Object I...
Subject Key Identifier	11 d7 43 b3 be 04 4a f9 7d a0...
Authority Key Identifier	KeyID=f3 92 ec cb 4d cf e8 d4...
CRL Distribution Points	[1]CRL Distribution Point: Distr...
Authority Information Access	[1]Authority Info Access: Acc...
Subject Alternative Name	Other Name:Principal Name=d...
Thumbprint algorithm	sha1
Thumbprint	0b ba 6a 93 8d 77 0c 93 bb fb ...

Certificat

- Vérification du certificat par le FW
 - Vérification s'il y a eu révocation du certificat
 - Télécharger les listes de révocation de certificats (CRL) sur le FortiGate ou configurer le FortiGate pour utiliser OCSP.
 - Les certificats sont identifiés par un numéro de série sur la CRL.
 - FortiGate possède-t-il le certificat de la CA?
 - FortiGate utilise la valeur « Issuer » pour déterminer s'il possède le certificat CA correspondant dans son magasin.
 - Vérification des dates de validité
 - Vérification de la signature numérique

Field	Value
Version	V3
Serial number	7e 9b 8a 8d 00 00 00 00 6b
Signature algorithm	sha1RSA
Signature hash algorithm	sha1
Issuer	fortinet-us-FGT-NPS-CA, fort...
Valid from	Tuesday, September 06, 2016...
Valid to	Wednesday, September 06, 2...
Subject	Derek Phillips, Training, Otta...
Public key	RSA (1024 Bits)
Certificate Template Name	EFS
Enhanced Key Usage	Encrypting File System (1.3.6...
Key Usage	Key Encipherment (20)
SMIME Capabilities	[1]SMIME Capability: Object I...
Subject Key Identifier	11 d7 43 b3 be 04 4a f9 7d a0...
Authority Key Identifier	KeyID=f3 92 ec cb 4d cf e8 d4...
CRL Distribution Points	[1]CRL Distribution Point: Distr...
Authority Information Access	[1]Authority Info Access: Acc...
Subject Alternative Name	Other Name:Principal Name=d...
Thumbprint algorithm	sha1
Thumbprint	0b ba 6a 93 8d 77 0c 93 bb fb ...

VPN IPsec

- IPsec
 - Internet Protocol SECurity
 - Standard ouvert, norme IETF : RFC 2401.
 - IPsec permet, par encapsulation, de protéger un flux au niveau de la couche réseau.
 - La technologie IPsec est souvent associée aux connexions VPN.
 - IPsec est indépendant des algorithmes de sécurité
 - IPsec définit les mécanismes à suivre pour sécuriser des communications
 - Il faut authentifier.
 - Il faut vérifier l'intégrité.
 - Il faut échanger les clés de manière sécurisée.
 - Il faut chiffrer les données.
 - Etc.
 - Pour suivre ces mécanismes, l'administrateur dispose de plusieurs choix parmi des technologies et algorithmes existants
 - Permet de répondre de façon adaptée aux besoins.
 - Permet d'implémenter les algorithmes les plus récents et les plus performants sans devoir modifier les normes IPsec existantes.

- IPsec (suite)

- Il permet d'assurer

- **La confidentialité des données**
 - Le trafic est transmis dans un tunnel IPsec peut être chiffré.
 - **L'intégrité des données**
 - IPsec utilise des algorithmes de hachage permettant de vérifier l'intégrité des données.
 - **L'authentification des machines aux extrémités**
 - Les utilisateurs, eux, ne sont pas authentifiés par IPsec.
 - **La protection contre le rejeu**
 - Le rejeu consiste à capturer un ou plusieurs paquets dans le but de les envoyer à nouveau.
 - Le rejeu peut permettre à l'attaquant de bénéficier des même avantages que l'expéditeur initial.
 - Il n'est pas nécessaire à l'attaquant d'avoir déchiffrés les paquets pour les réenvoyer.

- Utilisation d'IPsec

- Protection d'un protocole ou d'un logiciel

- **Certains protocoles ou logiciels présentent une sécurité trop faible**
 - Protéger des équipements dont certains protocoles ou logiciels ne proposent pas une sécurité suffisante pour leurs communications (par exemple des systèmes industriels).
 - Protéger des applications distribuées utilisant des protocoles propriétaires.
 - Protéger des communications clients/serveurs utilisant des protocoles non sécurisés (POP3, FTP, HTTP, VNC, ...)
 - **Compatibilité**
 - Si les équipements ne prennent pas en charge IPsec, il y a lieu d'utiliser des équipements réseau intermédiaires (pare-feux, routeurs, ...)

• Utilisation d'IPsec

– Connexion sécurisées entre sites ou utilisateurs

- VPN d'accès.
- VPN de site à site.

– Défense en profondeur

• Il est recommandé de recourir systématiquement à IPsec

- Même si les applications bénéficient d'une sécurisation au niveau applicatif (par exemple avec SSL/TLS).
- Même si les sites sont interconnectés via un réseau "fiable" (par exemple via des lignes louées ou un VPN MPLS).

– Attention

- Si IPsec n'est pas bien maîtrisé, une configuration non optimale peut offrir un niveau de sécurité plus faible que celui espéré.
 - C'est notamment le cas d'une configuration par défaut.

• Cadre IPsec

- IPsec étant indépendant des algorithmes, un protocole doit être choisi pour chaque fonctionnalité (confidentialité, intégrité, ...).



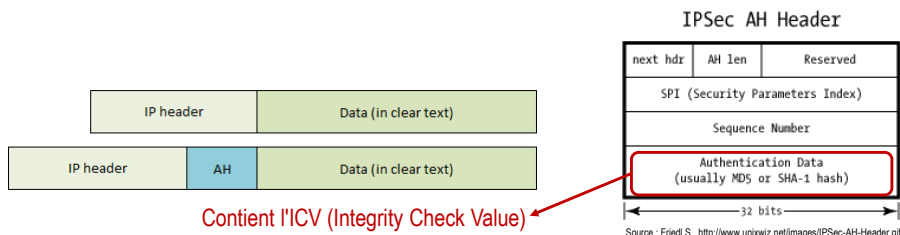
Source : Cisco Networking Academy, CCNA RS, Connecting Networks, page 7.3.2.6

IPsec s'appuie sur deux services qui peuvent

- être utilisés seuls ou associés.
- être utilisé en mode transport ou tunnel.

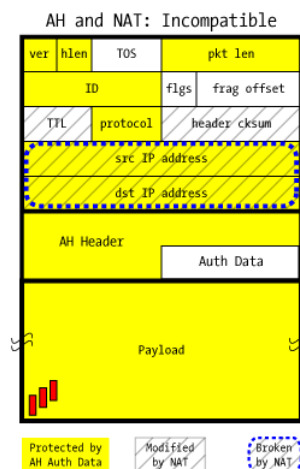
IPsec

- **AH, ESP ou AH+ESP**
 - IPsec s'appuie sur deux services qui peuvent être utilisés seuls ou associés.
- **Authentication Header (AH)**
 - Permet d'assurer l'authentification, l'intégrité et l'unicité des données transmises
 - Pour cela, un champ AH est inséré au datagramme IP.
 - Les services AH protègent tous les champs de l'en-tête qui ne changent pas dans le transport y compris adresses source et destination.



IPsec

- **Inconvénients de AH**
 - **AH n'assure pas la confidentialité des données**
 - Les données sont signées mais pas chiffrées.
 - Tous les messages sont envoyés en texte clair.
 - Protocole à utiliser uniquement lorsque la confidentialité n'est pas requise.
 - **Incompatible avec NAT et PAT**
 - Avec AH, les champs adresse source et adresse destination ne peuvent pas être modifiées (KMAC).
 - Une encapsulation NAT-T permet cependant de traverser un équipement qui fait de la NAT.
 - **AH+ESP**
 - ESP est encapsulé dans AH.
 - AH et AH+ESP sont rarement utilisés et même déconseillés.



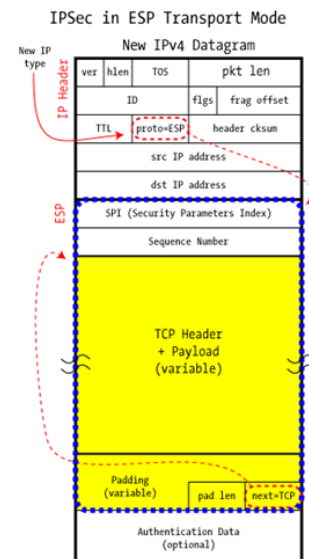
Source : Friedl S., <http://www.unixwiz.net/images/IP-Header-NAT.gif>

• Encapsulating Security Payload (ESP)

- Assure la confidentialité, l'intégrité, l'authentification et l'unicité des données transmises
 - Un en-tête et un en-queue ESP sont insérés au datagramme IP.
 - L'authentification (KMAC) ne vérifie que l'en-tête ESP et le payload chiffré (pas l'en-tête IP).
- ESP chiffre les données utiles mais pas les en-têtes des datagrammes IP
 - Le chiffrement se fait via l'utilisation d'un protocole de chiffrement (3DES, AES, Blowfish, ...).
 - Le protocole à utiliser (ainsi que la clé) est spécifié dans la Security Association.
 - Il est possible d'utiliser ESP sans cryptage.
 - Il agit alors de manière semblable à AH.
 - Il est possible d'utiliser ESP sans contrôle d'intégrité.
 - Déconseillé car n'offrant aucun avantage et exposant l'utilisateur à diverses attaques.

• Inconvénient de ESP

- Incompatible avec le PAT
 - Avec ESP, l'intégrité de l'en-tête IP du paquet n'est pas vérifiée, celle de l'en-tête TCP oui.
 - Le NAT peut donc fonctionner, pas le PAT.



• NAT-T

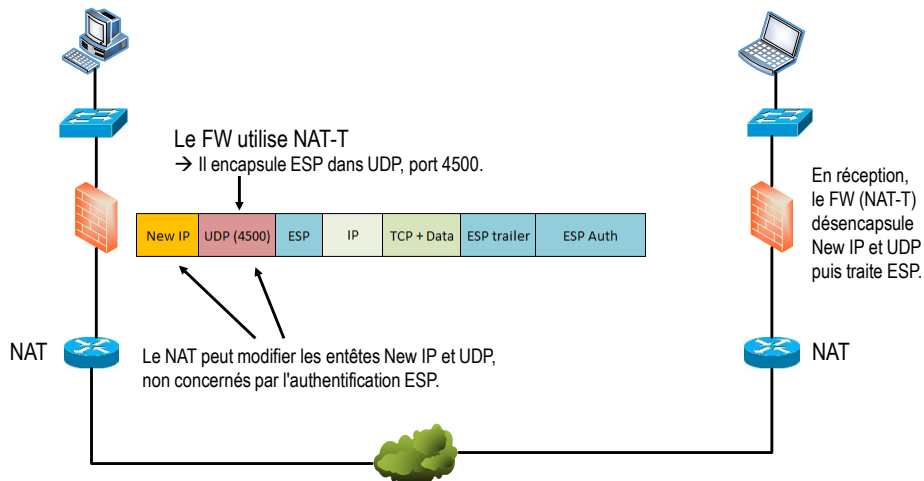
– NAT Traversal

- Méthode permettant aux datagrammes IPsec de traverser un réseau utilisant du NAT.
- NAT-T détecte si les deux extrémités supportent NAT-T.
- NAT-T détecte les équipements qui font de la NAT sur le chemin des données (NAT-Discovery).

– Principe

- NAT-T encapsule les paquets IPsec dans des segments UDP port 4500.
- L'en-tête UDP n'étant pas authentifiée par ESP, elle peut être modifiée par un NAT.
- Le récepteur décapsule le segment UDP et traite le trafic comme un paquet IPsec normal.

• NAT-T



Modes d'échange IPsec

- Le mode transport

- Utilise l'en-tête IP original du paquet.

- Il faut néanmoins modifier le champ *protocole* (50 ESP, 51 AH).
 - Ce mode nécessite moins de traitement que le mode tunnel.
 - Seule la partie payload peut être **chiffrée** (si l'on utilise ESP).
 - En-tête et données utiles sont authentifiées.

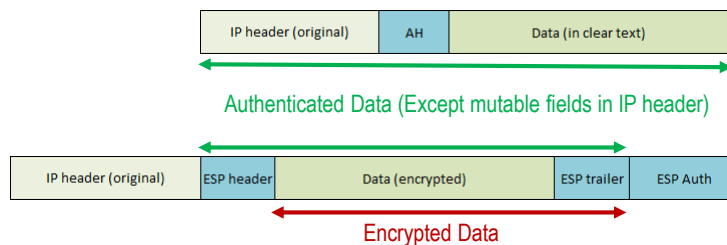
- Utilisation

- Pour les communications dites hôte à hôte, par ex. entre un PC et un serveur.
 - La connexion entre les hôtes est sécurisée, mais il ne s'agit pas d'un tunnel VPN.

Modes d'échange IPsec

- Le mode transport

- Format de paquet



- Mutable fields

- Certains champs ont besoin d'être modifiés lors du transit, ils ne sont donc pas authentifiés (TTL, DSCP, ECN, Flags, Fragment Offset).

Modes d'échange IPsec

- Le mode tunnel

- Le paquet IP entier est encapsulé.

- La totalité du paquet IP est authentifié (et chiffré si l'on utilise ESP).
 - Le paquet est ensuite encapsulé dans un nouveau paquet avec une nouvelle en-tête IP.

- Utilisation

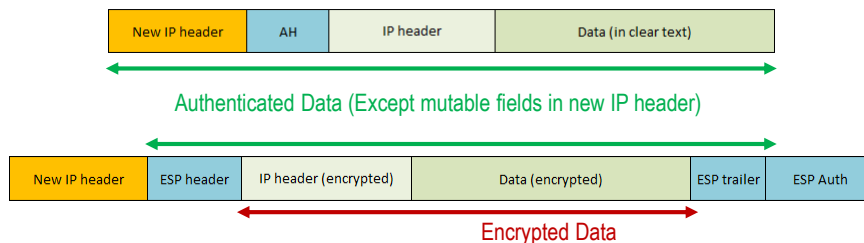
- Communication de réseau à réseau.
 - Dans cas, les passerelles VPN sont généralement placées à la frontière des réseaux, il n'y a donc pas de NAT à traverser.
 - Communication d'hôte à réseau.
 - Communication d'hôte à hôte.

→ le mode tunnel convient donc à la plupart des cas.

Modes d'échange IPsec

- Le mode tunnel

- Format de paquet



"Échange" des clés secrètes

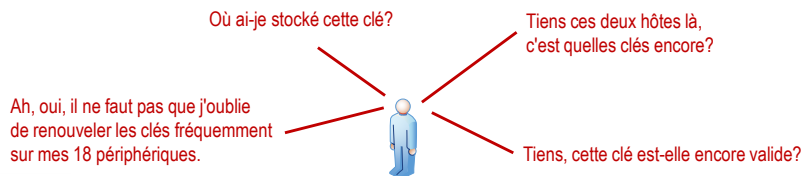
- Key management

- Gestion des clés

- La vérification de l'intégrité et le chiffrement utilisent une ou plusieurs clés secrètes (qui doivent donc être connue seulement de l'émetteur et du destinataire).
 - Comment échanger ces secrets de manière sécurisée?

- Manual Keying

- Il est possible de mettre en place manuellement des clés sur chaque hôte.
 - Méthode déconseillée la plupart du temps.
 - Fastidieux et probablement moins sécurisé (pas de PFS possible).



"Échange" des clés secrètes

- Key management (suite)

- L'utilisation du chiffrement asymétrique seul n'est pas idéal

- Le secret est généré par un seul des correspondants.
 - Peut-on lui faire confiance?
 - N'a t-il pas donné la clé secrète à une tierce personne?
 - Nécessite d'avoir échangé des clés publiques avant l'échange de données.
 - Nécessite éventuellement d'avoir échangé les certificats avant l'échange de données.

- IPsec peut utiliser un protocole spécifique pour l'échange des clés

- Par exemple IKE : Internet Key Exchange
 - Permet aux deux extrémités de configurer automatiquement leurs associations de sécurité ainsi que les clés secrètes à utiliser.

"Échange" des clés secrètes

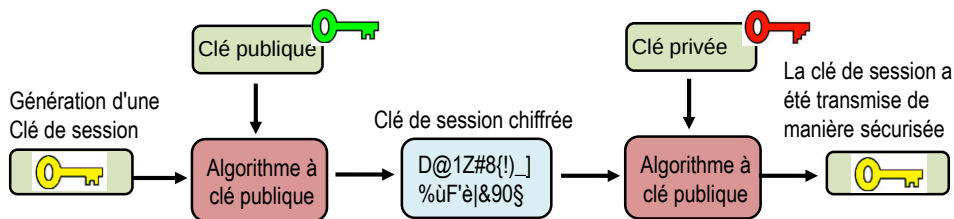
- Clé de session

- Principe

- Échange d'une clé secrète via la cryptographie asymétrique.

- Inconvénients

- Nécessite d'avoir échangé des clés publiques au préalable.
 - La clé est générée uniquement par une des extrémités.
 - La clé de session est envoyée sur le réseau.



"Échange" des clés secrètes

- Algorithme Diffie-Hellman (DH)

- De nombreux algorithmes utilisent une clé secrète partagée symétrique

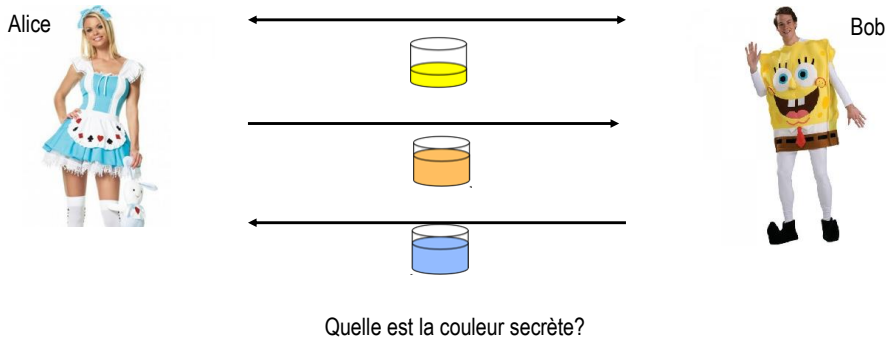
- Des algorithmes de chiffrement : DES, 3DES, AES.
 - Des algorithmes de hachage : MD5, SHA-1.

- L'algorithme DH

- **Protocole de cryptographie à clé publique**
 - L'algorithme est basé sur la difficulté de calculer des logarithmes discrets.
 - **DH permet d'établir, de manière sécurisée, un secret partagé sur un réseau non sécurisé.**
 - Aucune information secrète n'est échangée pour l'échange de clé.
 - Ne nécessite pas d'échanger des clés publiques au préalable.
 - Utilisé notamment dans la norme IPsec et TLS.

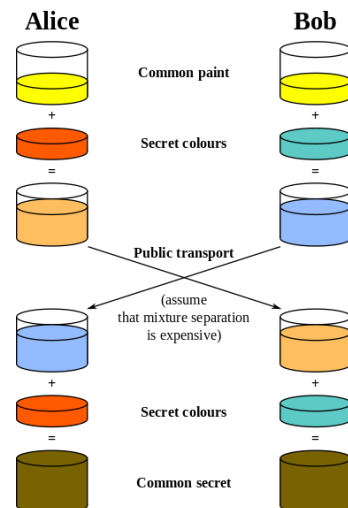
"Échange" des clés secrètes

- Algorithme Diffie-Hellman (DH)
 - Analogie avec de la peinture
 - Ce qu'un attaquant pourrait voir passer comme informations :



"Échange" des clés secrètes

- Algorithme Diffie-Hellman (DH)
 - Principe
 - Alice et Bob échangent publiquement des informations de gestion de clés.
 - Ces informations de gestion des clés, vont permettre à chacun de générer la même clé secrète partagée.



Source : <https://www.quora.com/What-is-the-difference-between-RSA-and-Diffie-Hellman>

"Échange" des clés secrètes

- Les Groupes Diffie-Hellman

- Ils déterminent la force de la clé utilisée dans le processus d'échange de clés
 - En fixant la longueur des nombres premiers de base utilisés durant l'échange.
- Les groupes DH portant un numéro supérieur
 - Sont plus sûrs car la clé résultante est plus longue, donc plus difficile à deviner par les intrus.
 - Nécessitent plus de temps pour créer la clé.
- Choix d'un groupe
 - Le groupe Diffie-Hellman disponible le plus élevé est le plus sécurisé.
 - A utiliser si la lenteur d'initialisation du tunnel et de renouvellement des clés n'est pas un problème.
 - Si le niveau de performance n'est pas acceptable, il faut opter pour un groupe inférieur.

"Échange" des clés secrètes

- Les Groupes Diffie-Hellman (suite)

- DH Group 1: 768-bit group
- DH Group 2: 1024-bit group
- DH Group 5: 1536-bit group
- DH Group 14: 2048-bit group
- DH Group 15: 3072-bit group
- DH Group 19: 256-bit elliptic curve group
- DH Group 20: 384-bit elliptic curve group
- DH Group 21 : 521 bit elliptic curve
- DH Group 24 : modular exponentiation group with a 2048-bit modulus and 256-bit prime order subgroup.

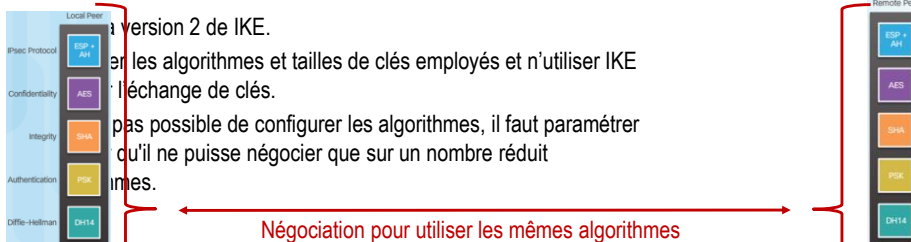
Remarque : La cryptographie elliptique permet d'assurer un haut niveau de sécurité avec des clés plus petites.

"Échange" des clés secrètes

- Inconvénients de DH
 - Il exige la simultanéité des actions (d'Alice et de Bob)
 - Si Alice veut envoyer un message à Bob alors que celui n'est pas connecté, elle ne pourra pas le faire immédiatement.
 - Il est sensible à une attaque de type MITM
 - Contrairement à RSA, DH ne permet pas de signer des informations.
 - Sans signature, un MITM est possible.
- Solution
 - On peut associer DH à un autre algorithme permettant de signer les documents
 - Par exemple DSA (Digital Signature Algorithm) faisant partie du standard DSS (Digital Signature Standard).
 - On voit donc souvent le sigle DH/DSS.

Internet Key Exchange

- IKE (Internet Key Exchange)
 - Protocole de gestion de clés
 - Ensemble de protocoles chargé de négocier automatiquement la connexion pour qu'une transmission IPsec soit possible.
 - Utilise le port UDP 500 (UDP 4500 si NAT) → Ne pas bloquer ce trafic.
 - Définit dans les RFC 2409 et RFC 4306 (IKE v1 et v2).
 - Recommandations



Source : Cisco networking Academy, CCNA RS, Connecting Networks, page 8.2.3.1

Internet Key Exchange

- Quelques caractéristiques de IKEv2 (RFC 4306)
 - Incompatible avec IKE v1
 - Les formats de trames sont différents.
 - Durée de vie d'une SA
 - Avec IKEv1, elle est négociée.
 - Avec IKEv2, chaque équipement définit sa propre durée de vie. C'est la plus courte qui sera sélectionnée.
 - Plus résistant aux attaques DoS
 - Une requête n'est pas traitée tant que son émetteur n'est pas authentifié.
 - Protège notamment des attaques par inondation de messages d'initialisation de connexion depuis une adresse IP usurpée.
 - EAP
 - IKEv2 supporte EAP pour l'authentification (et pas XAuth).
 - WESP
 - L'encapsulation WESP (Wrapped-ESP) ajoute un entête permettant aux équipements intermédiaires de déterminer si le trafic est chiffré ou pas.
 - Facilite le travail des IDS qui peuvent facilement déterminer si un paquet est chiffré.

Internet Key Exchange

- Security Association (SA)
 - Association de sécurité
 - Une SA peut être vue comme une collection de paramètres
 - Ces paramètres décrivent une connexion sécurisée unidirectionnelle entre deux périphériques.
 - Ces paramètres représentent les informations nécessaires pour l'échange et la sécurisation des flux de données (algorithmes, clés, durée de vie, ...).
 - Les deux extrémités du tunnel doivent être d'accord sur le contenu des SA, sinon le tunnel sécurisé ne s'établit pas.
 - Les SA doivent être renégociées à la fin de leur durée de vie.
 - ISAKMP
 - Internet Security Association Key Management Protocol.
 - Les SA peuvent être configurées manuellement, ISAKMP les automatise.
 - Défini dans la RFC 2408.

Internet Key Exchange

- Security Association (SA) (suite)
 - Une association de sécurité IPSec est unidirectionnelle
 - Il en faut donc deux pour assurer une communication sécurisée.
 - Lorsqu'un destinataire reçoit un paquet IPSec, il vérifie à quelle SA correspond le paquet reçu.
 - Si cette association de sécurité n'est pas trouvée le paquet est rejeté.
 - Sinon, il utilise les informations de sécurité pour interpréter le paquet IPSec.
 - Un numéro d'identification est assigné à chaque SA.
 - Le SPI (Security Parameters Index).
 - Security Association Database (SADB ou SAD)
 - Stocke l'ensemble des SA connus du périphérique.
 - Trois données permettent d'identifier de manière unique la SA à utiliser :
 - L'adresse de destination des paquets.
 - Le protocole IPsec (ESP or AH).
 - Le SPI : l'identifiant de la SA choisi par le périphérique lui-même.

Internet Key Exchange

- Security Association (SA) (suite)
 - Exemple de contenu stocké dans la Security Association Database
 - le Security Parameter Index (SPI, numéro d'identification assigné à chaque SA),
 - les hôtes source et destination,
 - les paramètres d'authentification (algorithmes, clés, ...),
 - les paramètres de chiffrement ESP (algorithmes, clés, ...),
 - la durée de vie de la SA,
 - le mode du protocole IPsec (tunnel ou transport),
 - le numéro de séquence (éviter le rejeu),
 - le compteur de dépassement de séquence,
 - une fenêtre d'anti-rejeu,
 - ...

Internet Key Exchange

• IKE phase 1 (mode Normal)

– Objectif de la phase 1

- Créer un tunnel sécurisé temporaire pour protéger l'ensemble des échanges IKE phase 2 (notamment la clé secrète).

1. Négociation ISAKMP policy (bidirectionnelle)

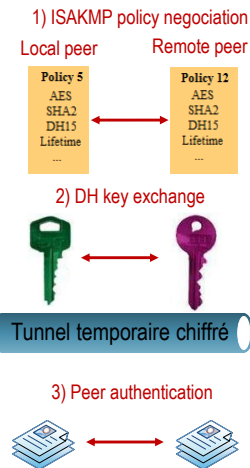
- Les paramètres choisis pour créer le tunnel temporaire sécurisé sont stockés dans une SA.
- On parle d' IKE SA (ou ISAKMP SA)
 - Les IPsec SA ne sont négociées que lors de la IKE phase 2.

2. "Échange" d'une première clé secrète

- En utilisant Diffie-Hellman
 - Ou un autre protocole d'échange de clé (Oakley).

3. Authentification des hôtes + hash payloads

- **Pre-shared Key**
 - Même clé à configurer manuellement sur chaque pair.
- **Digital Signature (Certificate)**
 - De manière automatisée via une infrastructure PKI (recommandé).



Internet Key Exchange

• Modes IKE phase 1

– Mode normal (Main Mode)

- Plus lent : les paramètres de phase 1 sont échangés en 6 messages.
- Plus sécurisé : les informations d'authentification sont envoyées dans les derniers messages.
 - Ces derniers messages sont chiffrés avec la clé établie dans les premiers messages.
 - L'adresse IP source est utilisée comme critère d'identification du pair.
 - Fonctionne pour les VPN de site à site (IP du pair est connue).
 - Fonctionne s'il y a un seul VPN Dial-up.

– Mode agressif (Aggressive mode)

- Plus rapide : paramètres échangés en 3 messages.
- A utiliser s'il y a plusieurs clients dial-up distants
 - En mode agressif, les identités des participants sont échangées dans le premier paquet. FortiGate peut alors faire correspondre le pair distant avec le bon tunnel VPN.

– Chaque Phase 1 peut avoir plusieurs phase 2

- Permet d'utiliser différentes clés de chiffrement pour chaque sous-réseau.

Internet Key Exchange

- IKE phase 2 (Quick mode)

- Objectif

- Négocier les divers paramètres de la SA IPsec afin de pouvoir établir un tunnel sécurisé pour protéger le trafic utilisateur.

Échanges
sécurisés
par IKE
phase 1

1. Négociation des paramètres de la SA IPsec
 - Négocier et établir deux SA par hôte (car unidirectionnelles).
2. Génération des clés de session pour l'échange sécurisé de données.
 - Une clé différente est nécessaire pour chaque flux (A vers B et B vers A).
 - Ces sont ces clés qui seront utilisées par ESP pour chiffrer/déchiffrer.
3. Renégociation périodique des SA IPsec (et donc des clés)
 - Renégociation lorsque la durée de vie (Lifetime) de la SA expire.

→ IKE phase 2 ne s'arrête pas lorsque ESP commence.

Internet Key Exchange

- IKE phase 2

- Quick Mode

- Nom donné à la négociation et l'échange de paramètres de IKE phase 2.
 - Les clés secrètes renégociées périodiquement sont basées sur les anciennes clés.

- Quick Mode PFS

- "Perfect" Forward Secrecy
 - Mesure visant à réduire le risque lors d'une attaque (Recommandé).
 - Chaque fois qu'une phase 2 expire, DH est utilisé pour calculer une toute nouvelle clé secrète.
 - Les anciennes clés ne sont pas conservées et ne sont pas dérivées des précédentes.

PFS : à ne pas confondre avec FPS ;-)



Source : <http://static.1f1.com/captures/2804/0117470-640.jpg>

Chapitre 7

Configuration d'un VPN IPsec de site à site

Objectifs

- A l'issue de ce chapitre, les étudiants seront capable de
 - Configurer un VPN IPsec de site à site.
 - Monitorer des tunnels VPN

VPN IPsec

• IPsec tunnel template

– Template

- Si un seul paramètre de configuration ne correspond pas, le VPN ne s'établira pas.
- Pour minimiser les risques d'erreurs, des templates sont disponibles (FortiOS 5.2).

– Template "Dialup – Forticlient"

- Permet de créer un VPN entre un PC et le FortiGate.
- Nécessite FortiClient installé sur le PC utilisateur.

– Template "Site to Site – FortiGate"

- Permet de créer un VPN entre deux FortiGate.



Affiche le détail du « template » sélectionné.

View	
Template	Description
Dialup - FortiClient (Windows, Mac OS, Android)	On-demand tunnel for users using the FortiClient software.
Site to Site - FortiGate	Static tunnel between this FortiGate and a remote FortiGate.
Dialup - FortiGate	On-demand tunnel between two FortiGate devices.

VPN IPsec

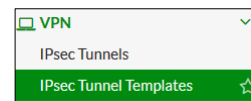
• IPsec tunnel template (suite)

– Template "Site to site – Cisco"

- Permet de créer un VPN entre le FortiGate et un Firewall Cisco

– Custom VPN tunnel (No Template)

- Permet de créer son propre template.



Template	Description
Dialup - Windows (Native L2TP/IPsec)	On-demand tunnel for Windows users using the native L2TP/IPsec client.
Dialup - Cisco IPsec Client	On-demand tunnel for users using the Cisco IPsec client.
Site to Site - Cisco	Static tunnel between this FortiGate and a remote Cisco firewall.
Dialup - Cisco Firewall	On-demand tunnel between a FortiGate device and a Cisco Firewall.

• Assistant de configuration VPN

– Un assistant (wizard) est disponible depuis FortiOS 5.2.

- Il suffit de configurer les paramètres des phases IKE.
- Les routes et les règles requises sont alors ajoutées automatiquement.

Configuration VPN IPsec avec assistant

- Configuration d'un VPN "site to site – FortiGate"

- Étapes de configuration avec l'assistant

1. Choix du template

- Les paramètres phase 1 et phase 2 sont préconfigurés.
- Pour paramétrer plusieurs phases2 et les associer à la phase1, il faut terminer l'assistant, puis utiliser les paramètres avancés.

VPN > IPsec Wizard

VPN Setup | Authentication | Policy & Routing | Review Settings

Name: ToRemoteBackup

Template type: Site to Site | Hub-and-Spoke | Remote Access | Custom

NAT configuration: No NAT between sites
This site is behind NAT
The remote site is behind NAT

Remote device type: FortiGate | Cisco

Site to Site - FortiGate

This FortiGate | Internet | Remote FortiGate

Annotations:

- Create new ou choisir template.
- Ce nom sera utilisé pour identifier l'interface virtuelle.
- Choix du template
- Choix du type de passerelle VPN distante

288

Configuration VPN IPsec avec assistant

- Configuration d'un VPN "site to site – FortiGate"

- Étapes de configuration avec l'assistant

2. Définir la clé partagée ou le certificat, l'interface de sortie et l'IP du boîtier distant.

VPN Setup | Authentication | Policy & Routing

Remote Device: IP Address | Dynamic DNS

IP Address: 10.200.3.1

Outgoing Interface: port1

Authentication Method: Pre-shared Key | Signature

Pre-shared Key:

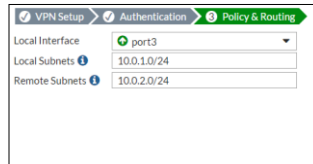
Annotations:

- Adresse IP externe du FortiGate distant
- L'adresse distante est joignable via cette interface locale

289

Configuration VPN IPsec avec assistant

- Configuration d'un VPN "site to site – Fortgate"
 - Étapes de configuration avec l'assistant
 - 3. Définir les réseaux locaux et distants

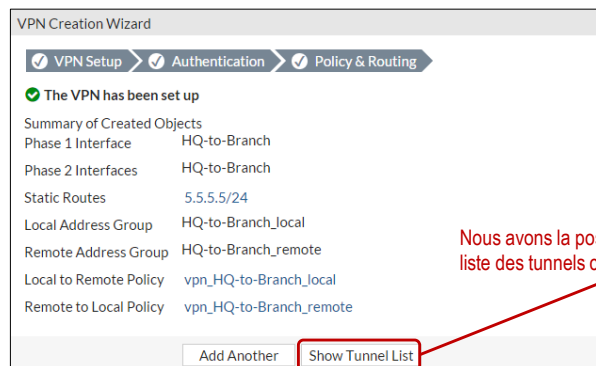


→ Le Wizard crée automatiquement les objets nécessaires

Les adresses et les groupes
 Les routes statiques
 Les règles de pare-feu
 Les paramètres IKE (P1 et P2)

Configuration VPN IPsec avec assistant

- Résumé
 - A la fin de la configuration, un résumé s'affiche.



Nous avons la possibilité de vérifier la liste des tunnels créés.

Configuration VPN IPsec avec assistant

- Interface virtuelle

- Le tunnel est vu comme une interface virtuelle de type VPN tunnel

▼ Status	▼ Name	▼ Members	▼ IP/Netmask	▼ Type	▼ Access
Physical (9)					
	port1		192.168.1.99 255.255.255.0	Physical	PING HTTPS SSH SNMP HTTP FMG-A
	HQ-to-Branch		0.0.0.0 0.0.0.0	VPN Tunnel	

- Cette interface est routable

- Une route a automatiquement été créée par l'assistant.

▼ IP/Netmask	▼ Gateway	▼ Device	▼ Comment
0.0.0.0 0.0.0.0	192.168.1.1	port1	
5.5.5.0 255.255.255.0		HQ-to-Branch	VPN: fgtcent-fgtdist (Created b...

Configuration VPN IPsec avec assistant

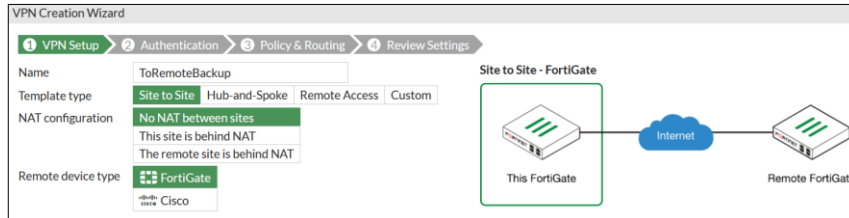
- Règles de pare-feu

- Les règles adéquates ont été créées automatiquement par l'assistant.

Seq. #	▼ Source	▼ Destination	▼ Schedule	▼ Service	▼ Action	▼ NAT
▼ fgtcent-fgtdist - port2 (1 - 1)						
1	fgtcent-fgtdist_remote	fgtcent-fgtdist_local	always	ALL	✓ ACCEPT	Disable
▼ port2 - fgtcent-fgtdist (2 - 2)						
2	fgtcent-fgtdist_local	fgtcent-fgtdist_remote	always	ALL	✓ ACCEPT	Disable
▶ port2 - port1 (3 - 3)						
▼ ssl.root (SSL VPN interface) - port1 (4 - 4)						
4	all	LAN-HQ	always	ALL	✓ ACCEPT	Disable
▶ Implicit (5 - 5)						

Configuration VPN IPsec avec assistant

- Configurer l'autre extrémité du tunnel
 - Même procédure



Site to site VPN IPsec : configuration manuelle

1. Configuration en mode route
 - Terminologie
 - Interface-based, Route-based VPN.
 - Caractéristiques
 - **La terminaison des tunnels sera vue comme une interface virtuelle (VI)**
 - Cette VI sera créée automatiquement lors de la configuration du nom du VPN.
 - **Le trafic devra être routé vers cette interface virtuelle IPsec**
 - Généralement avec des routes statiques.
 - **Deux règles de pare-feu avec action ACCEPT sont requises**
 - Une pour chaque direction du trafic.
 - **Mode par défaut sur le FortiGate**
 - C'est ce mode qui est utilisé par le VPN Wizard.
 - Avantages
 - Meilleur contrôle.
 - Plus de flexibilité.



Site to site VPN IPsec : configuration manuelle

2. Configuration en mode « règle »

– Terminologie

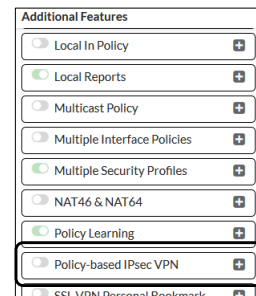
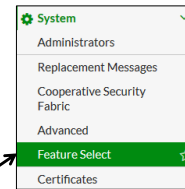
- Mode tunnel, Policy-based VPN.

– Caractéristiques

- Une seule règle requise : avec l'action "IPsec".
 - La règle est bidirectionnelle.
- Masquée par défaut sur l'interface graphique.

Afficher le mode règle depuis la CLI :

```
# config system global
  set gui-policy-based-ipsec enable
# end
```



Site to site VPN IPsec : configuration manuelle

• Compatibilité

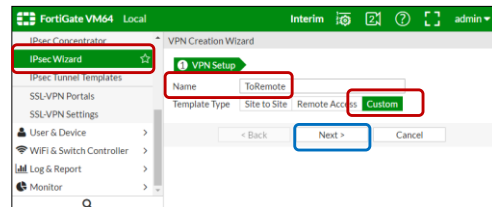
- Route-based VPN et policy-based VPN sont compatibles.
- Il faut évidemment que les paramètres IKE phase 1 et 2 correspondent.

• Comparaison

Paramètres	Mode règle (Policy-based)	Mode route (Route-based)
Mode de fonctionnement	NAT et transparent	NAT uniquement
L2TP-over-IPsec	Yes	Yes
GRE-over-IPsec	No	Yes
Protocole de routage	No	Yes
Nombre de règles par VPN	Une règle pour les deux directions	Deux règles, une pour chaque direction

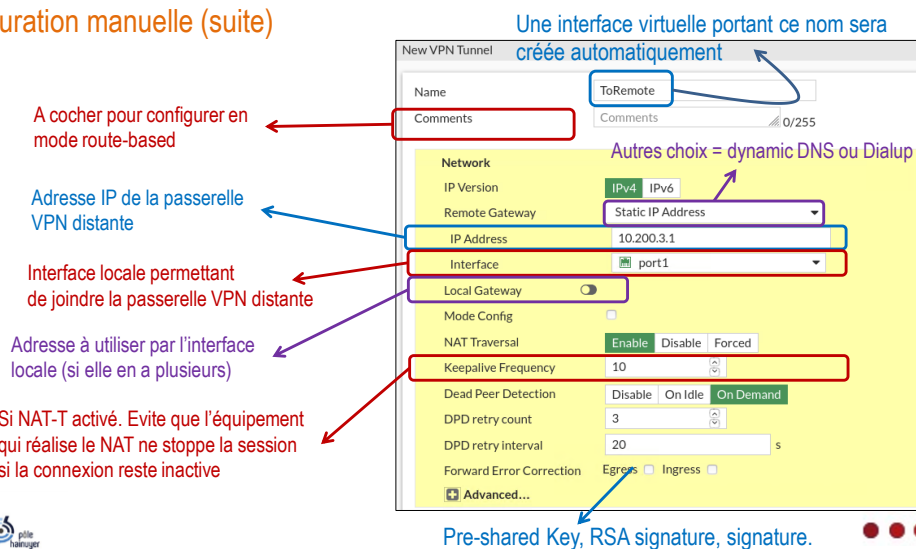
Site to site VPN IPsec : configuration manuelle

- Configuration manuelle
 - Lancer le Wizard puis choisir "custom"



Site to site VPN IPsec : configuration manuelle

- Configuration manuelle (suite)



Site to site VPN IPsec : configuration manuelle

- NAT-T (Network Address Translation Traversal)

- Dead Peer Detection (DPD)

- Négociation des SA IPsec terminée

- Le tunnel est considéré comme opérationnel.
- Pas de négociation d'autres SA IPsec avant leurs expirations (quelques heures).
- Si problème sur le réseau, les pairs continueront à envoyer du trafic via le tunnel même si la communication entre les sites est interrompue.

- DPD détecte les tunnels défectueux (ou mort) via l'envoi de sondes

- DPD les met alors hors service avant l'expiration de ses SA IPsec.
- Utile si le trafic peut basculer vers des chemins de secours.
- Rétablit les tunnels VPN sur les connexions inactives.

- Trois modes DPD

- On demand (default)** : FortiGate envoie des sondes DPD s'il n'y a que du trafic sortant dans le tunnel, mais pas de trafic entrant.
- On Idle** : FortiGate envoie des sondes DPD lorsqu'aucun trafic n'est observé dans le tunnel.
- Disable** : FortiGate répond uniquement aux sondes DPD reçues. FortiGate n'envoie jamais de sondes DPD au pair distant et ne peut donc pas détecter un tunnel mort.

Site to site VPN IPsec : configuration manuelle

- NAT-T (Network Address Translation Traversal)

- Enable NAT-T

- Recommandé si (au moins) une des deux passerelles VPN est derrière un NAT.
- Détecte si des périphériques NAT existent sur le chemin
 - Si oui, l'UTM encapsule les paquets avec UDP sur le port 4500.

- Forced NAT-T

- L'UTM encapsule toujours les paquets avec UDP sur le port 4500, même s'il n'y a pas de NAT.

IKE mode config (équivalent DHCP)

- Si la « remote GW » est Dial-up, le FortiGate agit en serveur
- Sinon, il agit en tant que client IKE mode config
- Doit être configuré sur les deux pairs.

Technique utilisée pour réduire le nombre de retransmissions dans les tunnels IPsec établis sur des liaisons peu fiables.

Site to site VPN IPsec : configuration manuelle

- NAT-T (Network Address Translation Traversal)

- Menu « Advanced »

- **Add route**

- À désactiver si vous utilisez un protocole de routage dynamique sur IPsec et ne souhaitez pas que FortiGate ajoute automatiquement des routes statiques.

- **Auto discovery sender**

- À activer si vous souhaitez utiliser ADVPN dans le hub. Ce paramètre indique que lorsque le trafic IPsec transite par le hub, celui-ci doit envoyer une offre de raccourci à l'initiateur du trafic pour indiquer qu'il pourrait peut-être établir une connexion plus directe.

- **Auto discovery receiver**

- Active l'ADVPN dans pour un spoke. Ce paramètre Indique que ce tunnel IPsec veut participer à un ADVPN.

- **Exchange interface IP**

- En dial-up ou ADVPN, cette option permet l'échange d'adresses IP des interfaces IPsec. Cela permet d'établir une connexion point à multipoint avec le FortiGate central.

- **Device creation**

- Si activé, le noyau crée une interface pour chaque client dial-up. Peut être désactivé afin d'obtenir de meilleures performances lors de déploiements comportant un grand nombre de clients dial-up.

- **Aggregate member**

- FortiGate permet d'agréger plusieurs tunnels IPsec sur une seule interface.

Site to site VPN IPsec : configuration manuelle

- IKE et NAT-T

- Certains FAI bloquent les communications UDP 500

- Il est donc possible de modifier (en CLI) les ports utilisés par IKE et NAT-T.

```
config system settings
    set ike-port <integer range 1024 to 65535>
    set ike-natt-port <integer range 1024 to 65535>
end
```

Site to site VPN IPsec : configuration manuelle

• Authentication

IKE phase 1

Soit Pre-shared Key
Soit Signature (= certificat)

Indiquez les choix que vous permettez à IKE de négocier avec la passerelle VPN distante

Durée de vie d'une IKE SA

Si le pair accepte un peer ID spécifique, entrez-le ici

The screenshot shows the 'Authentication' section for IKE Phase 1. The 'Method' is set to 'Pre-shared Key'. The 'Pre-shared Key' field is masked with dots. The 'IKE' section shows 'Version' set to 1 and 'Mode' set to 'Main (ID protection)'. Below this is the 'Phase 1 Proposal' section with an 'Add' button. It lists three proposals with their respective 'Encryption' and 'Authentication' algorithms. The first proposal has AES128 encryption and SHA256 authentication. The second has AES256 encryption and SHA256 authentication. The third has AES128 encryption and SHA1 authentication. There are checkboxes for 'Diffie-Hellman Groups' with values 32, 31, 30, 29, 28, 27, 21, 20, 19, 18, 17, 16, 15, 14, 5, 2, 1. The 'Key Lifetime (seconds)' is set to 86400. The 'Local ID' field is empty.

Site to site VPN IPsec : configuration manuelle

• Authentication XAUTH

– PreShared Key

- L'authentification Phase 1 par clé partagée est considéré comme une authentification faible.

– XAUTH apporte une protection supplémentaire

- Demande un couple username/password en plus de la PreShared Key.
- Intéressant pour les utilisateurs mobiles.

Sur l'UTM, cela correspond au côté serveur.

L'utilisateur doit avoir ses login et mdp contenu dans le groupe indiqué dans "User Group"

The screenshot shows the 'XAUTH' configuration section. The 'Type' is set to 'Auto Server'. The 'User Group' is set to 'Guest-group'.

Site to site VPN IPsec : configuration manuelle

• Configuration manuelle IKE phase 2

Les Quick mode selectors déterminent quelles adresses IP peuvent effectuer des négociations IKE pour établir un tunnel.
 0.0.0.0/0.0.0.0 = toutes les IP

Dans les VPN point à point, les sélecteurs doivent correspondre : la source sur un FortiGate est le paramètre de destination sur l'autre.

Permet d'utiliser des objets « adresse »

Indiquez les choix que vous permettez à IKE de négocier avec la passerelle VPN distante

IKE phase 2



306

Site to site VPN IPsec : configuration manuelle

• Quick Mode Selectors

– Filtrage du trafic IPsec

- Les *quick mode selectors* servent de filtre. Si le trafic ne correspond à aucun selector, il est abandonné.
- S'il correspond à un selector, les algorithmes associés sont utilisés pour créer le tunnel.

– Meilleure sécurité

- **Permet une sécurité granulaire pour chaque LAN**
 - Pour chaque sous réseau, il est possible de définir des paramètres ESP différents.
 - Par exemple, autoriser uniquement les algorithmes les plus sûrs et des clés plus longues pour les sous-réseaux sensibles.
- **Agit comme un filtre**
 - Si le trafic ne correspond à aucun *quick mode selector*, il est abandonné.
 - Cependant, ce filtrage est généralement déjà opéré au niveau des règles de pare-feu.

– Pour ne pas utiliser le filtrage du quick mode selector

- Créer une seule phase 2 avec un « quick mode selector » configuré sur 0.0.0.0/0.



307

Site to site VPN IPsec : configuration manuelle

• Configuration manuelle

L'UTM vérifier tous les paquets IPsec pour empêcher le rejeu.
(N'est pas négocié avec le pair distant)

Oblige à générer de nouvelles clés non dérivées des clés précédentes.

Renégocie automatiquement des nouvelles SA avant que les anciennes expirent.

Sélectionner si la clé doit être renouvelée toutes les x secondes ou tous les x Ko.

IKE phase 2 (suite)

À activer si vous souhaitez que le tunnel reste actif même lorsqu'aucune donnée n'y transite.

Site to site VPN IPsec : configuration manuelle

• Accélération matérielle

- Disponible sur certains modèles de FortiGate
 - Permet de décharger le chiffrement/déchiffrement du trafic IPsec vers les puces spécialisées.
- Forward Error Correction
 - « Forward Error Correction » ne peut pas être utilisé si l'accélération matérielle est activée.
- Par défaut, l'accélération matérielle est activée
 - Tous les algorithmes ne sont pas pris en charge, cela dépend du modèle de NP présent sur le FortiGate.

```
config vpn ipsec phase1-interface
  edit ToRemote
    set npu-offload enable | disable
  next
end
```


Site to site VPN IPsec : configuration manuelle

- Règle de pare-feu pour le VPN (Route-based)
 - En mode route-based, deux règles de pare-feu doit être configurées
 - Les interfaces par lesquelles sortent et entrent les paquets IPsec sont des interfaces virtuelles.
 - Rappel : Si l'on utilise le Wizard, ces règles sont créées automatiquement.

New Policy

Name: Traffic to Remote

Incoming Interface: port3

Outgoing Interface: ToRemote

Source: LOCAL_SUBNET

Destination Address: REMOTE_SUBNET

Schedule: always

Service: ALL

Action: ACCEPT

Firewall / Network Options: NAT

L'action doit être ACCEPT.

New Policy

Name: Traffic from Remote

Incoming Interface: ToRemote

Outgoing Interface: port3

Source: REMOTE_SUBNET

Destination Address: LOCAL_SUBNET

Schedule: always

Service: ALL

Action: ACCEPT

Firewall / Network Options: NAT

Site to site VPN IPsec : configuration manuelle

- Routage du trafic (Route-based)
 - En mode route-based, il faut router le trafic vers l'interface virtuelle
 - Rappel : Si l'on utilise le Wizard, cette route est créée automatiquement.
 - Le routage dynamique est supporté.
 - Si le pair distant est Dial-up et l'option add-route est activée (par défaut)
 - FortiGate ajoute automatiquement une route statique vers le réseau local du pair distant pendant la négociation de la phase 2.
 - « add-route » est activée par défaut.

Si le pair distant n'est pas Dial-up, il faut créer une route statique

New Static Route

Destination: 10.0.2.0/24

Device: ToRemote

Administrative Distance: 10

Comments:

Status: Enabled

Advanced Options

LAN distant

```
config vpn ipsec phase1-interface
edit "Dialup"
set add-route enable | disable
next
end
```

Pour joindre le LAN distant, il faut envoyer les paquets sur l'interface virtuelle

Site to site VPN IPsec : configuration manuelle

• Règle de sécurité VPN (Policy-based)

- En mode Policy-based, une seule règle de pare-feu doit être configurée
 - L'action de la règle doit être IPsec.
 - Policy-based VPN est pris en charge que pour des raisons de rétrocompatibilité. Son utilisation n'est pas recommandée pour les nouveaux déploiements.



312

IPsec VPN Monitor

• Surveiller les tunnels IPsec

- Le dashboard permet d'afficher des informations sur les tunnels.

Statuts du tunnel :

- La flèche verte indique que la négociation du tunnel est réussie : le tunnel est UP.
- La flèche rouge indique que le tunnel est DOWN.

Dashboard > Network > IPsec

Un clic droit permet d'arrêter ou démarrer les tunnels VPN



313

IPsec VPN Monitor

- Surveiller les tunnels IPsec (suite)
 - Permet d'afficher les adresses, les ID et les minuteurs.

```
# get vpn ike gateway ToRemote

vd: root/0
name: ToRemote
version: 1
interface: port1 3
addr: 10.200.1.1:500 -> 10.200.3.1:500
created: 11182s ago
IKE SA created: 1/1 established: 1/1 time: 0/0/0 ms
IPsec SA created: 1/7 established: 1/3 time: 0/0/0 ms

id/spi: 2 87cd23144999ff26/6344560f6f1e9b07
direction: initiator
status: established 11182-11182s ago = 0ms
proposal: aes-128-sha256
key: f22b28527b64f833-c193c4d3cd729ebd
lifetime/rekey: 86400/74917
DPD sent/recv: 00000000/00004141
```

Nom de la phase 1

« Initiator » ou « responder »

IPsec VPN Monitor

- Surveiller les tunnels IPsec (suite)
 - Les routes vers les tunnels IPsec apparaissent dans la table de routage :
 - Lorsque IKE phase 1 est « up » si le pair distant est configuré en tant que « static IP address » ou «dynamic DNS».
 - Lorsque IKE phase 2 est « up » si le pair distant est configuré en tant que «Dial-up User».
 - Journalisation

Log & Report > System Events > VPN Events

Double clic pour afficher les détails

Date/Time	Level	Action	Status	Message	VPN Tunnel
2020/04/21 19:10:32	INFO	negotiate	success	negotiate IPsec phase 2	ToRemote
2020/04/21 19:10:32	INFO	negotiate	success	progress IPsec phase 2	ToRemote
2020/04/21 19:10:32	INFO	tunnel up		IPsec connection status change	ToRemote
2020/04/21 19:10:32	INFO	phase2 up		IPsec phase 2 status change	ToRemote
2020/04/21 19:10:32	INFO	install_sa		install IPsec SA	ToRemote
2020/04/21 19:10:32	INFO	negotiate	success	progress IPsec phase 2	ToRemote
2020/04/21 19:09:35	INFO	negotiate	success	progress IPsec phase 1	ToRemote
2020/04/21 19:09:35	INFO	negotiate	success	progress IPsec phase 1	ToRemote
2020/04/21 19:09:35	INFO	negotiate	success	progress IPsec phase 1	ToRemote
2020/04/21 19:09:35	INFO	negotiate	success	progress IPsec phase 1	ToRemote
2020/04/21 19:09:34	INFO	delete_phase1_sa		delete IPsec phase 1 SA	ToRemote
2020/04/21 19:09:34	INFO	phase2 down		IPsec phase 2 status change	ToRemote
2020/04/21 19:09:04	INFO	negotiate	success	progress IPsec phase 1	ToRemote
2020/04/21 19:09:04	INFO	negotiate	success	progress IPsec phase 1	ToRemote
2020/04/21 19:09:04	INFO	negotiate	success	progress IPsec phase 1	ToRemote
2020/04/21 19:09:04	INFO	negotiate	success	progress IPsec phase 1	ToRemote

Details

General

Date: 2020/04/21 19:09:35

Time: 19:09:35

Event Domain: ipsec

Log Description: Progress IPsec phase 1

Source

Local IP: 10.1.1.57

User: N/A

Group: N/A

SAUTH User: N/A

SAUTH Group: N/A

Action

Action: negotiate

Status: success

Result: DONE

Security

Level: INFO

Event

Assigned IP: N/A

IPsec ID: 040F5B8D29cc72/6d7ba7ac6a24c4c4

IPsec ID: 040F5B8D29cc72/6d7ba7ac6a24c4c4

Chapitre 8

Inspection SSL/SSH

Inspection SSL/SSH

- Objectifs

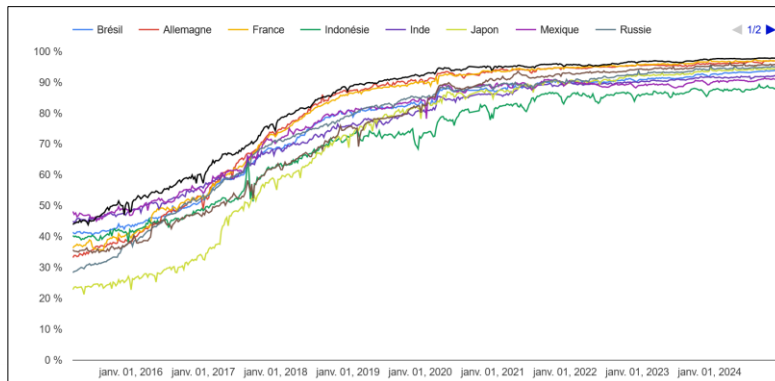
- Décrire l'inspection des certificats et l'inspection SSL complète (full SSL/SSH inspection)
- Configurer le FortiGate pour une inspection SSL/SSH complète ou juste une inspection des certificats.
- Installer des certificats CA privés sur les terminaux
- Dépanner les problèmes liés aux certificats

Inspection SSL/SSH

- **Traffic chiffré**

- De plus en plus d'applications exploitent la technologie de chiffrement SSL/TLS

- Les pirates peuvent masquer leurs malwares dans des communications chiffrées.



Inspection SSL/SSH

- **Traffic chiffré (suite)**

- Il n'est pas possible de lire son contenu

- Dès lors impossible de vérifier, par exemple, la présence de virus ou d'injection SQL dans le trafic.

- Pour contrôler le trafic, il faut déchiffrer

- Les NGFW disposent de fonctionnalités de déchiffrement du trafic SSL/TLS et SSH.

- Une fois déchiffré, il est possible d'appliquer de l'analyse antivirus ou l'IPS.

- **Deux méthodes d'inspection**

- *SSL Certificate Inspection*

- Méthode plus rapide (moins de latences, moins de ressources) mais moins sécurisée.

- Ne vérifie que la validité des certificats.

- *Full SSL Inspection (Deep inspection)*

- Offre une meilleure protection que le mode SSL Certificate Inspection.

- Introduit plus de latence et consomme plus de ressources.

- Permet de déchiffrer le trafic SSL/SSH pour appliquer des profils de sécurité.

Inspection SSL/SSH

- Les certificats numériques sont utilisés par le FortiGate pour :
 - Inspection du trafic
 - Inspection du trafic SSH et SSL.
 - Par exemple, FortiGate vérifie le certificat d'un serveur avant d'autoriser la connexion vers ce serveur.
 - Confidentialité
 - Assurer la confidentialité des échanges avec d'autres dispositifs (accès à FortiGuard en HTTPS).
 - Voir cours de cybersécurité 2.
 - Authentification
 - Authentification d'un utilisateur pour l'accès au réseau ou comme second facteur d'authentification.
 - Vérification des champs **Subject** et **Subject Alternative Name**.
 - Authentification d'un appareil, par exemple, pour autoriser une connexion VPN.
 - Authentification de second facteur pour l'administrateur FortiGate

SSL Certificate Inspection

- *SSL Certificate Inspection*
 - Utilisée pour vérifier l'identité des serveurs Web
 - L'UTM vérifie la validité du certificat pour le trafic chiffré
 - Si le certificat est valide, le trafic est accepté, même s'il contient des virus.
 - L'UTM extrait le FQDN de l'URL à partir de :
 - L'extension TLS *server name indication* (SNI) lors du handshake TLS.
 - Sinon, des champs *Subject* ou *Subject Alternative Name* du certificat SSL.
 - Utilisé pour le filtrage Web et le contrôle d'application
 - Le filtrage Web et le contrôle d'application sont les seules fonctionnalités de sécurité qui peuvent être appliquées en mode *SSL Certificate Inspection*.
 - Le trafic reste chiffré
 - Les attaques et les fichiers contenant des virus ne peuvent pas être détectés.

SSL Certificate Inspection

- *SSL Certificate Inspection Configuration*

Utilisé pour le trafic *sortant* : des utilisateurs internes se connectent à des serveurs en SSL (web, mails, FTPS).

Utilisé pour le trafic *entrant* : des utilisateurs externes se connectent à des serveurs internes.

Par défaut le profil est non modifiable
→ choisir « custom ».

Security Profiles > SSL/SSH Inspection

Edit SSL Inspection Profile

Name

Comments 37/255

SSL Inspection Options

Enable SSL Inspection of ☐ Multiple Clients Connecting to Multiple Servers ☐ Protecting SSL Server

Inspection Method ☐ SSL Certificate Inspection ☐ Full SSL Inspection

CA Certificate Fortinet_CA_SSL

Untrusted SSL Certificates

Indique quel certificat le FortiGate doit utiliser.

SSL Certificate Inspection

- *SSL Certificate Inspection Configuration*

Utilisé pour le trafic *sortant* : des utilisateurs internes se connectent à des serveurs en SSL (web, mails, FTPS).

Utilisé pour le trafic *entrant* : des utilisateurs externes se connectent à des serveurs internes.

Security Profiles > SSL/SSH Inspection

Edit SSL/SSH Inspection Profile

Name test

Comments Write a comment... 0/255

SSL Inspection Options

Enable SSL inspection of ☐ Multiple Clients Connecting to Multiple Servers ☐ Protecting SSL Server

Inspection method ☐ SSL Certificate Inspection ☐ Full SSL Inspection

CA certificate Fortinet_CA_SSL

Blocked certificates

Untrusted SSL certificates

Server certificate SNI check

Indique quel certificat le FortiGate doit utiliser.

Voir filtrage Web

SSL Certificate Inspection

• Invalid SSL certificates

– FortiGate effectue les contrôles suivants sur les certificats :

- Contrôle de la date de validité.
- Contrôle de la signature du certificat.
- Contrôle de la liste de révocation (CRL).

– Certificats invalides (Invalid)

- Par défaut, les certificats invalides génèrent un avertissement dans le navigateur.
- Il est possible d'autoriser les certificats invalides.

Keep untrusted & Allow : FortiGate autorise le site web et laisse le navigateur décider de l'action à entreprendre (signé par Fortinet_CA_Untrusted).

Block : FortiGate bloque le contenu du site.

Trust & Allow : Le FortiGate autorise le site web et considère le certificat comme fiable.(signé par Fortinet_CA_SSL)

Security Profiles > SSL/SSH Inspection

Common Options			
Invalid SSL certificates	Allow	Block	Custom
Expired certificates	Keep Untrusted & Allow	Block	Trust & Allow
Revoked certificates	Keep Untrusted & Allow	Block	Trust & Allow
Validation timed-out certificates	Keep Untrusted & Allow	Block	Trust & Allow
Validation failed certificates	Keep Untrusted & Allow	Block	Trust & Allow
Log SSL anomalies	 		



324

SSL Certificate Inspection

• Untrusted SSL certificates

– Certificats non fiables

- Les certificats SSL auto-signés ne sont pas considérés comme de confiance.
- Ils génèrent un avertissement dans le navigateur.

Edit SSL Inspection Profile

custom-deep-inspection
 certificate-inspection
 custom-deep-inspection
 deep-inspection

Name
 Comments 37/255

SSL Inspection Options

Enable SSL Inspection of **Multiple Clients Connecting to Multiple Servers**

Inspection Method **SSL Certificate Inspection** **Full SSL Inspection**

CA Certificate  Fortinet_CA_SSL [Download Certificate](#)

Untrusted SSL Certificates **Allow** **Block**  View Trusted CAs List

Allow : L'utilisateur reçoit un avertissement mais peut se rendre sur le site en ajoutant une exception au navigateur (signé par Fortinet_CA_SSL).

Block : Connexion au serveur bloquée, pas d'exception possible.

Ignore : FortiGate utilise toujours un certificat de confiance (Fortinet_CA_SSL) pour remplacer celui du serveur et la connexion peut être établie.



325

SSL Certificate Inspection

- *SSL Certificate Inspection Configuration (cont.)*

- *Blocked Certificate*

- Bloquer ou autoriser les certificats potentiellement malveillants.

- *Enforce SSL cipher compliance*

- Activer/désactiver la conformité du chiffrement SSL. Cette option ne concerne que l'inspection SSL complète.

- *Enforce SSL negotiation compliance*

- Activer/désactiver la conformité de la négociation SSL. Cette option ne concerne que l'inspection SSL complète.

- *RPC over HTTPS*

- Activer/désactiver l'inspection des appels de procédure à distance (RPC) sur le trafic HTTPS. Cette option ne concerne que l'inspection SSL complète.



326

SSL Certificate Inspection

- *SSL/TLS inspection options*

Security Profiles > SSL/SSH Inspection

Si coché, inspecte tous les ports

Sinon, inspecte uniquement les ports spécifiés

Les sites considérés comme « réputés » par FortiGuard
Ne sont pas soumis à l'inspection.

Permet de définir des sites Web, des catégories ou
encore des étendues d'adresses exemptées de l'inspection.
(Obligation légale, HPKP, ...)



327

Full SSL Inspection

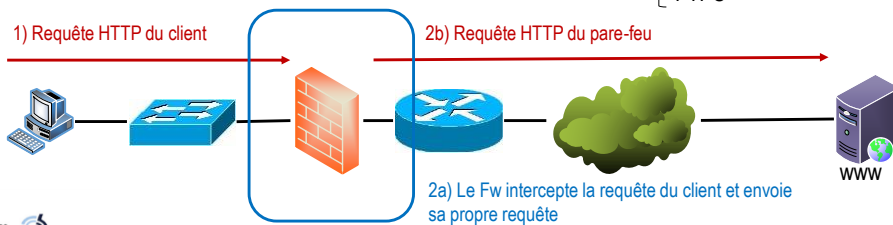
• "Full SSL Inspection"

– Principe (*Man-in-the-middle transparent proxy*)

1. Le client contacte le serveur Web
2. Le FortiGate agit en proxy transparent:
 - a) Il intercepte la requête du client.
 - b) Il envoie sa propre requête vers le serveur Web.

L'UTM peut jouer le rôle de la terminaison SSL/TLS pour les protocoles

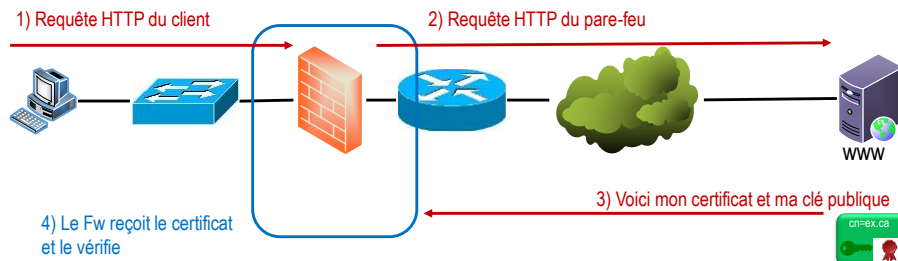
HTTPS
IMAPS
POP3S
SMTPS
FTPS



Full SSL Inspection

– Principe (suite)

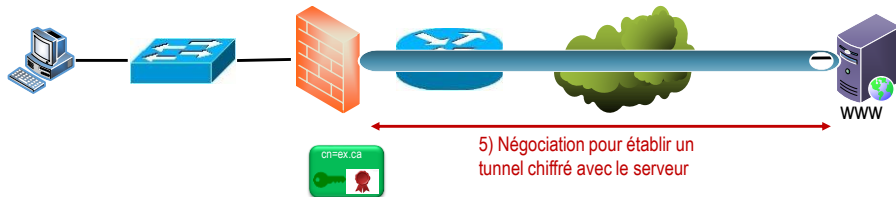
3. Le serveur Web répond en envoyant son certificat contenant sa clé publique.
4. Le FW reçoit le certificat du serveur et le vérifie.



Full SSL Inspection

– Principe (suite)

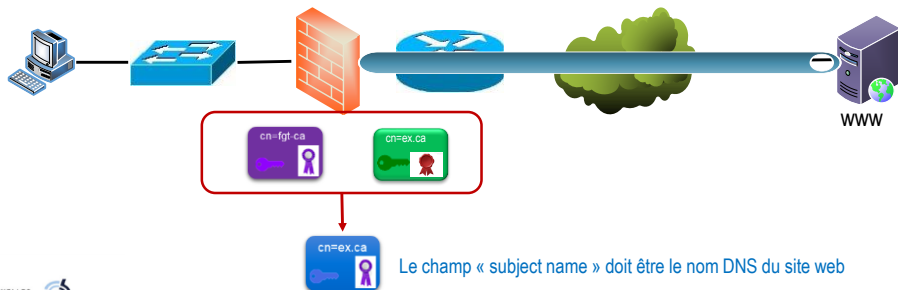
5. Le FW utilise le certificat pour établir un tunnel chiffré avec le serveur



Full SSL Inspection

– Principe (suite)

6. Le FW génère un nouveau certificat au nom du serveur
 - Pour pouvoir générer de nouveaux certificats, le certificat doit avoir les extensions suivantes :
 - » cA=True
 - » keyUsage=keyCertSign
 - Pour cela, le Fortigate dispose par défaut d'un certificat auto-signé : Fortinet_CA_SSL



Full SSL Inspection

– Principe (suite)

7. Le FW utilise ce nouveau certificat afin de se faire passer pour le serveur et établir un tunnel chiffré avec le client.
8. Le client vérifie la validité du certificat.
9. Négociation pour établir un tunnel chiffré (Le client pense qu'il négocie un tunnel avec le serveur).



Full SSL Inspection

– Principe (suite)

Sans Full SSL inspection

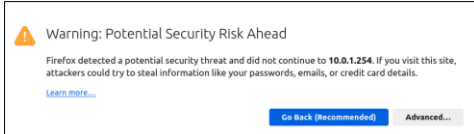


Avec Full SSL inspection



SSL/SSH Inspection

- Eviter les messages d'avertissement de certificat
 - Par défaut, FortiGate utilise un certificat auto-signé pour l'accès GUI au FortiGate

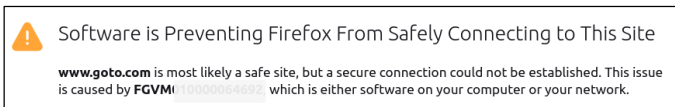


Un certificat émis par une CA dont le certificat racine n'est pas présent dans la liste des autorités de certification racine de confiance du navigateur (magasin de certificat) va générer un message d'avertissement car le navigateur ne peut pas garantir la validité du certificat.

- Vous pouvez accepter l'avertissement et établir la connexion.
 - Lorsque vous acceptez l'avertissement, votre navigateur importe le certificat auto-signé du FortiGate dans son magasin de certificats. A la prochaine connexion au FortiGate, le navigateur fera déjà confiance au certificat présenté.
- Vous pouvez utiliser le certificat `Fortinet_GUI_Server`
 - Via le menu System > Settings > HTTPS server certificate
 - Et importer le certificat `Fortinet_CA_SSL` dans votre navigateur.

SSL/SSH Inspection

- Eviter les messages d'avertissement de certificat (suite)
 - SSL/SSH deep inspection
 - Par défaut, le certificat utilisé par le FortiGate dans le profil SSL/SSH deep inspection est un certificat auto-signé.
 - Les navigateurs afficheront donc un message d'avertissement.



- Vous pouvez télécharger le certificat `Fortinet_CA_SSL` depuis le FortiGate

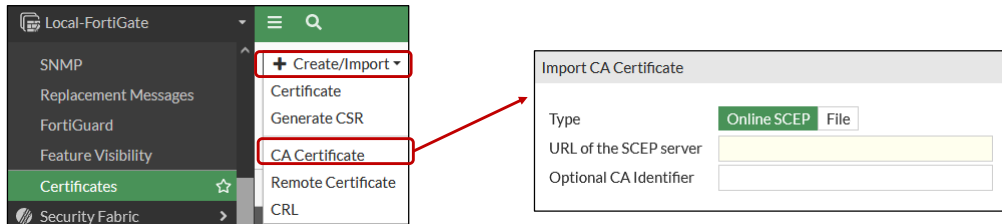
System > Certificates

+ Create/Import Edit Delete View Details Download Search		
Name	Subject	Comments
Local CA Certificate 2		
Fortinet_CA_SSL	C = US, ST = California, L = Sunnyvale, O...	This is the default CA ce
Fortinet_CA_Untrusted	C = US, ST = California, L = Sunnyvale, O...	This is the default CA ce

Lors du téléchargement, le FortiGate génère un fichier .cer que vous pouvez importer sur l'ordinateur.

SSL/SSH Inspection

- Eviter les messages d'avertissement de certificat (suite)
 - Importer un certificat sur le FortiGate
 - Vous pouvez importer le certificat d'une autorité de certification reconnue.



SSL/SSH Inspection

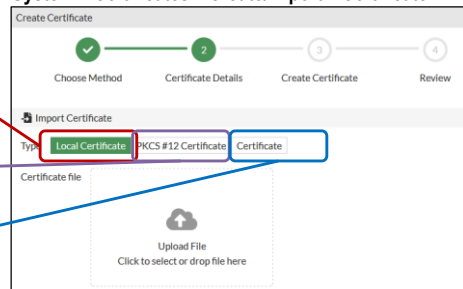
- Eviter les messages d'avertissement de certificat (suite)
 - Importer un certificat de votre compagnie sur le FortiGate
 - Si votre entreprise gère sa propre autorité de certification, vous pouvez générer des certificats pour l'accès à l'interface graphique du FortiGate ou l'accès à des VPN-SSL.
 - Trois méthodes :

a) Générer une demande de signature de certificat (CSR) et la soumettre à l'autorité de certification

b) Charger un fichier de certificat PKCS#12, (fichier .PFX). Il contient le certificat et la clé privée associée.

c) Importer le fichier de certificat et la clé associée dans le magasin de certificats du FortiGate

System > Certificates > Create/Import > Certificate



SSL/SSH Inspection

- Charger les CRL dans le FortiGate
 - Importer les CRL

Vous pouvez charger les CRL dans le FortiGate sous forme de fichiers fournis par les administrateurs de l'autorité de certification.

Méthode recommandée : charger les CRL via HTTP, LDAP ou SCEP.

System > Certificates > Create/Import > CRL

Import CRL

Import Method: ☐ File Based ☒ Online Updating

☒ HTTP
 URL of the HTTP server:

☐ LDAP

☐ SCEP

- Une fois importée, une section CRL apparaît dans la liste des certificats (System > certificates)

System > Certificates

Name	Subject	Comments	Issuer	Expires	Status	Source
CRL 1						
CRL_1			DigiCert Inc		Valid	User
Local CA Certificate 2						
Fortinet_CA_SSL	C = US, ST = Califor...	This is the default...	Fortinet	2030/04/25 13:37:28	Valid	Factory
Fortinet_CA_Untrus...	C = US, ST = Califor...	This is the default...	Fortinet	2030/04/25 12:21:58	Valid	Factory

338

SSL/SSH Inspection

- Magasin de certificat du FortiGate

System > Certificates

Name	Subject	Comments	Issuer	Expires	Status	Source
CRL 1						
CRL_1			DigiCert Inc		Valid	User
Local CA Certificate 3						
ACME-SSL-Cert	C = CA, O = ACME, OU = ACME-IIT, CN = ACME-SSL...	Company signing CA	ACME	2024/09/27 06:21:00	Valid	User
Fortinet_CA_SSL	C = US, ST = California, L = Sunnyvale, O = Fortinet, O...	This is the default CA certificate ...	Fortinet	2030/04/25 13:37:28	Valid	Factory
Fortinet_CA_Untrusted	C = US, ST = California, L = Sunnyvale, O = Fortinet, O...	This is the default CA certificate ...	Fortinet	2030/04/25 12:21:58	Valid	Factory
Local Certificate 18						
FortiGate_ACME					Pending	User
Ana	C = CA, O = ACME, OU = ACME-Finance, CN = Ana, e...		ACME	2024/09/27 06:21:00	Valid	User
Local-FortiGate	C = CA, O = ACME, OU = ACME-IT, CN = ACME-FGT, ...		ACME	2024/09/27 06:04:00	Valid	User
Fortinet_Wifi	C = US, ST = California, L = Sunnyvale, O = "Fortinet, L...	This certificate is embedded in t...	DigiCert Inc	2024/06/06 16:59:59	Valid	Factory
Fortinet_GUI_Server	C = US, ST = California, L = Sunnyvale, O = Fortinet Lt...	This is the default CA certificate ...	Fortinet	2025/08/28 10:57:01	Valid	Factory
Remote CA Certificate 5						
CA_Cert_1	C = CA, O = ACME, OU = ACME-IIT, CN = ACME-SSL...		ACME	2024/09/27 06:21:00	Valid	User
Fortinet_Wifi_CA	C = US, O = DigiCert Inc, CN = DigiCert TLS RSA SHA...		DigiCert Inc	2030/09/23 16:59:59	Valid	Factory
Fortinet_CA	C = US, ST = California, L = Sunnyvale, O = Fortinet, O...		Fortinet	2056/05/27 13:27:39	Valid	Factory

339

Certificats de signature

Certificats utilisateurs et de périphériques

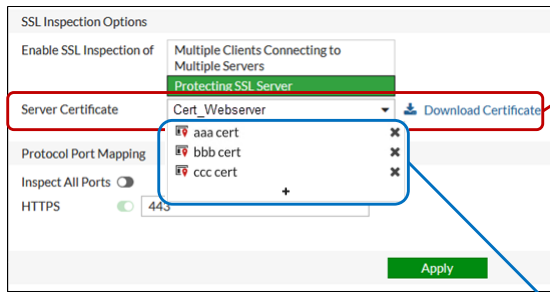
Certificats importés

- **HTTP Strict Transport Security (HSTS)**
 - HSTS doit être activé sur le site Web
 - Permet à un serveur web de signifier au navigateur web qu'il doit obligatoirement être contacté en HTTPS.
 - HSTS Strict
 - Si la sécurité de la connexion n'est pas garantie (certificat auto-signé, invalide, ...), l'utilisateur ne peut pas accéder au site.
- **Certificate pinning**
 - Ancrage, agrapage ou encore épinglage de certificat
 - Technique de sécurité utilisée pour protéger les communications entre un client et un serveur contre des attaques de type man-in-the-middle (MITM).
 - Principe
 - Une application (navigateur Web par exemple) est configurée pour accepter uniquement un ou plusieurs certificats ou clés publiques spécifiques pour un serveur.
 - L'information sur ces certificats ou clés dits "ancrés" est codée en dur dans l'application.

- **Protocoles autres que HTTPS**
 - Toutes les applications utilisant SSL sont impactées par l'inspection SSL/SSH
 - Pas uniquement les navigateurs web (HTTPS) : FTPS, POP3S, SMTPS, LDAPS, Microsoft outlook 365, ...
 - Full SSL/SSH inspection + Certificate pinning
 - Par exemple, Dropbox utilise l'épinglage de certificat pour s'assurer qu'aucune inspection SSL n'est possible sur le trafic utilisateur.
 - Lors de l'utilisation de l'inspection SSL complète sur le FortiGate, le client Dropbox cesse de fonctionner et signale qu'il ne peut pas établir de connexion sécurisée.
 - « Solution »
 - Exempter les domaines auxquels le client Dropbox se connecte de l'inspection SSL.
 - Utiliser l'inspection de certificat plutôt que l'inspection SSL/SSH complète.
 - Désactiver HSTS dans le navigateur.

Full SSL Inspection

- Protecting SSL Server
 - Utilisé pour protéger un ou plusieurs serveur(s) spécifique(s).

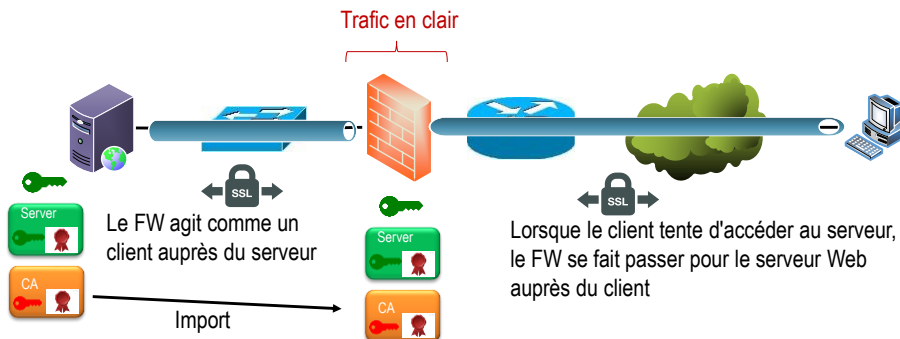


Le certificat, la clé privée et la chaîne de certificats du serveur doivent être installés dans le FortiGate

Depuis FortiOS 7, il est possible de définir plusieurs certificats dans un même profil pour protéger plusieurs serveurs.

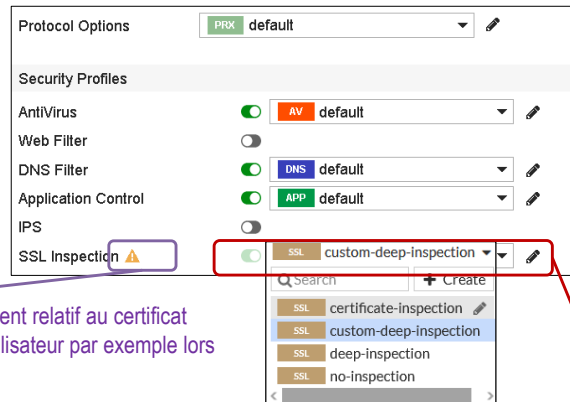
Full SSL Inspection

- Protecting SSL Server (cont.)
 - Principe



Full SSL Inspection

- Profil de sécurité
 - SSL/SSH inspection est un profil de sécurité à assigner à une règle de pare-feu.



Le signe *attention* sert à signaler l'avertissement relatif au certificat qui peut apparaître dans le navigateur de l'utilisateur par exemple lors de l'utilisation d'un certificat auto-signé.

Choix du profil

Chapitre 9

Filtrage Web

Objectifs

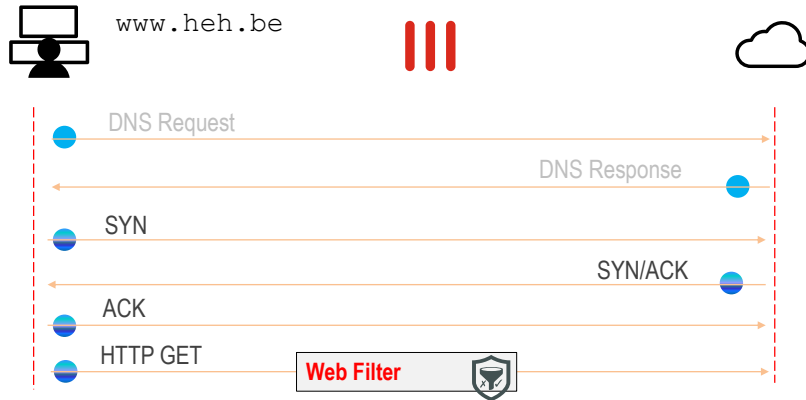
- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Sélectionner le mode d'inspection approprié (flux ou proxy).
 - Créer et appliquer des profils de filtrage Web et de filtrage DNS.
 - Créer des filtres URL statiques.
 - Configurer l'inspection des certificats pour le filtrage web.

Web Filtering

- Intérêts du filtrage Web
 - Préserver les ressources
 - Éviter une mauvaise utilisation de la bande passante.
 - Préserver la productivité des employés.
 - Réduire l'exposition aux menaces Web.
 - Empêcher l'accès aux sites connus pour être infectés.
 - Empêcher la perte ou l'exposition d'informations confidentielles.
 - Empêcher la violation du droit d'auteur.
 - Protéger contre certains contenus
 - Empêcher (les enfants) de regarder des contenus inappropriés (Écoles).

Web Filtering

- Quand s'applique le filtrage web?



Source : Fortinet Inc., FortiGate Administrator

Web Filtering

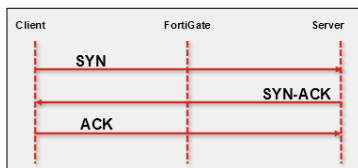
- Deux modes d'inspection

Policy & Objects > Firewall Policy (Edit Policy)

Inspection Mode ☐ Flow-based ☒ Proxy-based

Flow-based inspection

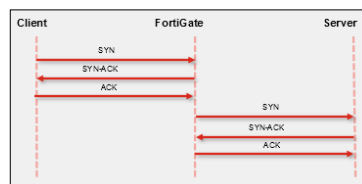
- Mode d'inspection par défaut.
- Moins de latence (scan plus rapide).
- Consomme moins de ressources.
- Moins d'options de filtrage.
- NGFW mode disponible.
- Le trafic n'est pas modifié.



```
config firewall policy
edit <policy_id>
set utm-inspection-mode [proxy | flow]
end
```

Proxy-based inspection

- Intercepte le trafic (proxy transparent, deux connexions TCP).
- Plus de latence.
- Consomme plus de ressources (*buffers traffic*).
- Plus d'options de filtrage, meilleure sécurité.
- Peut modifier le trafic (par ex. safe search, ...)



Web Filtering

- Deux modes d'inspection (suite)

New Web Filter Profile

Name: WebFilter

Comments: Write a comment... 0/255

Feature set: **Flow-based** Proxy-based

☐ FortiGuard Category Based Filter

☒ Static URL Filter

Block invalid URLs ☐

URL Filter ☐

Block malicious URLs discovered by FortiSandbox ☐

Content Filter ☐

☒ Rating Options

Allow websites when a rating error occurs ☐

Rate URLs by domain and IP Address ☐

New Web Filter Profile

Name: WebFilter

Comments: Write a comment... 0/255

Feature set: Flow-based **Proxy-based**

☐ FortiGuard Category Based Filter

☐ Allow users to override blocked categories

☒ Search Engines

Enforce 'Safe Search' on Google, Yahoo!, Bing, Yandex ☐

Restrict YouTube Access ☐

Log all search keywords ☐

☒ Static URL Filter

☒ Rating Options

☒ Proxy Options

Restrict Google account usage to specific domains ☐

HTTP POST Action: **Allow** Block

Remove Java Applets ☐

Remove ActiveX ☐

Remove Cookies ☐

350

Web Filtering

- Filtrage du trafic HTTPS
 - L'inspection du certificat est suffisante (SSL certificate inspection)
 - FortiGate inspecte la poignée de main SSL initiale non chiffrée.
 - Si le champ SNI existe (Server Name Indication), FortiGate l'utilise pour obtenir le FQDN afin d'évaluer le site.
 - Sinon, FortiGate récupère le FQDN à partir du champ CN du certificat du serveur.

```

Secure Sockets Layer
  TLSv1.2 Record Layer: Handshake Protocol: Client Hello
  Content Type: Handshake (22)
  Version: TLS 1.0 (0x0301)
  Length: 512
  Handshake Protocol: Client Hello
  Handshake Type: Client Hello (1)
  Length: 508
  Version: TLS 1.2 (0x0303)
  Cipher Suites Length: 36
  Cipher Suites (18 suites)
  Compression Methods (1 method)
  Extension: server_name (len=21)
  Type: server_name (0)
  Length: 21
  Server Name Indication extension
  Server Name list length: 19
  Server Name Type: host_name (0)
  Server Name length: 16
  Server Name: www.fortinet.com
  
```

Certificate

General Details Certification Path

Show: <All>

Field	Value
Signature hash algorithm	sha256
Issuer	DigiCert SHA2 High Assurance ...
Valid from	March 18, 2019 8:00:00 PM
Valid to	June 9, 2021 8:00:00 AM
Subject	www.fortinet.com, IT, Fortine...
Public key	RSA (2048 Bits)
Public key parameters	05 00
Authority Key Identifier	KeyID:a5168ff0a01207753rr

CN = www.fortinet.com

OU = IT

O = Fortinet, Inc.

L = Sunnyvale

C = California

351

• Configuration du profil d'inspection SSL

– Server certificate SNI check

- **Enable** : FortiGate vérifie le champ CN du certificat et le SNI. S'il n'y a pas correspondance il utilise la valeur du champ CN (Par exemple, SNI = youtube.com, CN = google.com).
- **Strict** : FortiGate ferme la connexion client en cas de non-concordance.
- **Disable** : FortiGate ne vérifie pas le SNI.

Security Profiles > SSL/SSH Inspection

SSL Inspection Options	
Enable SSL inspection of	Multiple Clients Connecting to Multiple Servers Protecting SSL Server
Inspection method	SSL Certificate Inspection Full SSL Inspection
CA certificate	Fortinet_CA_SSL Download
Blocked certificates	Allow Block View Blocked Certificates
Untrusted SSL certificates	Allow Block View Trusted CAs List
Server certificate SNI check	Enable Strict Disable



352

• Modes NGFW

– NGFW Profile-based

- Créer un profil de sécurité puis appliquer ce profil à une règle de pare-feu.
- Peut-être utilisé dans les modes d'inspection flow et proxy.

– NGFW Policy-based

- Uniquement disponible avec le mode d'inspection flow-based.
- Le contrôle d'application et le filtrage web peuvent être appliqués directement dans la règle de pare-feu. Il n'est pas nécessaire de configurer un profil de sécurité.
- SSL/SSH inspection doit être configuré.
- Nécessite l'utilisation de Central NAT

System > settings

System Operation Settings	
NGFW Mode	Profile-based Policy-based
Virtual Domains	☐



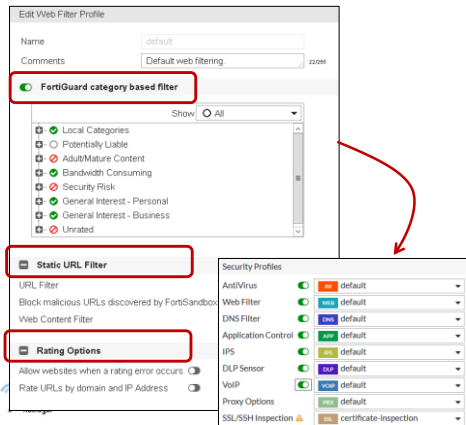
353

Web Filtering

• Deux modes NGFW

Profile-based Web Filter

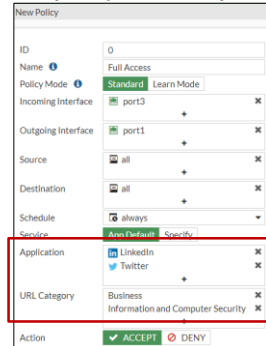
- Configurer un profil de sécurité Web filter.
- Appliquer le profil à une règle de pare-feu



Policy-based Web Filter

- Appliquer le filtrage par catégorie directement dans une règle de pare-feu
- Profil d'inspection SSL/SSH est requis

Policy & Objects > Security Policy



354

FortiGuard Category Filter

• Filtres de catégorie FortiGuard

– Catégories

- Permet de regrouper des URL afin d'éviter de devoir filtrer individuellement les sites Web.
- L'action (pass ou block) est basée sur la catégorie et non sur l'URL elle-même.

– Catégories FortiGuard

• Contenus des catégories FortiGuard

- Déterminés par des humains et par des robots d'exploration du Web.
- Ils examinent différents aspects des sites Web et établissent une note.

– Nécessite une licence

- Période de grâce de 7 jours.
- Si le contrat expire, le FortiGate ne pourra pas évaluer les sites Web.



355

FortiGuard Category Filter

- Filtres de catégorie FortiGuard

- Web Filter lookup

- <https://fortiguard.com/webfilter>

Permet de rechercher la catégorie d'un site

 Web Filter Lookup

Submit a URL to check its Rating

Latest Web Filter Databases 20.05299

 Web Filter: www.heh.be

Category: Education

Educational Institutions: Sites sponsored by schools, other educational facilities and non-academic research institutions, and sites that relate to educational events and activities. Educational Materials: Sites that provide information about, sell, or provide curriculum materials. Sites that direct instruction, as well as academic journals and similar publications where scholars and professors submit academic/research articles.

FortiGuard Category Filter

- Filtres de catégorie FortiGuard

- Web Filter Categories

- Permet de trouver des pages de test afin de vérifier le filtrage opéré par le fortigate.
 - <https://www.fortiguard.com/wftest/26.html>

Bandwidth Consuming	
Category	Description
File Sharing and Storage	Websites that permit users to utilize Internet servers to store personal files or for sharing, such as with photos. Test

 <https://fortiguard.com/wftest/24.html>

FortiGuard Web Filtering Test Page

This is a test page that will be rated by FortiGuard Web Filtering as:

File Sharing and Storage

Websites that permit users to utilize Internet servers to store personal files or for sharing, such as with photos.
 Examples: instagram.com, imgur.com, flickr.com, dropbox.com

FortiGuard Category Filter

• Principe des filtres de catégorie FortiGuard

– Principe du filtrage Web

1. Le FortiGate interroge le réseau de distribution FortiGuard (ou un FortiManager), afin de déterminer la catégorie de la page Web demandée.
2. Le FortiGate effectue l'action configurée pour cette catégorie.

– Actions

- Les actions à effectuer peuvent être configurées par catégories et par sous-catégories.

Proxy-based : ☒ Allow ☒ Monitor ☒ Block ☒ Warning ☒ Authenticate

Flow-based (Profile-based) : ☒ Allow ☒ Monitor ☒ Block ☒ Warning ☒ Authenticate

Flow-based (Policy-based) : Action définie dans la règle de pare-feu (accept/deny)

FortiGuard Category Filter

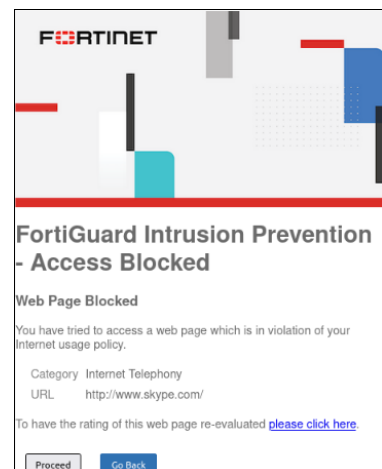
• Actions des filtres de catégorie FortiGuard

– Action "Warning"

- **Informe les utilisateurs que le site Web demandé n'est pas autorisé**
 - L'utilisateur a la possibilité de tout de même se rendre sur le site ou de revenir sur le site précédent.
- **Disponible uniquement avec**
 - Mode proxy.
 - Mode flow avec profile-based.
- **Intervalle d'avertissement**
 - Quand le timer expire, la page d'avertissement est à nouveau affichée.
 - La page peut être personnalisée.

Edit Filter

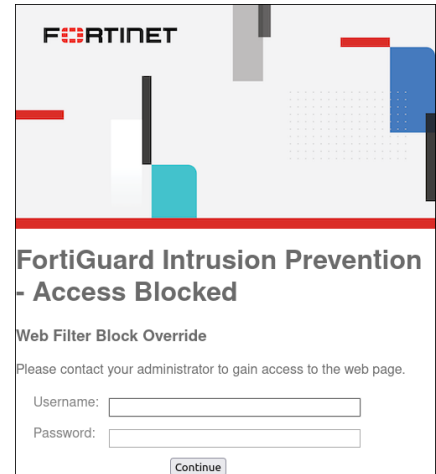
Warning Interval hour(s) minute(s) second(s)



FortiGuard Category Filter

• Actions des filtres de catégorie FortiGuard (suite)

- Action « Monitor »
 - Le FortiGate autorise l'accès au site et journalise le trafic.
- Action "Authenticate"
 - Bloque les sites Web demandés, sauf si l'utilisateur s'authentifie.
 - Intervalle de temps d'autorisation
 - Les utilisateurs ne doivent pas s'authentifier à nouveau s'ils accèdent à d'autres sites Web de la même catégorie.
 - Intervalle de temps personnalisable.



360

FortiGuard Category Filter

• Configuration de l'action "Authenticate"

Security Profiles > Web Filter

☒ FortiGuard category based filter

Name	Action
Local Categories 2	
custom1	Allow
custom2	Allow

Sélectionner la règle

Choisir l'action "Authenticate"

Choix des groupes d'utilisateurs

Edit Filter			
Warning Interval	0	hour(s)	5
		minute(s)	0
		second(s)	
Selected User Groups	+		

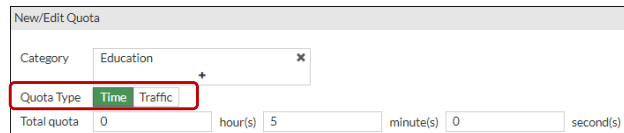
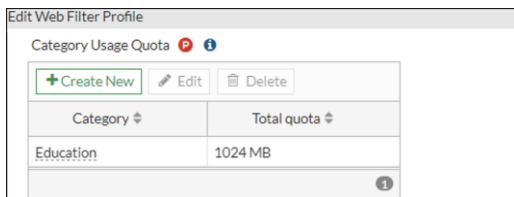
Les utilisateurs ne doivent pas s'authentifier à nouveau s'ils accèdent à d'autres sites Web de la même catégorie dans cet intervalle de temps.



361

FortiGuard Category Filter

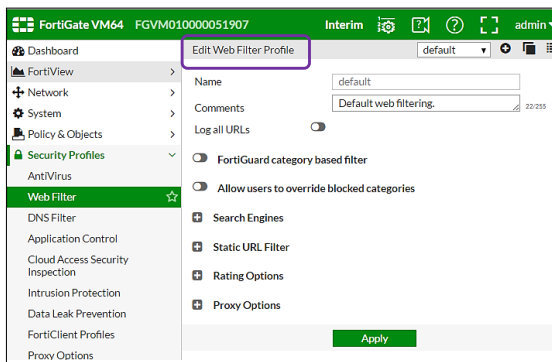
- **Actions des Filtres de catégorie FortiGuard (suite)**
 - **Quotas de temps**
 - **Permettent de limiter le temps ou la quantité de trafic**
 - Uniquement disponible
 - » pour le filtrage web en mode proxy.
 - » avec les actions Monitor, Warning, et Authenticate.
 - **Plusieurs quotas (minuteurs) peuvent être configurés**
 - Chaque quota peut être lié à une ou plusieurs catégories.
 - Les quotas peuvent être assignés
 - » Pour chaque IP source.
 - » Ou pour chaque utilisateur si l'authentification est activée.



362

Web filter configuration

- **Configuration du filtrage Web**
 - Différentes options selon le mode proxy ou le mode flow



Proxy-based options

- Category-based
- Search engines
- Static URL
- Rating option
- Proxy option

Flow-based options

- Category-based
- Static URL
- Rating Options



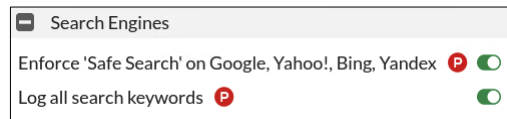
363

Web filter configuration

- Search Engines filtering (proxy-based only)

- Safe search

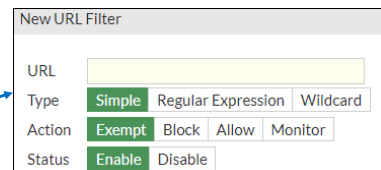
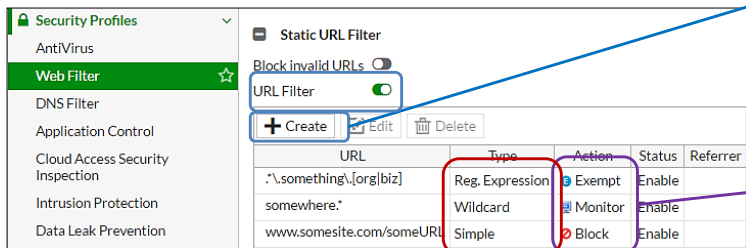
- Un code est ajouté à l'URL pour imposer l'utilisation de safe search
 - Par exemple, pour une recherche Google, la chaîne "&safe=active" est ajoutée à l'URL.
- Fortigate prends en charge le safe search pour Google, Yahoo, Bing et Yandex.
 - Permet d'utiliser safe search même si la fonction n'est pas configurée dans le browser.
- Deep SSL inspection est requis
 - Ne fonctionne pas avec « certificate inspection ».



URL filtering configuration

- Static URL Filter

- Comparaison avec les URL configurés dans le filtre d'URL



Si une correspondance est trouvée, l'action configurée est effectuée.

- Allow
- Exempt
- Block
- Monitor

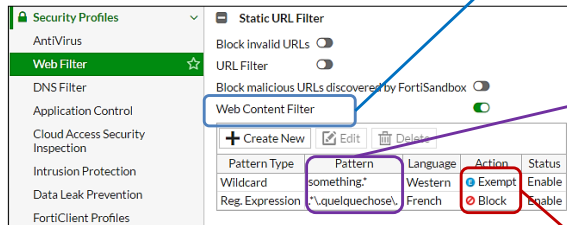
Pour trouver la correspondance exacte, le filtrage d'URL peut utiliser des motifs simples (single), des expressions régulières (regular expression) et des caractères génériques (wildcard).

URL filtering configuration

- *Static URL Filter (cont.)*

- *Web Content Filter*

- Deep SSL inspection est requis



Filtrage sur base de phrases ou de mots contenus dans les pages Web.

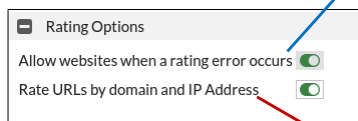
Les mots à rechercher sont associés à une valeur numérique.

Si la somme des valeurs est supérieure à un seuil défini dans le profil du filtre Web, l'action est réalisée :

- Exempt
- Block

URL filtering configuration

- *Rating Options*



Si une erreur d'évaluation se produit, les utilisateurs auront un accès complet non filtré à tous les sites Web.

Compare les évaluations par URL et par adresse IP du site.
L'action de l'évaluation la plus élevée est appliquée.

FortiGuard Category Filter

- **Web Rating Override**
 - Permet de modifier la catégorie d'un site sans passer par FortiGuard
 - **Ne s'applique qu'aux noms d'hôte**
 - Aucun caractère générique ou URL n'est autorisé.
 - **Ne fonctionne plus si la licence FortiGuard expire**

OK Pas OK

heh.be www.heh.be/index.html

www.heh.be www.heh.*

Il est possible d'ajouter ses propres catégories

Informations sur la catégorie d'origine

Informations sur la catégorie de remplacement

368

FortiGuard Category Filter

- **Web Filter Cache**
 - Fonction cache
 - FortiGate peut conserver en mémoire les réponses aux évaluations de sites Web.
 - Si en cache, FortiGate ne renvoie pas de demande d'évaluation à FortiGuard.
 - Evaluation plus rapide.
 - TTL par défaut = 60 minutes.

System > FortiGuard

Filtering

Web Filter cache ☒ Clear cache after 60 Minutes

Email Filter cache ☒ Clear cache after 30 Minutes

FortiGuard filtering services HTTPS 8888

Test Connectivity

Filtering services availability

Web Filtering ☒

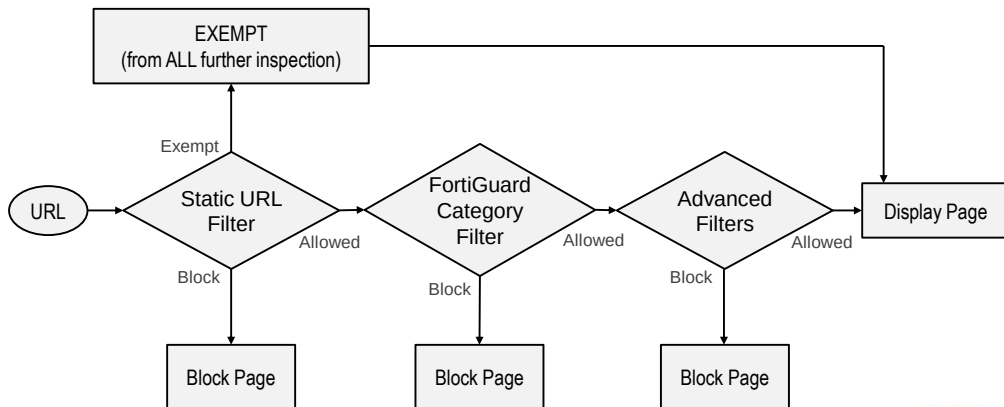
Anti-Spam ☒

Request re-evaluation of a URL's category

Ordre du filtrage

- Ordre du filtrage

- Tous les filtres configurés doivent autoriser le site pour qu'il soit affiché dans le navigateur



Web filter configuration

- Log

- Log & Report > Security Events > Web filter

Summary Logs							
Search				Web Filter Disk 24 hours Details			
Date/Time	User	Source	Action	URL	Category	Initiator	Sent / Received
2023/09/20 07:43:02		10.0.1.10	Blocked	https://www.google.com/	Search Engines and Portals		517 B / 0 B

Dépannage

- Vérifier l'accès aux serveurs FortiGuard

- Afficher les informations sur les serveurs FortiGuard.

- Drapeaux : D (IP renvoyée par le DNS), I (serveur de contrat contacté), T (délai d'attente), F (échec)

```
FortiGate-VM64 # diagnose debug rating
Locale       : english
Service      : Web-filter
Status       : Enable
License      : Contract
Num. of servers : 1
Protocol     : https
Port         : 443
Anycast      : Enable
Default servers : Included

-- Server List (Wed Apr 21 13:59:43 2021) --
IP           Weight RTT  Flags TZ FortiGuard-requests Curr Lost Total Lost Updated Time
173.243.140.16 -72 101 Di    0      36      0      0      0 Wed Apr 21
                                     13:58:13 2021
```

Dépannage

- Vérifier l'accès aux serveurs FortiGuard (suite)

- Par défaut, FortiGate est configuré pour imposer l'utilisation du port HTTPS 443

- Désactiver la commande *fortiguard-anycast* rend d'autres ports et protocoles disponibles
 - Les protocoles HTTPS et UDP
 - Les ports 53, 443 et 8888.

- Attention

- Si vous choisissez du trafic UDP sur le port 53 pour envoyer des requêtes de filtrage vers FortiGuard, les profils de sécurité pourraient bloquer le trafic car ce n'est pas du trafic DNS.
 - L'ouverture, par exemple du port UDP/8888, n'est pas garantie dans tous les réseaux.

```
config system fortiguard
  set fortiguard-anycast {enable|disable}
  set protocol {udp|https}
  set port {8888|53|443}
end
```

13:58:13 2021

Compléments Filtrage Web

DNS Filtering

- **DNS-Based Web Filtering**
 - Filtrage des requêtes DNS
 - Avant une requête HTTP GET, les machines clientes utilisent des requêtes DNS pour connaître l'IP du serveur à joindre.
 - Cette option filtre la requête DNS plutôt que la requête HTTP GET.
 - Caractéristiques
 - Impacte tous les protocoles qui dépendent du DNS, pas seulement le trafic HTTP.
 - Ne permet pas de filtrer aussi précisément que le filtrage HTTP.
 - Prend en charge le filtrage d'URL et les catégories FortiGuard uniquement.
 - Possible de filtrer les requêtes DNS chiffrées (> FortiOS 7)

DNS Filtering

- Principe du filtrage DNS

- Etapes du filtrage DNS

1. Lorsqu'il reçoit une requête DNS d'un client, FortiGate génère une requête DNS vers le service SDNS FortiGuard.
2. FortiGuard renvoie une adresse IP et une évaluation qui inclut la catégorie FortiGuard de la page Web demandée.
3. Le Fortigate effectue l'action configurée pour cette catégorie.

- Actions

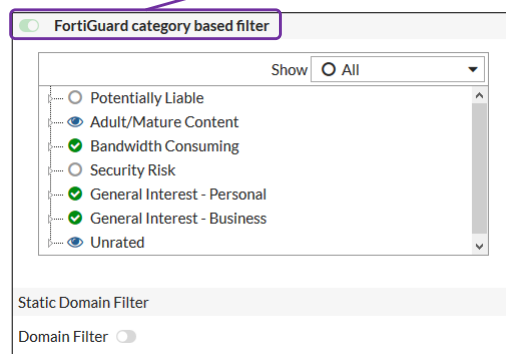
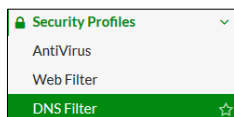
- Les actions à effectuer peuvent être configurées par catégories et sous-catégories.



DNS Filter Configuration

- DNS Filter Profile

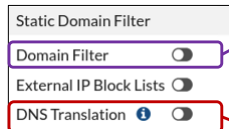
- Uniquement disponible en mode proxy-based inspection



Activer/désactiver le filtrage par catégorie

DNS Filter Configuration

• DNS Filter Profile (suite)



Activer/désactiver le filtrage statique

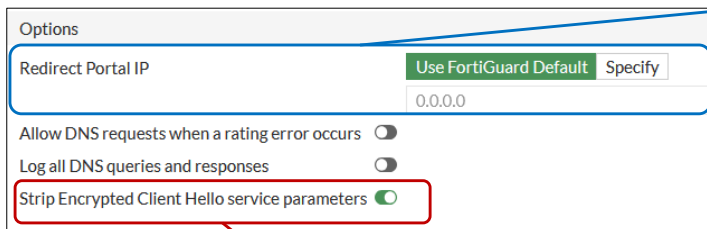
Permet de traduire une adresse IP résolue par DNS en une autre adresse IP de votre choix.

DNS Filter Configuration

• DNS Filter Profile (suite)

– Encrypted Client Hello (ECH)

- Extension de TLS qui permet à TLS de cacher les informations exposées dans le message TLS ClientHello non crypté. Or, si le SNI est chiffré FortiGate ne peut pas l'utiliser pour évaluer le site Web.



Rediriger les requêtes bloquées vers un portail

Web Page Blocked!

You have tried to access a web page which belongs to a category that is blocked.

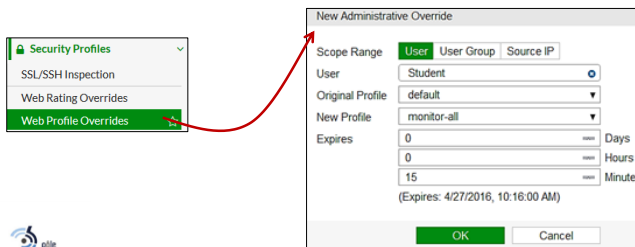
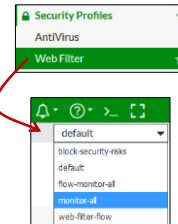
Supprime la réponse ECH renvoyée par le serveur DNS, ce qui empêche TLS de recevoir la clé de chiffrement ECH pour chiffrer le ClientHello.

FortiGuard Category Filter

• Web Profile Overrides

– Changer le profil de filtrage Web

- **Permet d'adapter les règles d'inspection du trafic**
 - Selon les utilisateurs, les groupes d'utilisateurs ou les adresses IP.
 - Uniquement disponible pour l'inspection en mode proxy.
- **Pour l'utiliser, une authentification est nécessaire**
 - Une fois activée, la page de blocage de FortiGuard affiche un lien que les utilisateurs peuvent sélectionner pour activer le remplacement.



Le nouveau profil est appliqué à l'utilisateur pendant un certain laps de temps

FortiGuard Category Filter

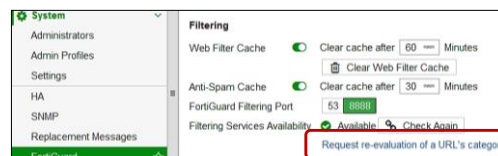
• FortiGuard Rating Submissions

– Classement correct des sites?

- Il est possible que des erreurs soient présentes dans les classements (robots...).
- Vous pouvez ne pas être d'accord avec la notation donnée par FortiGuard.

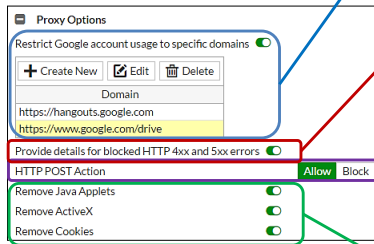
– Modifier l'évaluation d'un site?

- **Vous pouvez contacter l'équipe de FortiGuard**
 - Pour demander à modifier l'évaluation d'un site.
 - Pour faire évaluer un site qui ne figure pas déjà dans la base de données.



URL filtering configuration

- Proxy options



Permet de bloquer l'accès à certains comptes et services Google.

Le Fortigate affiche ses propres pages d'erreurs de type 4xx et 5xx.

L'option Allow empêche un timeout du serveur lors du scan ou lorsque d'autres processus de filtrage sont exécutés pour le trafic sortant.

Permet de filtrer les scripts ActiveX, les applets Java ou les cookies.
Attention, les sites concernés pourraient ne plus fonctionner correctement.

Filtrage Vidéo

- Permet de contrôler l'accès au contenu YouTube (> FortiOS 7)

- Contrôle l'accès aux vidéos Youtube

- Pour autoriser, surveiller ou bloquer
 - en fonction de la catégorie,
 - Des chaînes YouTube spécifiques via leurs identifiants (Channel ID).

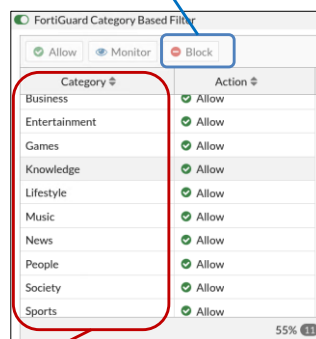
- Disponible depuis FortiOS 7

- Nécessite d'activer l'inspection SSL/SSH complète.
 - Nécessite une licence FortiGuard spécifique.
 - Nécessite le mode d'inspection proxy.
 - Nécessite une clé API YouTube (plusieurs API possibles).
 - L'API permet de faire correspondre les paramètres identifiés lorsque les utilisateurs accèdent au contenu YouTube aux catégories du FortiGate.

Filtrage Vidéo

- Filtrage vidéo par catégorie
 - Catégories de filtrage vidéo FortiGuard
 - Une catégorie FortiGuard combine plusieurs catégories des fournisseurs de contenus vidéo en une seule catégorie.
 - Par exemple, la catégorie vidéo FortiGuard « Entertainment » comprend diverses catégories YouTube telles que divertissement, comédie ou encore film.
 - Les catégories s'appliquent aux contenus hébergés par YouTube, Vimeo et Dailymotion.

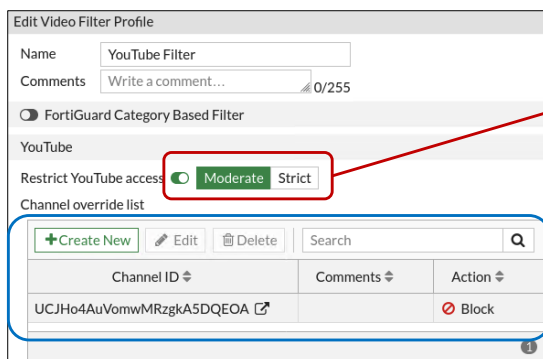
Empêche la vidéo et génère un log



11 catégories locales au FortiGate

Filtrage Vidéo

- Filtrage vidéo par niveau et par chaîne



Les utilisateurs ne reçoivent que le contenu qui est filtré selon le filtre « Moderate » ou « Strict » appliqué par Google.

Autoriser, surveiller ou bloquer l'accès à une chaîne YouTube selon son ID.

Chapitre 10

Antivirus

Objectifs

- A l'issue de ce chapitre, l'apprenant doit être capable de
 - Décrire les techniques antivirales du FortiGate.
 - Expliquer les différences entre le scan antivirus en mode proxy et en mode flow.
 - Configurer un profil antivirus et l'appliquer dans une règle de pare-feu.
 - Configurer le FortiGate pour scanner du trafic chiffré.
 - Mettre à jour l'antivirus d'un FortiGate.

Techniques antivirales

- **Analyse antivirus**
 - Objectifs de l'analyse antivirus en périphérie du réseau
 - **Empêche la propagation des menaces au sein du réseau**
 - Important si l'on ne peut pas contrôler l'antivirus de tous les postes du réseau (BYOD, WiFi guest).
 - Important car on ne peut pas installer l'antivirus sur tous périphériques du réseau (photocopieur, matériel médical ...).
 - **Préserve la réputation de l'IP publique de l'entreprise**
 - Empêche la distribution des malwares depuis l'IP de l'entreprise.
- **Analyse grayware**
 - Détecte les programmes non sollicités
 - Ils ne sont pas vraiment dangereux mais ont des effets secondaires indésirables (perte de productivité, ...) et sont donc classés comme logiciels malveillants.

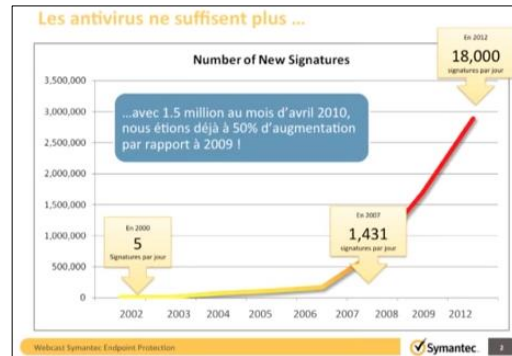
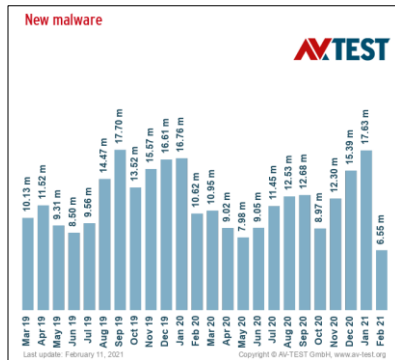
Techniques antivirales

- **Analyse par signature**
 - Signature virale
 - **A l'origine :**
 - Une signature est une suite continue de bits présents dans les malwares ou les fichiers infectés mais pas dans les fichiers non infectés.
 - **Actuellement :**
 - Différentes technologies sont utilisées pour alimenter les bases de données antivirus, mais on continue d'utiliser le terme signature.
 - Une signature peut être une partie de code, un hash d'un fichier malveillant, une combinaison d'attributs, des valeurs binaires à certains endroits, etc.
 - Principe de l'analyse par signature
 - Différentes technologies sont utilisées pour créer des signatures antivirus.
 - Les signatures sont téléchargées dans des bases de données sur le matériel.
 - Les antivirus scannent les fichiers à la recherche d'une correspondance dans leur base de données de signatures.

Techniques antivirales

Le cybercrime est une industrie

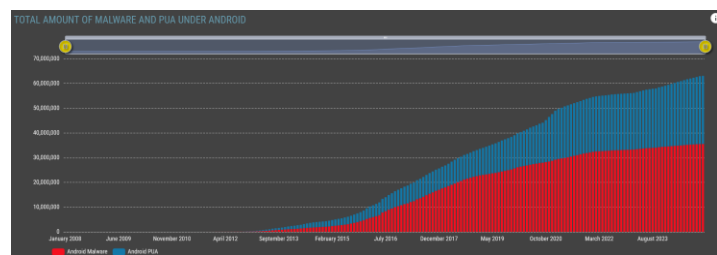
- Chaque jour, l'Institut AV-TEST enregistre plus de 350 000 nouveaux programmes malveillants (malware) et applications potentiellement indésirables (PUA).



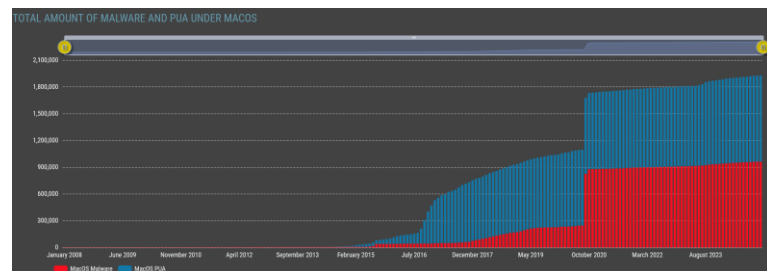
Techniques antivirales

Pas seulement sous Windows

Android



Mac OS



Techniques antivirales

- **Avantages de l'analyse par signature**
 - Le scan est très rapide.
 - Pas de faux positifs.
- **Limites de l'analyse par signature**
 - Il y a trop de signatures à devoir créer
 - Il y a tellement de variantes de malware qui sont créées chaque jour qu'il est impossible de maintenir les bases de données de signatures à jour.
 - Ne peut bloquer que les malwares connus (dont il existe une signature)
 - Le taux de détection peut donc être assez faible lors du premier mois du malware.
 - Nécessité de télécharger en continu une liste actualisée des signatures de virus connus.
 - Sensible à certains mécanismes d'obfuscation

Techniques antivirales

- **Limites de l'analyse par signatures (suite)**
 - Les pirates dissimulent leurs malwares en utilisant des techniques d'obfuscation telles que :
 - de la compression,
 - du polymorphisme,
 - du packer,
 - du chiffrement,
 - du dead code,
 - ...

En 2018, 93,6 % des logiciels malveillants observés étaient polymorphes.
[\(2020 Webroot Threat Report\)](#)

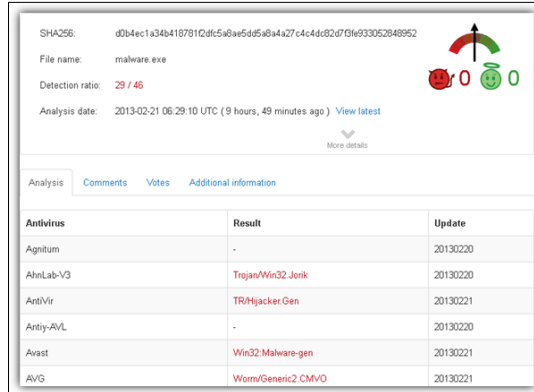


Techniques antivirales

- Antivirus multi-scanner ou multi-moteur

Online Multi-Engine Antivirus Scanners

- VirusTotal
- Jotti
- metadefender
- VirSCAN
- ...



SHA256: d0b4ec1a34b4187812dfc5a8ae5d5a8a4a27c4c4dc82d7bfe933052848952

File name: malware.exe

Detection ratio: 29 / 45

Analysis date: 2013-02-21 06:29:10 UTC (9 hours, 49 minutes ago) [View latest](#)

More details

Antivirus	Result	Update
Agnitum	-	20130220
AhnLab-V3	Trojan.Win32.Jonik	20130220
AntiVir	TR/Hijacker.Gen	20130221
Antiy-AVL	-	20130220
Avast	Win32:Malware-gen	20130221
AVG	Worm/Genetic2.CM/VO	20130221

Techniques antivirales

- AI-based malware detection* (anciennement scan Heuristique)

– Principe

- Utilise un modèle d'intelligence artificielle (IA)**
 - Formé sur d'immenses ensembles de menaces collectées par FortiGuard Labs.
- Analyse les comportements et les caractéristiques des fichiers**
 - Analyse du comportement lors de l'exécution du fichier : :
 - Par exemple, une application qui cherche à modifier des entrées de la base de registre ou ouvrir une connexion non sécurisée ou vers des adresses IP suspectes).
 - Attention, cela peut aussi être un comportement normal : par exemple lors de l'installation d'un driver.
 - Analyse des caractéristiques du fichier :
 - Par exemple, l'ajout de sections de fichiers supplémentaires non standard (comme .extra), une taille anormale d'une section, structure anormale des en-têtes ...
 - Décompose les fichiers pour détecter des motifs ou des structures typiques des logiciels malveillants.

Techniques antivirales

- *AI-based malware detection (suite)*

- Principe (suite)

- **Totalise l'ensemble des comportements et caractéristiques similaires à ceux d'un virus**
 - Le fichier peut alors être considéré comme
 - » Sain,
 - » Suspect (nécessitant un examen supplémentaire → sandbox),
 - » Malveillant (bloqué immédiatement).
 - Rend possible la détection de caractéristiques suspectes dans des fichiers non connus (zero-day).
 - **« AI scan » scanne uniquement certains types de fichiers (.exe, pdf, Microsoft Office)**

- Limitations

- **Risque de faux positifs**
 - Par défaut, les fichiers suspects ne sont pas bloqués (pour éviter les faux positifs).
 - **Consomme plus de ressources que le scan par signatures**
 - **Sensible à certains mécanismes d'obfuscation**

Techniques antivirales

- *Analyse du comportement via une sandbox*

- Environnement d'exécution virtuel sécurisé

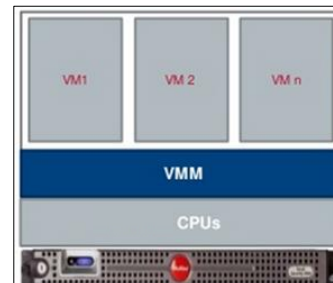
- Permet d'exécuter les fichiers afin d'analyser leurs comportements et révéler les menaces inconnues (pour lesquelles il n'existe pas de signature).
 - Détection des attaques zero-day avec un haut niveau de certitude.

- Détection et neutralisation

- En cas de détection, génération possible de signatures et transmission aux autres équipements de sécurité.

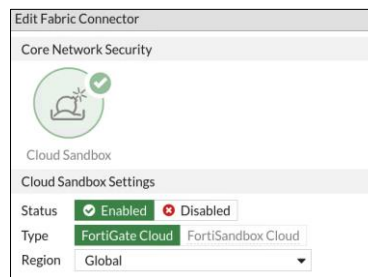
- Reporting

- Un rapport détaillé sur la menace est fourni après l'analyse.



Techniques antivirales

- **Analyse du comportement via une sandbox (suite)**
 - Analyse avec une sandbox locale
 - Plus rapide mais nécessite l'achat et la maintenance du boîtier.
 - Analyse avec une sandbox dans le cloud
 - Plus lent, mais pas besoin de faire la maintenance.
 - Attention à la taille maximale des fichiers uploadés.
 - Deux types : FortiGate cloud (SaaS) ou FortiSandbox cloud (PaaS).



398

Techniques antivirales

- **Limites de l'analyse par sandbox**
 - La configuration offrant la meilleure protection nécessite probablement trop de temps d'analyse.
 - Nombre limité de VM → Limite le nombre de fichiers analysés simultanément.
 - Les pirates utilisent des techniques d'évasion/obfuscation.
 - Plus lent que les autres types d'analyse.



Un malware peut passer inaperçu dans une sandbox



399

Techniques antivirales

- Exemples de techniques d'évasion

- Interaction humaine

- Le code malicieux nécessite une action humaine pour s'exécuter (un clic de souris, du scrolling, ...).

- Détection de sandbox

- Le malware essaie de détecter s'il se trouve dans une sandbox.
- S'il y arrive, la partie malicieuse reste en sommeil.

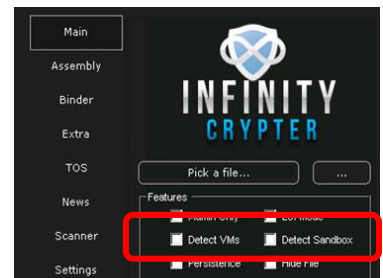
- Fragmentation des données

- Les paquets malicieux sont fragmentés en paquets plus petits.
- Ces petits paquets contenant chacun une partie du malware ne sont pas envoyés directement l'un après l'autre mais en attendant un certains laps de temps.

- Utilisation de packer ou crypter

- Programme dont le but va être de compresser et/ou chiffrer, par exemple des exécutables, pour cacher un objet malveillant.
- Utile pour les pirates mais aussi pour le pentesting.

...



Source : <http://hackshound.blogspot.be/2015/01/infinity-crypter-cracked-latest-version.html>

Protection anti-malware

- Protection contre les malwares

- Mécanismes d'évasion, nombreux nouveaux malwares, ...

→ Nécessité d'analyser en continu (pas juste à un moment).

→ Nécessité d'avoir un plan B si un malware passe quand même.

AGIR :

- AVANT

- PENDANT

- APRES

- Sécurité rétrospective

- Analyse rétrospective

- Il faut pouvoir réévaluer ce fichier plus tard afin de vérifier s'il est toujours sain.

- Analyse forensique

- Analyse d'un système informatique après incident.

- Il est avantageux de pouvoir disposer de points de contrôle à différents endroits du réseau (défense en profondeur)

- NGFW.
- Web security appliance.
- Email security appliance.
- Endpoints protection.
- Private cloud virtual appliance.
- ...

Protection anti-malware

- Protection contre les malwares
 - Exemple d'importance d'une protection rétrospective et d'une bonne visibilité.



Dans cet exemple, les systèmes de sécurité n'ont pas vu qu'il s'agissait d'un malware lorsqu'il est entré dans le réseau.

Source : Cisco System Inc., Allez au-delà du contrôle et de la visibilité sur les applications. Choisissez un next-generation firewall axé sur les menaces. Webinar du 29 Septembre 2016

Modes d'inspection

- Flow-based inspection mode
 - Mode flux (Pas de proxy)
 - Les paquets sont mis en cache et transmis immédiatement
 - Comme le fichier est transmis en même temps, il consomme plus de CPU que le mode proxy-based.
 - Avantageux de disposer de puces FortiAsic.
 - Supporte moins de fonctions de sécurité (pas SSH, pas MAPI ...).
 - A l'exception du dernier paquet, les paquets ne sont pas retardés
 - Il est nécessaire d'extraire la charge utile pour découvrir si elle est virale.
 - Les clients perçoivent moins de latence qu'avec le mode proxy-based.

Security Profiles > AntiVirus

Edit AntiVirus Profile

Name: default

Comments: Scan files and block viruses. 29/255

AntiVirus scan: ☒ Block ☐ Monitor

Feature set: ☒ Flow-based ☐ Proxy-based

Modes d'inspection

- *Flow-based inspection mode (Cont.)*

2. Une copie des paquets est conservée en mémoire tampon

- **Le moteur antivirus scanne le fichier**
 - Uniquement lorsque le dernier paquet est bufférisé.
 - Ce dernier paquet n'est pas transmis, on attend le résultat du scan.
- **Fichiers de grande taille**
 - Les fichiers de taille supérieure à celle de la mémoire tampon ne sont pas scannés.
- **Full scan**
 - Le scan utilise l'entièreté de la base de données antivirus configurée (Normal, extended ou extreme → Extended par défaut)

3. Si le fichier est sain :

- Le dernier paquet est transmis à la fin du scan.

Modes d'inspection

- *Flow-based inspection mode (Cont.)*

4. Si le fichier est suspect

- **Le dernier paquet des fichiers suspects n'est pas transmis**
 - La connexion est alors réinitialisée.
- **Si le virus est détecté alors que des paquets ont déjà été envoyés au client :**
 - Le client ne reçoit pas de message signalant le blocage du fichier.
 - L'UTM place en cache l'URL du fichier.
 - » Si le client tente de retélécharger le fichier, un message de blocage est envoyé.
- **Si le virus est détecté au début du flux**
 - Un message de blocage est envoyé dès la première tentative de téléchargement.

Si la performance est votre priorité, le mode d'inspection de flux est plus approprié.

Modes d'inspection

- *Proxy-based inspection mode*

1. Le proxy du protocole concerné intercepte la connexion et bufferise le fichier

- Transparent pour l'utilisateur.
- Aucune partie du fichier n'est transmise à l'utilisateur.

2. Le moteur antivirus examine le fichier entièrement bufferisé

- **Scanne le fichier jusqu'à**

- La taille maximum définie.
- La taille de la mémoire tampon.



Les virus sont souvent détectés dans les deux premiers Mo du fichier.

- **Un grand fichier ne peut pas être scanné**

- Nécessité d'avoir aussi un A-V sur le poste client.
- Possibilité de laisser passer ou bloquer les fichiers > à la taille de la mémoire tampon.

- **Full scan**

- Le scan utilise l'entièreté de la base de données antivirus configurée (Normal, extended ou extreme).

Modes d'inspection

- *Proxy-based inspection mode (Cont.)*

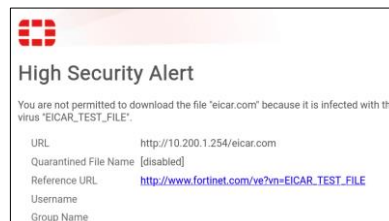
3. Si les fichiers sont sains

- Les paquets sont transmis uniquement à la fin du scan.
- Une latence perceptible par les utilisateurs est possible.
 - Suivant les performances de l'UTM et la quantité de trafic à traiter.
- Si tous les paquets ne sont pas reçus suffisamment rapidement, le client pourrait mettre fin à la connexion.
 - Il est possible de configurer le proxy pour délivrer lentement les paquets afin de permettre au client de ne pas mettre fin à la connexion (confort client).

4. Les fichiers suspects sont soumis à l'action pass ou block

- Si l'action est block, aucun paquet n'a été transmis aux clients.
- Les clients sont toujours informés du blocage du fichier via un message.

Si la sécurité est votre priorité, le mode d'inspection par proxy est plus approprié.



Modes d'inspection

- Comparaison des modes d'inspection

Flow-based

Edit AntiVirus Profile

Comments: Write a comment...

AntiVirus scan: ☒ Block ☒ Monitor

Feature set: ☒ Flow-based ☐ Proxy-based

Inspected Protocols

HTTP ☒
 SMTP ☒
 POP3 ☒
 IMAP ☒
 FTP ☒
 CIFS ☐

APT Protection Options

Treat Windows executables ☒

Proxy-based

Edit AntiVirus Profile

Name: AV-Monitor

Comments: Write a comment...

AntiVirus scan: ☒ Block ☒ Monitor

Feature set: ☐ Flow-based ☒ Proxy-based

Inspected Protocols

HTTP ☒
 SMTP ☒
 POP3 ☒
 IMAP ☒
 FTP ☒
 CIFS ☐
 MAPI ☒
 SSH ☒

APT Protection Options

Content Disarm and Reconstruction ☒

Configuration de l'antivirus

- Configuration des options de protocole

→ Les options de protocole sont utilisées par les antivirus mais aussi par d'autres profils de Sécurité (filtrage Web, DLP, ...)

Permet l'analyse antivirus des e-mails Microsoft Exchange Server qui utilisent le protocole RPC sur HTTP.

Configuration du mappage de ports (plusieurs ports possibles).

Policy & Objects > Protocol Options

Edit Proxy Options

Name: default

Comments: All default services. 21/255

Log Oversized Files ☐

RPC over HTTP ☒

Protocol Port Mapping

HTTP	☒	Any	Specify	80
SMTP	☒	Any	Specify	25
POP3	☒	Any	Specify	110
IMAP	☒	Any	Specify	143
FTP	☒	Any	Specify	21
NNTP	☒	Any	Specify	119
MAPI	☒	135		
DNS	☒	53		

Configuration de l'antivirus

- Configuration des options de protocole (suite)

Envoie petit à petit le fichier au client pendant qu'il est scanné. Évite que les clients impatients annulent le téléchargement en ne le voyant pas démarrer. Disponible pour HTTP(S) et FTP(S).

Bloque les fichiers de taille > Threshold(MB)
 Permet de fixer à partir de quelle taille les fichiers ne seront pas scannés mais directement bloqués.

Certains serveurs temps réel peuvent envoyer des données à un applet en utilisant des messages HTTP. Le proxy AV ne détectera jamais la fin du flux TCP et pourrait donc bloquer le flux.

Policy & Objects > Protocol Options



410

Configuration de l'antivirus

- Configuration des options de protocole (suite)

Autorise les fichiers fragmentés.
 Anciennement utilisé par les messageries pour fragmenter les mails volumineux et transmettre les fragments en parallèle sur des lignes bas débit.

Policy & Objects > Protocol Options

Permet de s'assurer que les emails sortant contiennent tous les termes souhaités par l'entreprise (par exemple des clauses de non responsabilité). Cette signature annexe est ajoutée après la signature personnelle de l'utilisateur.



411

Configuration de l'antivirus

- Gestion des grands fichiers en CLI

- L'option **oversize-log**

- Quand elle est activée, FortiGate consigne si des fichiers grande taille ont été bloqués ou autorisés à passer.
 - Permet de savoir si le FortiGate voit passer beaucoup de grands fichiers afin de déterminer s'il est intéressant de les bloquer ou non.

- L'option **oversize-limit** permet d'ajuster la taille du buffer (10Mo par défaut)

- Un buffer plus petit permet de réduire la latence et utilise moins de RAM.
 - Un buffer plus grand améliore la sécurité en permettant de scanner de plus gros fichiers mais consommera plus de mémoire.

- L'option **oversize** bloque les fichiers plus grands que le buffer.

```
config firewall profile-protocol-options
edit <profile_name>
  set oversize-log {enable|disable}
config <protocol_name>
  set oversize-limit [1-<model_limit>]
  set options oversize
end
```

Configuration globale.

Configuration par protocole



412

Configuration de l'antivirus

- Gestion des grands fichiers (suite)

- Seuil par défaut de 10Mo

- Avec le seuil par défaut de 10 Mo, seulement 0,01% des virus passent.

	1MB	2MB	3MB	4MB	5MB	6MB	7MB	8MB	9MB	10MB
exploit	99.83%	99.95%	99.97%	99.97%	99.98%	99.98%	99.99%	100%	100%	100%
mass-mailer	99.62%	99.87%	100%	100%	100%	100%	100%	100%	100%	100%
phish	100%	100%	100%	100%	100%	100%	100%	100%	100%	100%
spyware	95.08%	97.97%	98.88%	99.47%	99.76%	99.83%	99.89%	99.91%	99.94%	99.95%
trojan	97.52%	99.24%	99.62%	99.80%	99.88%	99.93%	99.95%	99.97%	99.98%	99.98%
virus	98.27%	99.37%	99.63%	99.80%	99.88%	99.93%	99.95%	99.97%	99.98%	99.99%
worm	99.02%	99.65%	99.74%	99.86%	99.89%	99.92%	99.94%	99.94%	99.95%	99.96%

Source : Fortinet Inc.



413

Configuration de l'antivirus

- Gestion des fichiers compressés

- Compression et scan antivirus

- Si un fichier est compressé, sa signature est différente.
 - Il est donc nécessaire de décompresser le fichier avant le scan.

- Décompression des fichiers

- Il faut utiliser le bon algorithme de décompression.
 - Certains format de compression peuvent être trouvé en analysant les en-têtes du fichier.
 - Fichiers compressés protégés par mot de passe
 - L'UTM ne pourra pas décompresser ni scanner le fichier !

- Compressions imbriquées (nested archive)

- Si un fichier a été compressé plusieurs fois, l'UTM décompressera tous les niveaux de compression.
 - Jusqu'à 12 niveaux par défaut.
 - Modifiable jusqu'à 100 niveaux (attention à la consommation de RAM).

Configuration de l'antivirus

- Gestion des fichiers compressés (suite)

- Taille limite

- La taille limite des fichiers compressés est différente de celle des autres fichiers.

Configuration par protocole

```

config firewall profile-protocol-options
edit <profile name>
config <protocol_name>
set uncompressed-oversize-limit [1-<model_limit>]
set uncompressed-nest-limit [1-100]
end
end
  
```

Fixe la taille maximale des fichiers décompressés qui seront soumis au scan antivirus

Fixe le nombre de compressions imbriquées maximales que l'UTM pourra décompresser

Configuration de l'antivirus

- Activer l'antivirus
 - Pour que le profil de sécurité antivirus défini soit actif, il faudra l'appliquer à une règle de pare-feu.

Activer l'inspection SSL/SSH et sélectionner "deep-inspection" afin de pouvoir contrôler le trafic chiffré

Policy & Objects > IPv4 Policy

Security Profiles		
AntiVirus	☒	default
Web Filter	☐	
DNS Filter	☐	
Application Control	☐	
IPS	☐	
SSL Inspection	☒	deep-inspection

Configuration de l'antivirus

- Eicar test file
 - Fichier qui a une signature correspondant à un virus mais qui ne contient pas de charge active.

www.eicar.org/86-0-Intended-use.html

ABOUT US CONFERENCE PROJECTS **ANTI-MALWARE TESTFILE** TRUSTWORTHY

Download area using the standard protocol http

eicar.com	eicar.com.txt	eicar_com.zip	eicarcom2.zip
68 Bytes	68 Bytes	184 Bytes	308 Bytes

Download area using the secure, SSL enabled protocol https

eicar.com	eicar.com.txt	eicar_com.zip
68 Bytes	68 Bytes	184 Bytes

INTENDED USE

DOWNLOAD

High Security Alert!!

You are not permitted to download the file "eicar_com.zip" because it is infected with the virus "EICAR_TEST_FILE".

URL = http://www.eicar.org/download/eicar_com.zip

File quarantined as: .

http://www.fortinet.com/ve?vn=EICAR_TEST_FILE

Client IP: 192.168.2.15

Server IP: 188.40.238.250

User name:

Group name:

Configuration de l'antivirus

- Activez la journalisation (règle de pare-feu)

Log & Report > Security Events

Summary	Logs
3 Events	
AntiVirus 2	
Top Virus/Botnet	
EICAR_TEST_FILE	

Summary	Logs					
Q Search						
AntiVirus - Disk - 1 hour - Details						
Date/Time	Service	Source	File Name	Virus/Botnet	User	Action
2023/09/13 00:49:19	FTP	10.0.1.10	eicar.com	EICAR_TEST_FILE	Host: 10.200.1.254	Blocked
2023/09/13 00:49:19	FTP	10.0.1.10	eicar.com	EICAR_TEST_FILE	Host: 10.200.1.254	Blocked
2023/09/13 00:43:57	HTTP	10.0.1.10	eicar.com	EICAR_TEST_FILE	URL: http://10.200.1.254/eicar.com	Blocked
2023/09/13 00:43:12	HTTP	10.0.1.10	eicar.com	EICAR_TEST_FILE	URL: http://10.200.1.254/eicar.com	Blocked

Log Details
Protocol: 6
Service: HTTP
Data
File Name: eicar.com
Action
Action: Blocked
Threat: 2
Policy ID: 1 (Full Access)
Policy UID: b11a50c-792b-51e7-4600-12029
Policy Type: Firewall
Security
Level: Warning
Threat Level: Critical
Threat Score: 50
Cellular
Service: HTTP
AntiVirus
Profile: default
Virus/Botnet: EICAR_TEST_FILE
Virus ID: 2.172
Reference: http://www.fortinet.com/venom/EICAR_TEST_FILE
Detection Type: cached
Direction: Incoming
Quarantine Skip: Quarantine-disabled
Submitted to FortiSandbox: false
Message: File is infected.

Log & Report > Forward Traffic

Date/Time	Source	Destination	Application Name	Result	Policy ID
2023/09/13 00:50:20	10.0.1.10	10.200.1.254	FTP	Accept (1.61 kB / 1.73 kB)	1 (Full Access)
2023/09/13 00:49:24	10.0.1.10	10.200.1.254	tcp/63214	Deny (Deny: UTM Blocked)	1 (Full Access)
2023/09/13 00:49:24	10.0.1.10	10.200.1.254	tcp/21070	Deny (Deny: UTM Blocked)	1 (Full Access)
2023/09/13 00:49:24	10.0.1.10	10.200.1.254	tcp/35516	Deny (Deny: UTM Blocked)	1 (Full Access)

Configuration de l'antivirus

Dashboard > Security

- Dashboard widget
 - Widget fournissant des statistiques en temps réel

Dashboard
Status
interface
+
FortiView Sessions
FortiView Sources
Top Threats
DHCP Monitor
Asset Inventory Monitor
FortiView Source Interfaces
Top System Events
FortiView Destinations
Physical Topology
+

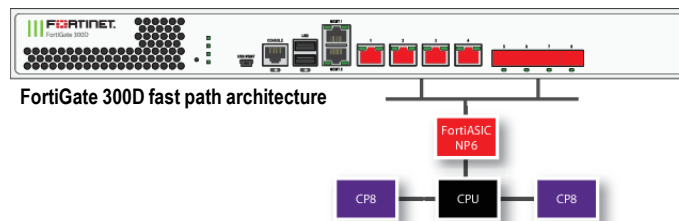


System
Top System Events
Show system events.
Security
Assets - Vulnerabilities
Monitor vulnerabilities of connected assets.
Compromised Hosts
Show all compromised hosts.
FortiSandbox Files
Show scan results for files that have been submitted to FortiSandbox for inspection.

Accélération matérielle

• Hardware acceleration

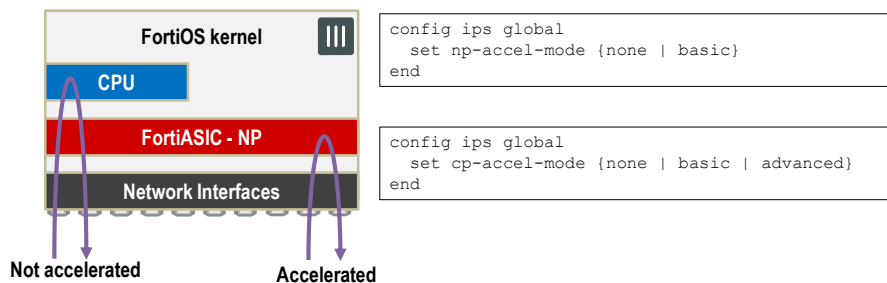
- Certains modèles FortiGate possèdent des puces spécialisées
 - Ces puces peuvent décharger le processeur des tâches d'inspection pour améliorer les performances
 - Les modèles FortiGate avec NTurbo (NP4 ou NP6).
 - Les modèles FortiGate avec SoC3.
- Accélération matérielle uniquement disponible en mode flow-based



Accélération matérielle

• Hardware acceleration

- Ce qui peut être accéléré et la manière dont l'accélération s'effectue dépend du type de puce utilisée (NP, CP, SP)



Configuration de l'antivirus

- Recommandations

- Activer le scan antivirus
 - En bordure de réseau, pour tout le trafic Internet, avec SSL deep-inspection.
 - Sur tous les FW d'un cluster HA.
- Configurez les mises à jour automatique Fortiguard (push updates)
 - Si l'UTM le supporte, activer la base de données de virus étendue.
- Journalisez les événements de sécurité
 - Activez la journalisation des fichiers trop grands pour être scannés.
 - Examinez périodiquement les journaux antivirus.
- Activez l'option "Treat Windows Executables in Email Attachments as Viruses"

Recommandations

- Recommandations (suite)

- N'augmentez pas la taille maximale des fichiers à scanner, sauf si cela est nécessaire
 - Généralement pas nécessaire car les virus sont souvent des petits fichiers.
 - Cela consommerait plus de mémoire.
- Utilisez l'accélération matérielle
 - Uniquement en mode flow-based.
 - En mode proxy, le trafic ne peut pas être accéléré.
- Ne vous limitez pas à l'antivirus du FortiGate
 - Utilisez un antivirus sur toutes les stations de travail.
 - Utilisez une sandbox.

Dépannage

• Résolution de problème

- Le service FortiGuard update est-il accessible ?
 - Vérifiez votre connexion à l'internet.
 - Vérifiez que le FortiGate est capable de résolutions DNS (update.fortiguard.net).
 - Vérifiez que le port TCP 443 est ouvert.
- La licence FortiGuard est-elle toujours valide?

System > FortiGuard

Advanced Malware Protection	Licensed (Expiration Date: 2026/01/19)
AI Malware Detection Model	Version 2.05360
AntiVirus Definitions	Version 90.01635
AntiVirus Engine	Version 7.00018
Mobile Malware	Version 90.01635
Outbreak Prevention	Licensed (Expiration Date: 2026/01/19)

Dépannage

• Résolution de problème

- La version de la base de données antivirus est-elle à jour?

- Consultez le site web FortiGuard <https://fortiguard.com/updates/antivirus>

Updated: Apr 20th, 2020 - 01:42
Added (24)
Modified (77)
Latest Versions
76.834

- Démarrer une mise à jour manuelle.

```
# execute update-av
```

- Le scan antivirus ne détecte pas les virus

• Vérifiez la configuration

- Vérifiez que le profil antivirus est appliqué sur au moins une règle de pare-feu.
- Vérifiez que le bon profil antivirus est sélectionné.
- Vérifiez que les options de protocole sont correctes.
- Vérifiez que le profil d'inspection SSH/SSL permet de scanner le trafic chiffré.
- Vérifiez que la configuration antivirus s'applique bien à toutes les connexions redondantes.

Dépannage

- Résolution de problème
 - Utiliser les commandes de dépannage

```
# get system performance status
→ Affiche les statistiques sur les virus pour la dernière minute écoulée.

# diagnose antivirus database-info
→ Affiche les informations de la base de données antivirus utilisée

# diagnose autoupdate versions
→ Affiche les versions actuelles du moteur antivirus et des signatures

# diagnose antivirus test "get scantime"
→ Affiche la durée d'analyse des fichiers infectés

# diagnose debug enable
→ active le débogage.

# diagnose debug application update -1
→ Affiche des informations détaillées de débogage relatives aux mises à jour
```

Compléments

Antivirus

Antivirus FortiGate

- **Scan Antivirus**
 - Moteur antivirus et base de données de signatures
 - **Chaque antivirus est constitué**
 - D'un moteur de détection.
 - D'une base de données de signatures de virus.
 - Chaque éditeur utilise ses propres moteurs de détection et ses signatures.
 - **Le nom d'un virus est composé de deux parties**
 - <vector>/<pattern> : W32/Kryptik.EMT!tr
 - <vector> : Toujours le même pour le même virus
 - » W32 pour Windows 32 bits,
 - » W64 pour Windows 64 bits
 - » OSX pour Apple Mac
 - » JS pour JavaScript
 - » ...
 - <pattern> : Varie selon le vendeur de solution A-V.

Antivirus FortiGate

- **Scan Antivirus (suite)**
 - Liste des Virus
 - <https://fortiguard.com/updates/antivirus>

Updated: Apr 10th, 2020 - 16:50
+ Added (19)

Updated: Apr 10th, 2020 - 17:49
+ Added (38)

Updated: Apr 10th, 2020 - 19:23
+ Added (12)

Updated: Apr 10th, 2020 - 20:58
+ Added (41)



Name	Status	Update
Adware/Ewind!Android	+	Sig Added
Android/Agent.BDS!tr.spy	+	Sig Added
W32/Agent.LOF!tr	+	Sig Added
W32/Agent.TJAX!tr.pws	+	Sig Added
W32/Alien.IMFJKXJ!tr	+	Sig Added
W32/CUOZ!tr	+	Sig Added
W32/CIQZ.MW!tr	+	Sig Added

- Scan Antivirus (suite)

At a glance:

ID	8203943
Released	Apr 10, 2020
Description Updated	Apr 10, 2020

Detection Availability

FortiGate	
Active	☐
Extended	☒
Extreme	☐
Mobile	☐

Virus

W32/Agent.OFI!tr

Analysis

W32/Agent.OFI!tr is classified as a trojan. A trojan is a type of malware that performs activities without the user's knowledge. These activities commonly include establishing remote access connections, capturing keyboard input, collecting system information, downloading/uploading files, dropping other malware into the infected system, performing denial-of-service (DoS) attacks, and running/terminating processes. The Fortinet Antivirus Analyst Team is constantly updating our descriptions. Please check the FortiGuard Encyclopedia regularly for updates.

- Mise à jour de la base de données de signatures antivirales

- Prérequis

- Nécessite une souscription à FortiGuard antivirus.
- Nécessite d'avoir activé le scan antivirus dans au moins une règle de pare-feu.

- Vérifier si l'antivirus est à jour

System > FortiGuard

AntiVirus	Licensed (Expires on 2017-03-17)	Upload Package
AV Definitions	Version 35.00254	
AV Engine	Version 5.00234	

```
config antivirus settings
  set default-db {normal | extended | extreme}
End

diagnose autoupdate status
diagnose autoupdate versions
```

- Choisir une base de données de signatures (CLI only)

- **Normal** : Inclut les signatures d'attaques récentes courantes.
 - **Extended** : Inclut plus de signatures de virus, actifs ou non.
 - **Extreme** : Inclut une DB de virus étendues ainsi que les anciens virus dormants.
- Non disponible sur tous les modèles de FortiGate

Antivirus FortiGate

- Mise à jour de la base de données de signatures antivirus (suite)
 - Méthodes de mise à jour

System > FortiGuard

FortiGuard Updates

Scheduled updates ☒ Every ☐ Daily ☐ Weekly ☒ Automatic

Improve IPS quality ☐

Use extended IPS signature package ☒

AntiVirus PUP/PUA ☒

Update server location ☐ Lowest latency locations ☒ Restrict to ☐ US only ☐ EU only

Active l'analyse antigrayware

Techniques antivirus

- FortiGuard Protection Services
 - Virus Outbreak Prevention
 - Virus n'ayant pas encore de signature**
 - Il faut un certain temps pour créer et distribuer une signature de virus, ce qui peut laisser le temps à un nouveau virus de se répandre.
 - Principe**
 - Virus Outbreak Prevention permet de filtrer des virus n'ayant pas encore de signature en se basant sur des hashes.
 - Une requête est envoyée en temps réel à Fortiguard pour obtenir une évaluation basée sur les hashes du fichier.
 - Nécessite une licence Zero-Hour Virus Outbreak (ZHVO)**

Virus Outbreak Prevention ☐

Use FortiGuard Outbreak Prevention Database ☐

Use External Malware Block List ☒

Techniques antivirales

• FortiGuard Protection Services (suite)

– Malware block list

- **Liste de malwares complémentaire à la DB FortiGate**
 - Il est possible d'enrichir la base de données antivirus en liant à FortiGate une liste externe de hash à bloquer.
- **La liste est hébergée sur un serveur web**
 - Disponible via l'URL HTTP(S) définie dans la "Security Fabric malware hash list".
 - Elle se présente sous la forme d'un fichier texte contenant une liste de hachages MD5, SHA1 et SHA256.
- **Connecteur Security Fabric**
 - La liste de blocage peut être définie comme un connecteur Security Fabric et configurée pour extraire la liste de façon dynamique.
 - La fréquence de rafraîchissement peut être configurée.



434

Techniques antivirales

• FortiGuard Protection Services (suite)

– Content Disarm and Reconstruction (CDR)

- **Principe**
 - Certains malwares ne sont présents que dans une partie d'un fichier.
 - » Les documents Microsoft Office sont structurés comme des fichiers ZIP, contenant des dossiers avec un certain nombre de fichiers différents.
 - CDR enlève les contenus de fichiers jugés malicieux, exploitables ou non sûrs mais envoie le reste du document à l'utilisateur.
 - FortiGate envoie le fichier original (complet) à une sandbox pour inspection.
 - Le client reçoit la version propre du document qui contient une page de couverture renvoyant vers le document original via la sandbox.
- **Contenus et protocoles supportés**
 - Fichiers PDF, fichiers Microsoft Office.
 - Téléchargement Web HTTP, l'envoi d'e-mails SMTP, la réception d'e-mails IMAP et POP3 (MAPI n'est pas pris en charge).



435

Antivirus FortiGate

- Scan antigrayware

- Grayware

- Applications ou fichiers qui ne sont pas considérés comme des virus mais qui peuvent avoir des effets indésirables (par exemple les adwares).
 - Ils ne sont pas franchement malveillants, mais ils ne sont pas non plus inoffensifs.
 - Peuvent faire perdre du temps, de la productivité ou consommer des ressources.

- Grayware Scan

- Les graywares sont détectables de la même manière que les virus.
 - Souvent ils sont détectés avec une simple signature.

- Sur FortiGate, la protection contre les graywares est activée par défaut

<pre># config antivirus setting (settings)# set grayware {enable disable} (settings)# end</pre>	<pre>FGT60D4Q16067135 (settings) # get default-db : extended grayware : enable</pre>
--	--

Antivirus FortiGate

- AI Scan

- Activer le scan heuristique (CLI uniquement)

```
config antivirus settings
  set machine-learning-detection {enable| monitor | disable}
end
```

- Options

- **enable**
 - Active le scan heuristique et la journalisation.
 - Laisse passer les fichiers suspects.
 - **monitor**
 - Active le scan heuristique et la journalisation.
 - Ne laisse pas passer les fichiers suspects.
 - **disable**
 - Désactive le scan heuristique.

Conseil :

Commencer par utiliser l'option *monito* afin d'analyser les logs et pouvoir mieux déterminer les éléments à bloquer.

Ordre des scans

1. Scan antivirus
2. Scan antigrayware
3. Scan heuristique

« Conserve mode »

- **Conserve mode**
 - **Quantité de mémoire limitée**
 - Si la mémoire vient à manquer, FortiOS ne peut plus s'acquitter de ses tâches et pourrait agir de manière inattendue.
 - Pour éviter cette incertitude, FortiOS entre en « conserve mode ».
 - **Seuils**
 - **Seuil « red » (par ex. 88% de mémoire utilisée)**
 - FortiOS entre en « conserve mode » lorsqu'il atteint le seuil rouge:
 - » Il génère des messages de journal (log).
 - » Il génère des trap SNMP.
 - » Il affiche une bannière qui apparaît sur l'interface graphique.
 - **Seuil extrême (Par ex. 95% de mémoire utilisée)**
 - Le « conserve mode » se poursuit, de plus les nouvelles sessions sont abandonnées.
 - **Seuil « green » (Par ex. 82 % de mémoire utilisée)**
 - Le conserve mode se poursuit jusqu'à ce que l'utilisation de la mémoire soit réduite au seuil « green ».

« Conserve mode »

- **Fonctionnement de l'antivirus en « conserve mode »**
 - **Off**
 - Tout trafic devant être inspecté par le proxy antivirus est bloqué.
 - Les nouvelles sessions ne sont pas autorisées, mais les sessions en cours continuent d'être traitées normalement, à moins qu'elles ne demandent plus de mémoire.
 - A utiliser lorsque la sécurité est plus importante qu'une perte d'accès momentanée.
 - **Pass**
 - Permet au trafic de continuer vers sa destination mais aucune analyse antivirus n'est effectuée.
 - Les profils de sécurité n'utilisant pas le proxy antivirus sont effectués normalement.
 - **One-shot**
 - Similaire au paramètre « pass » mais l'antivirus reste dans ce mode même après avoir quitté le « conserve mode ».
 - Il reprend l'utilisation du proxy AV uniquement lorsque le paramètre av-failopen est modifié ou lorsque le FortiGate est redémarré.

« Conserve mode »

- Configuration du « Conserve mode »

- Configuration des seuils

- Fortinet recommande de ne pas les modifier

```
config system global
    set memory-use-threshold-extreme 95
    set memory-use-threshold-red 88
    set memory-use-threshold-green 82
end
```

- Vérification des seuils

```
FGVM # diagnose hardware sysinfo conserve
memory conserve mode: off
total RAM: 994 MB
memory used: 448 MB 45% of total RAM
memory used threshold extreme: 944 MB 95% of total RAM
memory used threshold red: 874 MB 88% of total RAM
memory used threshold green: 815 MB 82% of total RAM
```

« Conserve mode »

- Configuration du « Conserve mode » (suite)

- Configuration du paramètre « av-failopen »

```
config system global
    set av-failopen {pass | off | one-shot}
end
```

- Vérifier si le FortiGate est en « conserve mode »

- conservemode: 0 → Le FortiGate n'est pas en "conserve mode"
 - conservemode: 1 → Le FortiGate est entré en "conserve mode"

```
# diag hardware sysinfo shm
SHM counter: 67
SHM allocated: 1556480
SHM total: 101220352
conservemode: 0
```